



Research Report

ASHER BRASS-GERSHOVICH, RACHEL STERATORE, WESLEY HURD,
HENRY ALEXANDER BRADLEY, ANJAY FRIEDMAN, SELLA NEVO

Securing AI Algorithmic Insights

For more information on this publication, visit www.rand.org/t/RR-A4685-1.

About RAND

RAND is a research organization that develops solutions to public policy challenges to help make communities throughout the world safer and more secure, healthier and more prosperous. RAND is nonprofit, nonpartisan, and committed to the public interest. To learn more about RAND, visit www.rand.org.

Research Integrity

Our research integrity is grounded in RAND's core values of quality and objectivity. Rigorous quality assurance procedures, conflict of interest screening, and transparency in funding ensure that every study is objective and nonpartisan. Learn more at www.rand.org/integrity.

RAND's publications do not necessarily reflect the opinions of its research clients and sponsors.

Published by the RAND Corporation, Santa Monica, Calif.

© 2026 RAND Corporation

RAND® is a registered trademark.

Limited Print and Electronic Distribution Rights

This publication and trademark(s) contained herein are protected by law. This representation of RAND intellectual property is provided for noncommercial use only. Unauthorized posting of this publication online is prohibited; linking directly to its webpage on rand.org is encouraged. Permission is required from RAND to reproduce, or reuse in another form, any of its research products for commercial purposes. For information on reprint and reuse permissions, visit www.rand.org/about/publishing/permissions.

About This Report

This report extends the framework from the RAND report *Securing AI Model Weights* to address the challenge of protecting *algorithmic insights*—that is, the techniques and design know-how that drive artificial intelligence (AI) progress.¹ Unlike model weights, which can be centralized and secured, insights are distributed across code, documentation, communications, and human expertise, making them far harder to contain.

Using expert engagements, a targeted literature review, and a gap analysis, we define five insight security levels that are aligned with five adversary operational capacities. The framework is descriptive rather than prescriptive, offering a structured way to assess what level of protection would be required to defend a given insight against a specific adversary capability.

We explore three central themes: the broad and human-centric attack surface for insights, the role of compartmentalization as a core security principle, and the organizational trade-offs that accompany higher protection levels. With this report, we aim to inform policymakers, AI developers, and security practitioners seeking to understand what securing algorithmic insights would entail and how such measures could be implemented as AI capabilities advance.

Center on AI, Security, and Technology

RAND Global and Emerging Risks is a division of RAND that delivers rigorous and objective public policy research on the most consequential challenges to civilization and global security. This work was undertaken by the division's Center on AI, Security, and Technology (CAST), which aims to examine the opportunities and risks of rapid technological change, focusing on artificial intelligence, security, and biotechnology. For more information, contact cast@rand.org.

Funding

This research was independently initiated and conducted within the Center on AI, Security, and Technology using income from operations and gifts and grants from philanthropic supporters. A complete list of donors and funders is available at www.rand.org/CAST. RAND clients, donors, and grantors have no influence over research findings or recommendations.

Acknowledgments

We are grateful to the many individuals who contributed to this report. We thank Frank Lugo for his early analysis and insights that helped shape the report's foundation. We are especially appreciative of our communications analyst, David Adamson, for sharpening our work and bringing clarity to the report's key insights. We also thank Rosa Maria Torres for her expert engagement coordination and the final touches that strengthened the report. Our gratitude extends to Kyle Siler-Evans and the CAST leadership team for their steady guidance, feedback, and input that contributed greatly to the report's success. Finally, we thank Michael Vermeer and Michael Sulmeyer for their thoughtful reviews and valuable input.

¹ Sella Nevo, Dan Lahav, Ajay Karpur, Yogev Bar-On, Henry Alexander Bradley, and Jeff Alstott, *Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models*, RAND Corporation, RR-A2849-1, 2024.

Summary

Algorithmic insights—the novel techniques, methods, and design know-how that materially improve artificial intelligence (AI) systems—are among the most strategically valuable assets in the AI ecosystem. Across language models evaluated from 2012 to 2023, the compute required to reach a fixed performance threshold fell by half approximately every eight months due to algorithmic efficiency improvements, which is equivalent to roughly a threefold annual gain in effective compute. Theft or leakage of these insights could compress years of AI progress for adversaries, and some insights might also lower barriers to dangerous capabilities, making their protection a matter not only of commercial interest but of national security.

Unlike model weights, which can be centralized on secured servers, algorithmic insights resist centralization: They exist as part of code, documentation, communications, and human knowledge, and the insights can leak through low-bandwidth channels, such as conversations or observable screens. Although insights’ distributed nature makes them harder to protect than weights, the challenge is not intractable. Organizations can take concrete, practical steps to substantially reduce the risk of unauthorized access to such insights. Furthermore, the measures required at lower security levels (SLs) align closely with industry best practices that most frontier AI developers might already be implementing.

In this report, we extend a framework from the RAND report *Securing AI Model Weights* (SMW) to provide the first systematic roadmap for protecting algorithmic insights.² We define five insight security levels (ISLs) aligned with five adversary operational capacities (OCs), identify 44 attack vectors, and provide benchmark security systems for each level. The framework is intentionally descriptive rather than prescriptive: **It provides a tool for answering the conditional question, “If an organization wishes to—or is expected to—secure insight X against an adversary with capability level Y, what security posture would likely be required?”** After answering this question, organizations can make informed decisions about which insights warrant security investments using their own assessments, priorities, and cost-benefit analyses.

Key Findings

- **Some properties that make insights valuable also make them difficult to secure.** Algorithmic insights are often conceptually compact, broadly applicable, and easily transferable, which means that they can leak through a wide variety of channels. Unauthorized proliferation could erase competitive or strategic advantages that took years and billions of dollars to establish, and overcoming this challenge requires a comprehensive security approach rather than protections of a few obvious assets.
- **The attack surface is broad and extends well beyond cyberthreats.** The attack vectors that we identified reflect the diversity of technical, organizational, and human pathways through which insights can leak. Participants whom we engaged with as part of our study rated human intelligence threats and other risks that are not cyberthreats, especially risks related to personnel and process weaknesses on the defender’s side, as highly feasible across all adversary capability levels (OC1 through OC5). Employees who inadvertently share sensitive information through casual conversations, conference presentations, or social interactions represent major risks that technical controls alone cannot address.
- **Compartmentalization is the central organizing principle for insight security.** Because transformative insights are often easily shared, organizations might not be able to rely on protecting just a few

² Sella Nevo, Dan Lahav, Ajay Karpur, Yogev Bar-On, Henry Alexander Bradley, and Jeff Alstott, *Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models*, RAND Corporation, RR-A2849-1, 2024.

crown jewels. The framework presented in this report emphasizes progressively stricter compartmentalization of information, personnel, and systems across ISL2 through ISL5 to reduce both the number of endpoints at which insights reside and the number of individuals with complete knowledge.

- **Meaningful security improvements are achievable at every ISL.** ISL1 and ISL2 align with security fundamentals and industry best practices that impose a minimal operational burden. ISL3 is more substantial and introduces formal data classification, insider-threat programs, network segmentation, and supply chain assurance measures. These levels represent concrete, actionable steps that frontier AI organizations can likely begin implementing today, independent of an organization’s specific threat model.
- **Achieving ISL4 or ISL5 protection requires significant organizational trade-offs and might require support from the national security community.** At ISL4 or ISL5, security measures (e.g., isolated compartmented facilities with emanation shielding, government-standard personnel vetting, supply chain compartmentalizing, restricting researcher travel and communication) are likely to reshape how organizations operate. Because insights are more diffuse and easier to transport than model weights, the tension between security and productivity at these ISLs is likely to be more acute than for weight security: Protecting assets that exist across people, conversations, and documents requires broader restrictions on daily work than protecting a centralized digital artifact. Some of these security measures might not be achievable without governmental assistance or involvement. Organizations that believe they might eventually need these levels of protection should identify and develop plans for long-lead items—which can include physical infrastructure, personnel security programs, and supply chain verification—now, even if full implementation might be years away.

Implications

Organizations developing frontier AI systems can use our framework to evaluate their current security postures, identify gaps, and prioritize investments. At the lower ISLs, the path forward is clear: Security measures for ISL1 and ISL2 represent “security hygiene” that most organizations handling sensitive AI techniques could implement quickly. ISL3 adds meaningful protection against insider threats and organized cybercrime while likely remaining achievable within recognizable corporate structures.

For organizations considering stronger protections, the framework maps out a spectrum of options alongside the trade-offs involved. Whether the trade-offs involved in achieving a given SL are warranted (particularly for ISL3 through ISL5) depends on judgments about specific insights, specific adversaries, and the broader trajectory of AI development; these are judgments that we do not attempt to make. What the framework does provide is a structured way to reason about what each protection level would require, which lets decisionmakers act with a clear-eyed understanding of the costs and benefits involved.

Contents

About This Report	iii
Summary	v
 CHAPTER 1	
The Case for Securing Algorithmic Insights	1
 CHAPTER 2	
Defining the Security Object	3
Defining Algorithmic Insights	4
Key Security Characteristics of Algorithmic Insights	5
The Strategic Importance of Securing Algorithmic Insights	6
 CHAPTER 3	
Research Approach and Expert Engagement	9
Research Design and Data Collection	9
Analytical Framework and Synthesis	10
 CHAPTER 4	
How Adversaries Acquire Algorithmic Insights	13
Landscape of Attack Vectors	13
Key Findings on Attack Vectors	16
 CHAPTER 5	
Calibrating Defenses Across Five Security Levels	19
Insight Security Level 1	19
Insight Security Level 2	21
Insight Security Level 3	22
Insight Security Level 4	23
Insight Security Level 5	25
Securing Insights Versus Securing Weights	26
Notable Areas of Consensus and Disagreement	27
 CHAPTER 6	
Implications and a Path Forward	29
 APPENDIXES	
A. Methods for Eliciting Expert Judgments on Securing AI Algorithmic Insights	31
B. Detailed List of Attack Vectors	37
C. Detailed Benchmark Systems for Insight Security Levels	53
D. Progressive Compartmentalization Across Insight Security Levels	69
E. Detailed Examples of Algorithmic Insights	75
 Abbreviations	 81
References	83
About the Authors	89

Figures and Tables

Figures

4.1.	Operational Capacity Definitions	14
5.1.	The Five Security Levels	20

Tables

4.1.	Overview of Attack Vectors	15
5.1.	Overview of the Insight Security Level 1 Benchmark	20
5.2.	Overview of the Insight Security Level 2 Benchmark	21
5.3.	Overview of the Insight Security Level 3 Benchmark	23
5.4.	Overview of the Insight Security Level 4 Benchmark	24
5.5.	Overview of the Insight Security Level 5 Benchmark	26
A.1.	Study Participants, by Expertise.....	32
A.2.	Thematic Codebook Used for the AI Security Workshop	33

The Case for Securing Algorithmic Insights

As frontier artificial intelligence (AI) systems continue to demonstrate increasingly sophisticated capabilities, securing the key assets that enable these advancements becomes critically important. These assets represent proprietary intellectual property (IP) that underpins technological leadership, and responsibly managing the assets' security is essential for both competitive positioning and the broader goal of ensuring that dual-use capabilities are developed and deployed safely.

Modern AI capabilities are largely a product of three key inputs: compute, data, and algorithms.¹ In this report, we focus on the third: *algorithmic insights*, or the novel techniques, methods, and design know-how that materially improve the efficiency, performance, deployability, or other desirable features of AI systems.

We apply an analytical framework from the RAND report *Securing AI Model Weights* (SMW) to certain threats and security issues that algorithms, as a distinct class of assets, face.² We identify potential attack vectors, assess adversarial capabilities across operational capacity (OC) categories, and define benchmark security levels (SLs) with tailored protective measures. The primary goal of SMW's authors was to "promote more-robust AI security strategies by facilitating [a] shared understanding" of "how an organization's security measures translate into actual security."³ Our goal with this report is one and the same.

Throughout this report, we refer to SLs for protecting algorithmic insights as *insight SLs* (ISLs 1 through 5), distinguishing them from the *weight SLs* (WSLs 1 through 5), which were established in SMW to describe model weight protection. We apply the umbrella term *SL* to both frameworks. Protecting algorithmic insights requires meeting an appropriate WSL for the underlying models then adding further measures on top.⁴ ISLs should therefore be understood as building on and extending the SMW weight security framework rather than replacing it. Although the two frameworks are complementary, an organization might reasonably target different SLs for weights and insights that are based on the organization's assessment of relative asset value and threat exposure. For instance, an organization might pursue WSL4 for its *model weights* (the learned parameters of trained models) while maintaining ISL2 for its algorithmic insights if the organization judges the weights to be at a greater risk of adversary targeting.

Algorithmic insights present security challenges that differ substantively from the challenges of model weight protection. Unlike model weights, which can be isolated as discrete digital artifacts, **algorithmic insights resist centralization.** AI researchers' code exists on developers' hard drives and in documentation and collaboration tools; findings might be shared via diverse communication channels; and critical knowledge resides in the minds of researchers, executives, and a wide variety of other personnel.

¹ Ben Buchanan, *The AI Triad and What It Means for National Security Strategy*, Center for Security and Emerging Technology, August 2020.

² Sella Nevo, Dan Lahav, Ajay Karpur, Yogev Bar-On, Henry Alexander Bradley, and Jeff Alstott, *Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models*, RAND Corporation, RR-A2849-1, 2024.

³ Nevo et al., 2024, p. 2.

⁴ Access to weights can also reveal some of the algorithmic innovations used to create or improve those weights.

This distributed nature creates a twofold security challenge: (1) hardening the numerous endpoints at which insights are likely to be found and (2) minimizing the number and scope of such endpoints through security controls.

We drew on a workshop and follow-up engagements with 20 participants who are experts in AI research, safety, hardware, and software security. We complemented the workshop with a targeted literature scan and a quantitative gap analysis that informed the calibration of ISL1 through ISL5.

In the remainder of this report, we define algorithmic insights and their security characteristics (Chapter 2), discuss the methodological approach that underpins this work (Chapter 3), catalog attack vectors and adversary capabilities (Chapter 4), establish SL benchmarks with specific protective measures (Chapter 5), and offer concluding remarks (Chapter 6).

Defining the Security Object

The findings that we present in this report should be understood within the broader context of the ecosystem of AI security, which encompasses such components as model weights, architectural design, training data, operational infrastructure, and the algorithmic innovations that enable these systems to achieve frontier capabilities.¹ Within this ecosystem, we focus on one critical component: **algorithmic insights**. In practice, algorithmic insights and other components of the ecosystem (such as architectural design) can overlap; we discuss the boundaries of what we include in our definition.

We specifically address threats related to theft, leakage, or unauthorized replication of algorithmic insights—that is, loss of confidentiality.² We touch on other security objectives, such as integrity and availability, only so far as they intersect with protecting confidentiality. This decision reflects the primary concern that unauthorized dissemination of key insights could enable adversaries to rapidly replicate or build on frontier AI models’ capabilities.

We describe measures that frontier AI developers themselves can implement to protect algorithmic insights. Developers at the cutting edge of AI development have the primary capacity to implement security controls when such controls are warranted. We aim to make the discussion accessible to security professionals, policymakers, and AI company leadership, although our recommendations focus on internal security measures rather than external regulatory requirements or industrywide standards.

As a general principle, we take no normative stance on the broader question of which algorithmic insights should be shared or secured. Some insights warrant protection because of their strategic importance or dual-use potential, while others could be shared publicly to advance scientific understanding and beneficial applications. Deciding the appropriate security posture for any given insight must account for factors that are beyond the scope of this report, including the insight’s potential to enable harmful capabilities, the likelihood of independently discovering the insight, the competitive landscape, and broader considerations about the overall pace and direction of AI development.

We assume that organizations can use the insights’ security characteristics (size, access, medium, observability, transferability, shelf life) to inform which insights to classify, compartmentalize, and protect. The security characteristics framework serves a second function: It shows why we do not attempt to map individual security controls to specific insight types. Because individual insights frequently exist in multiple forms simultaneously, each with different security characteristics, a type-to-control mapping would be both incomplete and potentially misleading. A training recipe that exists as code, as internal documentation, and as knowledge held by its developers is simultaneously vulnerable to code exfiltration, document theft, and elicitation through conversation. The ISL benchmarks in Chapter 5 address this dilemma by defining comprehensive security postures at each threat level rather than prescribing controls per insight category.

¹ Nevo et al., 2024.

² Joint Task Force, *Security and Privacy Controls for Information Systems and Organizations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-53, Revision 5, September 2020.

We do not attempt to assess or quantify the impact of the theft of particular insights. Although some forecasting studies have pursued such quantitative approaches,³ our framework takes a qualitative and guardrail-focused approach, concentrating on identifying vulnerabilities and cataloging mitigations. The underlying assumption is that organizations will determine which algorithmic insights, if any, they deem sensitive and that the controls we recommend in this report should be applied to those insights at an SL appropriate to their assessed sensitivities.

We do not prioritize security measures within each SL. Our categorization of SLs is not a full, ordered priority list, but we aim to provide enough information to assist security teams in prioritizing next steps no matter what their existing security posture is, and we do so while avoiding overprescription for tactical decisions that are context-dependent. Organizations should triage and prioritize according to their own circumstances.

The field of AI security continues to evolve rapidly. Readers should view this framework as a **starting point for calibrating organizational security approaches** rather than as a definitive or permanent standard.

Defining Algorithmic Insights

What Are Algorithmic Insights?

Algorithmic insights are the novel techniques, methods, or design know-how that materially improve the efficiency, performance, deployability, or similar desirable features of AI systems. This definition is intentionally broad and covers innovations across the AI development life cycle. Concretely, we divide algorithmic insights into the following three major categories:

- **Pretraining and training-time insights.** These insights include innovations that improve AI models before and during training, including architectural designs (e.g., the transformer⁴), tactical improvements (e.g., normalization and regularization techniques), training algorithms, scaling-law discoveries, and data strategies (e.g., new methods of cleaning or curating data at scale). These insights have historically delivered large, durable gains and often require broad access within research teams to implement and iterate.⁵
- **Post-training insights.** These insights are techniques applied after a base model is trained that significantly enhance its capabilities, typically at a low cost. These insights include such methods as reinforcement learning from human feedback (RLHF) and parameter-efficient fine-tuning approaches. In practice, these techniques can enable major capability jumps without the expense of full retraining.⁶
- **Inference and deployment optimization insights.** These insights are methods that make trained models run faster or more efficiently in production or that improve models' capabilities and output

³ Romeo Dean, *Security Forecast*, AI 2027, April 2025.

⁴ Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N. Gomez, Lukasz Kaiser, and Illia Polosukhin, "Attention Is All You Need," arXiv, arXiv:1706.03762v7, August 2, 2023.

⁵ Anson Ho, Tamay Besiroglu, Ege Erdil, David Owen, Robi Rahman, Zifan Carl Guo, David Atkinson, Neil Thompson, and Jaime Sevilla, "Algorithmic Progress in Language Models," arXiv, arXiv:2403.05812, March 9, 2024.

⁶ Long Ouyang, Jeff Wu, Xu Jiang, Diogo Almeida, Carroll L. Wainwright, Pamela Mishkin, Chong Zhang, Sandhini Agarwal, Katarina Slama, Alex Ray, et al., "Training Language Models to Follow Instructions with Human Feedback," arXiv, arXiv:2203.02155, March 4, 2022.

quality at inference time, including both infrastructure-level optimizations and end-user strategies.⁷ These insights span techniques for reducing costs and latency (e.g., quantization, distillation), as well as methods for improving capability and output quality (e.g., scaffolding and harnesses, chain of thought, mixture-of-experts routing). Such insights can be crucial for scaling deployments, enhancing model performance without retraining, and extracting maximum value from trained models.⁸

Detailed examples of each insight category can be found in Appendix E.

Both the *conceptual breakthroughs* themselves and their *practical implementations* are in our definition's scope; that is, algorithmic insights encompass all the know-how that could meaningfully accelerate AI progress if a third party were to obtain it. However, the other inputs used to produce models (such as compute and data), as well as the resulting models themselves, are not included in the definition. We do *not* consider model weights and raw datasets as algorithmic insights for our purposes. We also exclude general machine learning (ML) knowledge that is already public (e.g., the concept of *backpropagation*) unless it is packaged into a proprietary implementation.

Key Security Characteristics of Algorithmic Insights

Algorithmic insights are a heterogeneous category, varying widely in their forms and in how they might leak or be protected. Some insights are small and simple; for example, they can be a new prompt format or tuning trick that can be conveyed in just a few sentences as part of ordinary conversation. Other insights are large and complex, such as an end-to-end bespoke training pipeline requiring tens of thousands of lines of code to implement. Likewise, some insights live only in a few researchers' minds or in confidential design documents, whereas others are widely embedded in codebases, configurations and parameters, model weights, hardware, or even marketing material.⁹

In general, four baseline properties influence an insight's security profile:

- **Complexity and size.** How *complex* is the insight in terms of information content or technical intricacy? An idea consisting of a few lines of pseudocode or a short verbal description is easier to communicate or copy than a complicated engineering system. All else being equal, *smaller and simpler* insights are harder to secure—a single individual could memorize or exfiltrate them—whereas larger or more complex innovations are inherently harder to steal.
- **Access.** Who within an organization needs to know or interact with the insight to do their job? Some trade secrets can be tightly held by a small research team, but many algorithmic techniques must be shared broadly with engineers, DevOps or information technology personnel, or other staff to be applied in practice. Broader internal access translates into a larger attack surface for adversaries. Generally, the more employees or contractors who work with a particular insight, the higher the risk of its theft or leakage.

⁷ Ggaliwango Marvin, Nakayiza Hellen, Daudi Jjingo, and Joyce Nakatumba-Nabende, "Prompt Engineering in Large Language Models," in I. Jeena Jacob, Selwyn Piramuthu, and Przemyslaw Falkowski-Gilski, eds., *Data Intelligence and Cognitive Informatics: Proceedings of ICDICI 2023*, Springer, 2024.

⁸ Woosuk Kwon, Zhuohan Li, Siyuan Zhuang, Ying Sheng, Lianmin Zheng, Cody Hao Yu, Joseph E. Gonzalez, Hao Zhang, and Ion Stoica, "Efficient Memory Management for Larger Language Model Serving with *PagedAttention*," *SOSP'23: Proceedings of the 29th Symposium on Operating Systems Principles*, October 2023.

⁹ Anthropic, "Claude's Extended Thinking," press release, February 24, 2025.

- **Medium and location.** Where does the insight “live”? Is it written down in design documents or research papers, embodied in source code or model weights, embedded in deployment infrastructure, presented in slideshows to leadership, or just tacit knowledge in experts’ minds? The medium and location of an insight determine what kinds of attacks and which intelligence collection methods might be relevant for attackers.
- **Observability.** Can outsiders detect or infer the presence of the insight by observing the system’s behavior or other external signals? For instance, a new model’s architecture might be partly inferable from published benchmark results or by analyzing the model’s outputs and latency. Some insights are virtually invisible from outside an organization (e.g., a subtle training trick that leaves no obvious signature), while others are easily noticed and reverse-engineered (e.g., the concept of reasoning models).

Two additional properties not related to security are worth mentioning because of their effect on insights’ relative values to adversaries:

- **Transferability.** How easily does the insight port across model families, hardware architectures, tasks, or modalities? Highly transferable insights pose a greater proliferation risk; niche techniques might be less attractive targets.
- **Shelf life.** How long will the insight remain differentially valuable? This property has two dimensions: first, whether the insight will remain relevant given the pace of independent progress (e.g., Will a new training technique still be state-of-the-art in three years, or will it be superseded?), and second, how long before another party independently discovers the same insight. Some innovations confer advantages for only weeks; others might remain uniquely valuable for years. Shelf life informs both protection investments and attacker targeting decisions.

Notably, there does not appear to be a strong correlation between an insight’s strategic value and its inherent ease of defense. Some of the most transformative insights (e.g., the transformer attention mechanism) are *conceptually compact and easily transferred* and could leak via an overheard phone call or a casual conversation at a party, as workshop participants attested. This lack of a natural “size defense” means that organizations might not be able to rely on shoring up protections around just a few obvious major insights (e.g., model weights), and organizations might require more-comprehensive approaches to safeguard even small-but-critical insights.

The Strategic Importance of Securing Algorithmic Insights

Algorithmic insights act as **force multipliers** for compute and data, sharply reducing the resources needed to achieve a given level of AI performance.¹⁰ Algorithmic progress alone has been delivering approximately threefold annual gains in effective compute, and training compute for frontier AI models has simultaneously grown at roughly fivefold per year, meaning that effective compute has been increasing by more than an order of magnitude annually.¹¹ This force-multiplier property has two important implications for global security.

First, insight theft can enable adversaries to leapfrog resource constraints. Attaining algorithmic insights has emerged as a key lever in great-power AI competition because it affects how efficiently a country

¹⁰ Ho et al., 2024.

¹¹ Hans Gundlach, Jayson Lynch, Matthias Mertens, and Neil Thompson, “The Price of Progress: Algorithmic Efficiency and the Falling Cost of AI Inference,” arXiv, arXiv:2511.23455, November 28, 2025.

or company can progress in developing AI.¹² If countries or competitors gain access to cutting-edge algorithms, they can potentially offset hardware disadvantages and challenge existing leads. China's DeepSeek AI models offer an illustration: Public reports and technical documentation suggest that DeepSeek-V3 and DeepSeek-R1 achieved performance that was competitive with leading U.S. proprietary models on several benchmarks, despite being trained with an order of magnitude less compute and budget.¹³ This success was enabled at least in part by algorithmic innovations, including distillation from reasoning models.¹⁴

Second, insight proliferation carries implications that vary significantly depending on the nature of the insights involved. The proliferation of narrow, domain-specific capabilities might be beneficial or harmful depending on the domain: Techniques that improve medical reasoning carry very different implications than techniques that lower barriers to developing weapons of mass destruction. The proliferation of broad capability improvements is typically commercially damaging for the originating organization, but whether such proliferation is net positive or negative for society is a complex and highly contested question, one that might also shift as different AI capabilities emerge and as the broader ecosystem matures. From a national security perspective, researchers have flagged the risk that certain insights could empower nonexperts to develop dangerous capabilities as AI advances.¹⁵ Post-training and inference insights might warrant particular attention in this regard: Because such methods as fine-tuning, scaffolding, or prompting techniques are relatively cheap and straightforward to implement, they could enable small teams or even individuals to amplify the capabilities of publicly available base models without requiring the resources for full model training.

That said, the calculus around insight diffusion is not one-sided. Some insights might be capability-specific, so the risks and benefits of their diffusion should be assessed with that specific capability in mind. Many algorithmic insights broadly improve AI capabilities or efficiency, and whether it is better to broadly diffuse such insights or to control their access is highly contested; it is a question of policy and strategy, and the answer might change as beneficial or dangerous capabilities emerge from AI systems.

The downstream value of stolen algorithmic insights differs qualitatively from that of stolen model weights. Possession of a frontier model's weight file gives an adversary immediate, deployable capability. The adversary can run the model, fine-tune it, and extract value without making any additional research and development investment. Possession of an algorithmic insight, by contrast, confers a *generative* advantage: A novel training methodology, a more efficient architecture, or a breakthrough in data curation can be applied across multiple model generations and adapted to the adversary's own infrastructure. This makes certain algorithmic insights, in some respects, more strategically valuable than any single model. Insights represent the capacity to *build* frontier AI, not merely to *use* a particular instance of it.

¹² National Security Commission on Artificial Intelligence, "Emerging Threats in the AI Era," in *Final Report*, 2021; White House, *National Security Strategy of the United States of America*, November 2025.

¹³ See Aixin Liu, Bei Feng, Bing Xue, Bingxuan Wang, Bochao Wu, Chengda Lu, Chenggang Zhao, Chengqi Deng, Chenyu Zhang, Chong Ruan, et al., "DeepSeek-V3 Technical Report," arXiv, arXiv:2412.19437v2, February 18, 2025. DeepSeek reported \$5.6 million in training compute for the final production run but noted that this excluded "prior research and ablation experiments on architectures, algorithms, or data" (Liu et al., 2025, p. 5). Analysts have estimated the company's total hardware spend at well over \$500 million, with total server capital expenditure around \$1.6 billion. See Dylan Patel, A. J. Kourabi, Doug, and Reyk Knuhtsen, "DeepSeek Debates: Chinese Leadership on Cost, True Training Cost, Closed Model Margin Impacts," SemiAnalysis, January 30, 2025.

¹⁴ Daya Guo, Dejian Yang, Haowei Zhang, Junxiao Song, Peiyi Wang, Qihao Zhu, Runxin Xu, Ruoyu Zhang, Shirong Ma, Xiao Bi, et al., "DeepSeek-R1: Incentivizing Reasoning Capability in LLMs via Reinforcement Learning," arXiv, arXiv:2501.12948, January 22, 2025.

¹⁵ Jim Mitre and Joel B. Predd, *Artificial General Intelligence's Five Hard National Security Problems*, RAND Corporation, PE-A3691-4, February 2025.

However, this generative potential is contingent on the adversary’s ability to act on the insight. A stolen training recipe is only valuable to an actor with sufficient compute, data, and engineering talent to execute it. An adversary lacking these complementary resources might find a stolen insight difficult to operationalize; however, they might still transfer or sell the insight to a better-resourced actor or use it to close a specific capability gap rather than replicate an entire system. The value of a stolen insight thus depends heavily on the recipient’s existing capabilities, making the threat landscape more varied for insights than for model weights.

To illustrate: If an adversary had obtained the core techniques behind RLHF before they were publicly described,¹⁶ they would not have gained a deployable model, but they would have gained the ability to dramatically improve the usability and alignment of any large language model (LLM) they could train, which would be a capability advantage that would have compounded across every subsequent model generation.

Illustrative examples of high-impact insights can be found in Appendix E.

¹⁶ Paul Christiano, Jan Leike, Tom B. Brown, Miljan Martic, Shane Legg, and Dario Amodei, “Deep Reinforcement Learning from Human Preferences,” arXiv, arXiv:1706.03741v4, February 17, 2023.

Research Approach and Expert Engagement

We used a mixed-methods approach to (1) synthesize existing knowledge on unauthorized access risks to AI algorithmic insights and (2) develop a structured framework for mitigating those risks. We integrated expert input, a targeted literature scan, and a structured synthesis within a single analytical workflow. Our process followed the same five-step structure that was used in the SMW framework, which we adapted for algorithmic insights.

Research Design and Data Collection

We collected experts' input through workshops and interviews. We conducted a targeted literature scan to identify threat pathways and evaluate mitigation strategies. This design captured both practitioner experience and empirical evidence to support a repeatable process for assessing AI security risks.

Expert Input

The primary data-collection activity was the RAND-sponsored *Securing AI Algorithmic Insights* workshop held in San Francisco in May 2025. Twenty subject-matter experts participated, including ten in person and ten asynchronously. Participants were experts in security engineering and in AI research, safety, hardware, and software security. We also conducted follow-up interviews to clarify and expand on workshop findings.

Before the workshop, participants completed a structured assessment that asked them to evaluate adversary OCs, the effectiveness of five incremental SLs, and areas of disagreement or refinement. These inputs informed the workshop discussions and subsequent analysis.

In workshop sessions, we used a semistructured format to balance systematic coverage with open debate. Experts focused on three central questions:

- What constitutes an AI algorithmic insight?
- Which actors are capable of compromising such insights?
- Which mitigations meaningfully reduce risk?

We coded facilitator notes, interview transcripts, and participant materials using a structured codebook that aligned with the study objectives. Codes captured attack types, OCs, and rationales for security ratings. We complemented this qualitative analysis with quantitative aggregation of experts' judgments on the feasibility of attack vectors and the adequacy of SLs. Experts rated each vector's feasibility and potential for mitigation on a binary scale, which we aggregated and converted to a five-point scale. We calculated "gap scores" by comparing the perceived adversary capability with the perceived mitigation strength to identify how SLs were too weak or too strong. These results guided our refinement of the final security benchmarks.

Targeted Literature Scan

We consulted literature from academic, commercial, and governmental sources that address AI security, algorithmic innovation, and historical cases of IP compromise. Key references included analyses of algorithmic efficiency improvements, case studies of major AI breakthroughs, and documented espionage and supply chain incidents. Beyond SMW, we did not use another framework to structure our analysis, which allowed us to focus specifically on protecting algorithmic insights without anchoring to prior terminology or assumptions. The literature scan informed the taxonomy of attack vectors and mitigations and provided empirical validation for the experts' assessments.

In Appendix A, we describe the methods that we used to elicit and analyze the experts' judgments, and in subsequent appendixes, we provide detailed descriptions of the workshop materials, worksheets, and coding schema.

Analytical Framework and Synthesis

Framework Extension

We extended the SMW framework to include algorithmic insights. The core architecture of attack vectors, OC categories (OC1 through OC5), security measures, and SLs (SL1 through SL5) remained consistent across AI asset types. To distinguish between the application of these levels to different asset types, we introduce specific terminology: WSL1 through WSL5 refer to security requirements for model weights as described in SMW, while ISL1 through ISL5 refer to the security requirements for algorithmic insights as we define them in this report. The underlying framework and organizational capacity levels are shared, but the specific controls differ to reflect the distinct characteristics of each asset type. Algorithmic insights differ from model weights in their heterogeneity and exposure pathways, which necessitated deeper treatment of such disciplines as supply chain security, human intelligence (HUMINT), and physical surveillance. Algorithmic insights share some vulnerabilities with model weights, and in those cases, we carried the corresponding SMW measures into the ISL framework and adapted their application as needed. We developed new measures to address any of the algorithmic insights' distinct vulnerabilities.

Defining Algorithmic Insights

The targeted literature scan and expert input helped us develop a working definition and taxonomy of algorithmic insights. The taxonomy emphasizes the types of algorithmic knowledge that materially advance AI performance, such as architectural innovations, optimization techniques, and scaling laws. This taxonomy supports the threat and mitigation mapping that we describe in the next sections.

Identifying Attack Vectors and Security Measures

We identified attack vectors and security measures through an integrated analysis of the literature scan, workshop discussions, interviews, and prior frameworks. We also relied on our own experience in AI security, threat modeling, and intelligence operations. We evaluated each vector for relevance to algorithmic insights and mapped them to one or more security measures. The resulting catalog represents a substantial, though not exhaustive, set of plausible compromise pathways. Full descriptions of the attack vectors and security measures appear in the appendixes.

Capability Assessment and Benchmark Development

Experts assessed the feasibility of each attack vector for adversaries at each OC level. We aggregated responses to produce capability profiles, emphasizing empirical grounding using real-world evidence when possible. We then mapped attack vectors to corresponding security measures and OCs. We emphasized that no single measure would provide complete protection because distinct attack vectors can independently lead to compromise. The SLs (SL1 through SL5) were defined as bundles of measures sufficient to mitigate threats from adversaries at OC1 through OC5. Quantitative gap analysis results guided our calibration of these levels to balance costs and levels of protection.

After developing the draft framework, we collected additional feedback from participants who had contributed through the workshop, interviews, or asynchronous input. We also sought input from attendees of the Frontier Model Forum.¹ During this period of gathering feedback, we focused on identifying any missing or redundant attack vectors or security measures, correcting items that were inaccurately described or misplaced, and clarifying definitions or distinctions as needed. The feedback informed the final refinements to the framework's structure and terminology.

¹ Frontier Model Forum, homepage, undated.

How Adversaries Acquire Algorithmic Insights

In this chapter, we identify the methods (attack vectors) that adversaries might employ to acquire algorithmic insights without authorization.¹ These attack vectors serve two functions in our framework: First, they help determine which security measures would be required to protect against specific threats. Second, because we map vectors to the OC level at which an attack becomes feasible (Figure 4.1), they inform the SL benchmarks that we present in Chapter 5.

To systematically evaluate potential attack vectors, we developed a five-part test examining whether each vector (1) directly advances an attacker in accessing or learning insights, (2) is feasible (and/or whether there is empirical evidence supporting that claim of feasibility), (3) requires security measures that are distinct from other vectors, (4) either differs from SMW vectors or requires modification for insight protection, and (5) can be clearly distinguished by security professionals.

We emphasize that this catalog should not be considered exhaustive. Adversaries continually develop novel techniques, and the rapid evolution of AI capabilities and organizational practices creates new vulnerabilities. Organizations should treat this analysis as a starting point for threat modeling rather than as a comprehensive enumeration of all possible risks.

Landscape of Attack Vectors

We organized attack vectors according to their SMW categories, and we then identified 44 vectors within those categories. Most of these vectors are inherited directly from SMW: The threats that apply to model weights generally apply to algorithmic insights. In addition, we identified six attack vectors that are specific to algorithmic insight security; these attack vectors apply more specifically to insights primarily because insights can be communicated. Several existing attack vectors also take on particularly important or distinctive forms in the context of algorithmic insights; we discuss these insight-specific manifestations in detail in Appendix B.

Table 4.1 summarizes these categories and vectors. Descriptions of each vector, along with real-world examples, can be found in Appendix B.

As in the SMW framework, the categories in Table 4.1 group vectors by different organizing dimensions depending on which dimension is most operationally useful: Some vectors are categorized by target (e.g., vectors in the “Undermining the access control system itself” category), by method (e.g., the “HUMINT” category), or by the access required (e.g., the “Nontrivial access to data or networks” category). Individual vectors within each category are defined to be distinct from one another. It is important to note that attack vectors are individual techniques, not complete operations. A real-world attack campaign will typically chain multiple vectors from different categories in sequence or in parallel.

¹ We define *without authorization* to refer to the unauthorized acquisition, exfiltration, or transfer of algorithmic insights rather than to the attacker’s access credentials. An insider with legitimate access to insights who transfers those insights to an unauthorized party is acting without authorization under this framework, and insider threats are addressed as a distinct attack vector category.

FIGURE 4.1
Operational Capacity Definitions



OC1 Amateur attempts



Operations roughly less capable than or comparable to a single individual with some limited professional expertise in information security spending several days with a total budget of up to \$1,000 on the specific operation, and no preexisting infrastructure or access to the organization.

This includes the operations of many **hobbyist hackers**, as well as more experienced hackers who implement completely untargeted “**spray and pray**” attacks.



OC2 Professional opportunistic efforts



Operations roughly less capable than or comparable to a single individual who is broadly capable in information security spending several weeks with a total budget of up to \$10,000 on the specific operation, with preexisting personal cyber infrastructure but no preexisting access to the organization.

This includes the operations of many individual **professional hackers**, as well as **capable hacker groups when executing untargeted or lower-priority attacks**.



OC3 Cybercrime syndicates and insider threats



Operations roughly less capable than or comparable to ten individuals who are experienced professionals in information security spending several months with a total budget of up to \$1 million on the specific operation, with major preexisting cyberattack infrastructure but no preexisting access to the organization. Also included in this category are attempts by insider threats within the organization, who will have significantly less resources and expertise than the previous operations described as part of this category but significant access to sensitive organization resources (e.g., a senior member of the organization’s research team).

This includes the operations of many **world-renowned criminal hacker groups, well-resourced terrorist organizations, disgruntled employees, and industrial espionage organizations**.^a



OC4 Standard operations by leading cyber-capable institutions



Operations roughly less capable than or comparable to 100 individuals who have experience in a variety of relevant professions (cybersecurity, human intelligence gathering, physical operations, etc.) spending a year with a total budget of up to \$10 million on the specific operation, with vast infrastructure and access to state resources such as legal cover, interception of communication infrastructure, and more.

This includes the operations of many of the world’s leading **state-sponsored groups** and many **foreign intelligence agencies** across the world. The top cyber-capable nations globally can execute such operations more than **100 times per year**.



OC5 Top-priority operations by the top cyber-capable institutions



Operations roughly less capable than or comparable to 1,000 individuals who have experience and expertise years ahead of the (public) state of the art in a variety of relevant professions (cybersecurity, human intelligence gathering, physical operations, etc.) spending years with a total budget of up to \$1 billion on the specific operation, with state-level infrastructure and access developed over decades and access to state resources such as legal cover, interception of communication infrastructure, and more.

This includes the handful of operations most prioritized by the world’s **most capable nation-states**.

^a The set of actors within OC3 is more diverse than in other categories—most notably in the inclusion of both insider threats and external cyber organizations. We group the OC3 actors together because the level of investment required to robustly defend against them is comparable, despite the specific measures required being partially but not fully overlapping.

TABLE 4.1
Overview of Attack Vectors

Category	Attack Vector
Running unauthorized code	• Exploitation of vulnerabilities for which a patch exists (attacking nonupdated software) • Exploitation of reported but not fully patched vulnerabilities • The finding and exploitation of individual “zero-days”
Compromising existing credentials	• Social engineering • Exploitation of exposed credentials • Expansion of illegitimate access (e.g., escalation of privileges)
Undermining the access control system itself	• The authentication or bypass of vulnerabilities (in the access control system) • Access to secret material that undermines a protocol
Bypassing the access control system altogether	• Incorrect configuration or security-policy implementation • Additional (less secure) copies of sensitive data
AI-specific attack vectors	• Exploitation of existing vulnerabilities in the ML stack • Prompt-triggered code execution • Model extraction • The staging of data poisoning for the exfiltration of insights^a • Autocomplete and code assistant leakage
HUMINT	• Bribes and cooperation • Extortion • Seduction • Candidate placement • Organizational leverage attacks • Risks from former employees^a • Elicitation of insights^a
Nontrivial access to data or networks	• External surveillance^a • Optical or acoustic reflection capture • Internal surveillance^a • Surveillance via access to other devices • Digital access to air-gapped networks • Attack of network components • Attack of other devices • Side-channel attacks (including TEMPEST attacks) • Eavesdropping and wiretaps
Unauthorized physical access to systems	• Physical access to devices in other locations • Malicious placement of portable device implants • Direct physical access • Removal of devices and storage • Evasion of physical access control systems • Armed break-in • Military takeover • Penetration of hardware security • Shoulder surfing^a
Supply chain attacks	• Services and equipment the organization uses • Vendors with access to information • Front operations and ruses • Code and infrastructure incorporated into the codebase

^a These vectors are our new contributions that are specific to algorithmic insight security, which we identified in consultation with experts who called for defensive measures with no direct analogue in the weight security context. Several existing vectors also take on distinctive forms in the algorithmic insights context; we discuss these insight-specific manifestations in Appendix B, and we fully describe their defensive measures in Appendix C.

Key Findings on Attack Vectors

The findings below draw on a structured capability assessment in which subject-matter experts rated the feasibility of each attack vector at each OC level (OC1 through OC5) on a scale of 1 (low feasibility) to 5 (high feasibility). Our assessment followed the same methodology that the authors of SMW used, although we adapted the methodology for algorithmic insights. Full scoring results appear in Appendix D; we describe the methodology in detail in Appendix A.

The attack surface for algorithmic insights is broader and more distributed than for model weights. Although the same nine attack categories apply, applying the methodology to insights introduces six additional attack vectors and heightens the significance of several threat areas that were a lower priority for weight security. Insights can exist across code, documentation, human knowledge, visual artifacts, communications, and numerous other locations, making the defender's task fundamentally more challenging. Our key findings are as follows:

- **Conventional security concerns and low-bandwidth channels are strategically significant.** Many vectors represent conventional security concerns (e.g., endpoint compromises, communication interception, development environment exploits) rather than exotic intelligence tradecraft. Because insights are distributed across endpoints, devices, and people rather than centralized in secured model-serving infrastructure, these conventional vectors become primary threats. Many valuable insights can be conveyed through low-bandwidth channels: brief conversations, observed visual displays, or short written descriptions. As a result, many attack vectors that are relevant to weight security only as an instrumental step in a far-more-complicated operation, such as visual and audio surveillance, become high-priority vectors for insight security. Although organizations should centralize and compartmentalize insights to the maximum extent that is operationally feasible, some endpoint distribution appears unavoidable.
- **Several attack vectors were assessed by experts as feasible for adversaries at all capability levels,** even for the least capable adversary class (OC1). These universally exploitable vectors (e.g., exposed credentials, misconfigurations, former employee risks, social engineering, and software supply chain compromises) succeed primarily because of human and process failures on the defender's side rather than because they require technical sophistication from the attacker's side. This finding underscores that securing algorithmic insights requires robust baseline security practices even before addressing more-sophisticated threats.
- **Software and ML supply chain attacks represent a near-universal threat surface.** Software-centric supply chain vectors (including dependency confusion and the poisoning of open-source ML components) scored highly across all capability levels, reflecting the low barrier to exploiting the open-source software ecosystem that underpins most AI development. Hardware supply chain compromise, by contrast, was assessed as substantially more difficult to achieve for lower-capability actors (those with OC1 or OC2) because it requires physical access, manufacturing relationships, or a sustained operational presence that exceeds most amateurs' resources.
- **Distributed work environments introduce distinctive vulnerabilities.** Several vectors (e.g., shoulder surfing, physical access to devices in other locations, and the removal of devices and storage media) reflect the reality that modern AI research can occur across coworking spaces, homes, conference venues, and travel contexts in which physical security is inherently weaker than in controlled facilities.
- **HUMINT vectors dominate experts' concerns.** Workshop participants consistently emphasized HUMINT as the highest-priority threat category. Employees inadvertently leaking sensitive information through casual conversations, conference presentations, or social interactions represent major risks that technical controls alone cannot address.

- **AI systems themselves can become attack vectors.** Internal AI tools, such as coding assistants with broad codebase access or research automation systems, might inadvertently surface compartmentalized information to users who lack direct authorization to access it. Additionally, adversaries might poison training data so that deployed models stage or exfiltrate insights when triggered. Security practitioners at frontier AI companies have identified both of these emerging risks as areas of growing concern.

Calibrating Defenses Across Five Security Levels

The SLs that we describe in this chapter and their benchmarks offer a preliminary framework for calibrating the relationship between the implementation of security measures (and their expected security outcomes) against adversaries of varying capabilities. Although the optimal security setup for a specific organization might differ from the benchmark security setup for a given SL, **each benchmark can assist in identifying whether an organization’s security posture consistently falls short of experts’ expectations for that SL** (as opposed to achieving similar goals in a slightly different way) and therefore might not provide adequate security for the relevant OC category.

Each ISL is designed to thwart an adversary’s OC level of equal value: ISL1 addresses OC1-level threats, ISL2 addresses OC2-level threats, and so on. Additional details on how the ISLs map to OCs appear later in this chapter.

A critical consideration for all ISLs is the relationship between security and operational flexibility. Lower ISLs (ISL1 and ISL2) implement foundational protections that align with industry best practices and impose minimal notable operational constraints. As security requirements increase, however, organizations face progressively more-difficult choices: Measures that effectively defend against sophisticated adversaries often constrain collaboration, slow development velocity, limit work flexibility, and increase operational overhead. At ISL3, these constraints become noticeable; at ISL4 and ISL5, the constraints are likely to fundamentally reshape how organizations operate. Throughout this chapter, we note when and how security measures begin to impose significant operational costs.

We describe a benchmark system for each ISL, listing concrete measures and policies that represent the estimated minimum requirements of a system that conforms to that level’s security goals. **As mentioned previously, these SL benchmarks do not represent a complete standard or a comprehensive compliance regime.**

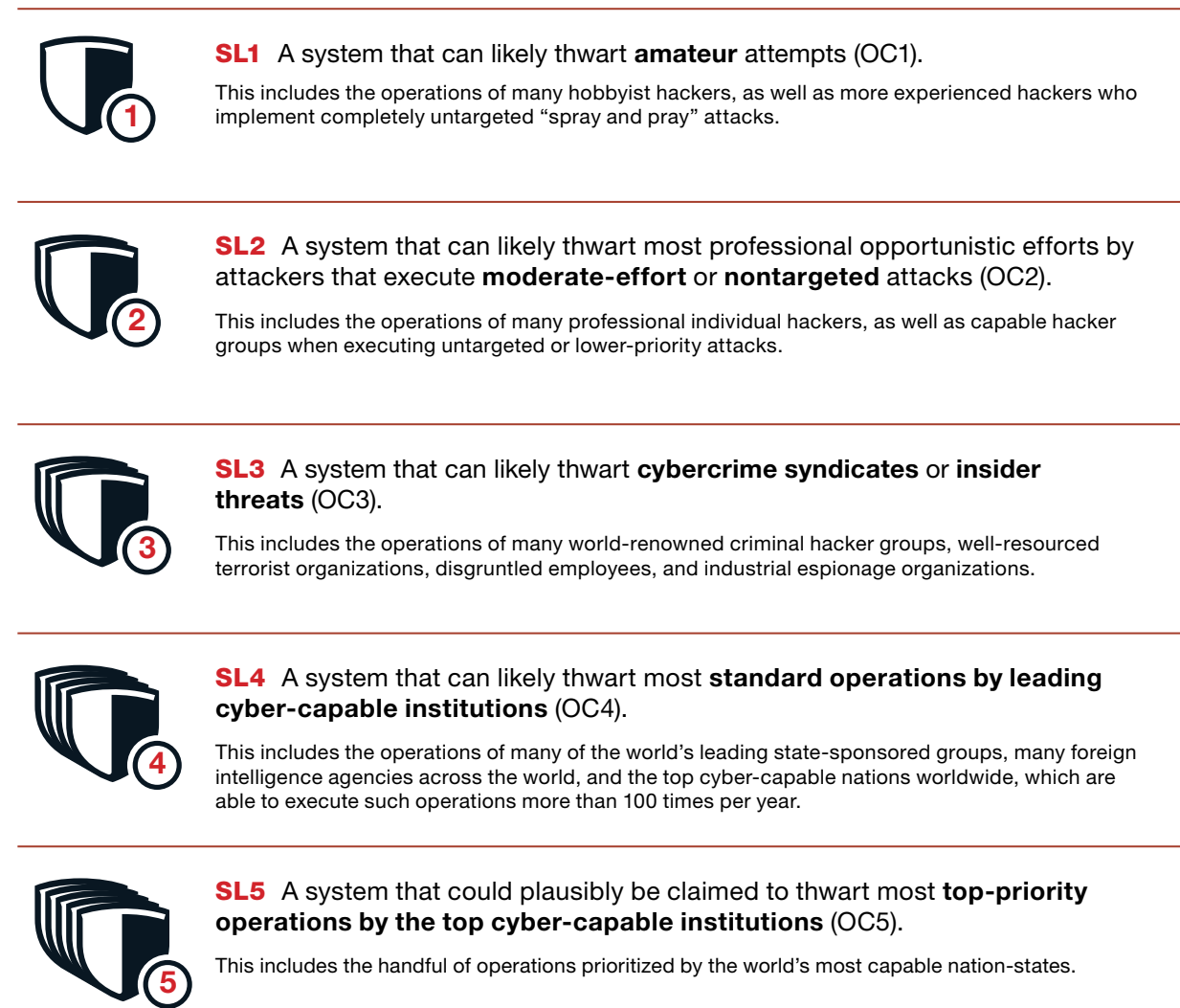
It is important to consider some context for reading the benchmarks: ISLs are cumulative, and each level builds on the SMW framework (see Figure 5.1). The tables that follow list only measures that are new or substantially modified for algorithmic insights; they do not repeat measures inherited from SMW’s corresponding WSLs. Our ISL1, for example, includes all of SMW’s WSL1 measures by default, with additions specific to insights. In this chapter, we focus on measures that are unique to insights or those requiring substantial modification from the weight security context. Full details on all security measures, including inherited ones, can be found in Appendix C.

Insight Security Level 1

Definition

A system that can likely thwart amateur attempts (OC1). This level includes the operations of many hobbyist hackers and more experienced hackers who implement completely untargeted “spray and pray” attacks. See Table 5.1 for an overview of ISL1.

FIGURE 5.1
The Five Security Levels



SOURCE: Reproduced from Nevo et al., 2024, p. 22.

TABLE 5.1
Overview of the Insight Security Level 1 Benchmark

Category	Security Measure(s)
Access control and authentication	• Private internal test AI instances
Digital network and endpoint security	• Disable macros by default
Threat detection, monitoring, and incident response	• Endpoint detection and response (EDR) on key endpoints • Intrusion detection systems (IDS)

Key Takeaways

- **Most ISL1 security measures carry over from the weight-security framework** (e.g., multifactor authentication [MFA], password policies, access management, email security, disk encryption, network encryption). ISL1 adds only a small number of insight-specific measures, reflecting that foundational controls for weights and insights substantially overlap at this level.

Insight Security Level 2

Definition

A system that can likely thwart most professional and opportunistic efforts by attackers executing moderate-effort or nontargeted attacks (OC2). This level includes the operations of many professional individual hackers and capable hacker groups when executing untargeted or lower-priority attacks. See Table 5.2 for an overview of ISL2.

Key Takeaways

- **ISL2 focuses on the comprehensive implementation of security fundamentals and industry best practices across an organization by closing gaps that opportunistic attackers commonly exploit.** The most important concern at this level is ensuring that there are no blind spots left unaddressed. Some measures at this level are not unique to protecting algorithmic insights but represent general security practices that SMW did not enumerate explicitly; we include them here so that the ISL framework provides a self-contained reference for practitioners. ISL2 introduces additional security measures across a broad variety of categories: role-based access controls (RBAC) and disk encryption; mobile device management (MDM) solutions, secure communications protocols, and hardware-disposal pro-

TABLE 5.2
Overview of the Insight Security Level 2 Benchmark

Category	Security Measures
Access control and authentication	• Full-disk or full-volume encryption on insight-storing devices • Prohibition of sending sensitive insights over insecure channels • RBAC • Secure authorization for cloud endpoints and application programming interfaces (APIs)
Digital network and endpoint security	• Hardware and document disposal protocols • Browser extension allow-listing • MDM • Secure communications protocols • Secure communications channels using encrypted protocols
AI model resilience	• No API keys in client-side code • Controlled use of algorithmic insights as training data • Restricted information in AI deployment interfaces and APIs
Insight compartmentalization	• Compartmented authorization lists • Need-to-know sharing of sensitive research within relevant teams
Threat detection, monitoring, and incident response	• Protective domain name system (DNS)
Insider threat mitigation and personnel security	• Structured offboarding and exit procedures for departing employees • Security awareness and operational security (OPSEC) training • Whistleblower reporting and protection

cedures; comprehensive security training, offboarding procedures, and whistleblower protections; and protective DNS services. **For many of these measures, the incremental cost of implementation is low relative to the security benefit, making ISL2 a high-value investment for any organization handling proprietary AI research.**

- **Compartmentalization appears at ISL2 as an informal organizational practice by ensuring that sensitive research is shared only with the teams that need it rather than broadly across an organization.** This lightweight, need-to-know-type practice reduces the risk of opportunistic compromise without requiring the overhead of formal compartment structures (which are introduced at ISL3).

Insight Security Level 3

Definition

A system that can likely thwart cybercrime syndicates or insider threats (OC3). This level includes the operations of many world-renowned criminal hacker groups, well-resourced terrorist organizations, disgruntled employees, and industrial espionage organizations. See Table 5.3 for an overview of ISL3.

Key Takeaways

- **Comprehensive document policies—including sensitivity labeling, securing repositories, watermarking, tracking, minimizing hard copies, and secure printing—provide the classification framework that compartments operate in.** Filesystem-level tagging with input/output (I/O) restrictions should enforce these policies technically,¹ and the restrictions can be complemented by information-flow monitoring between compartments, clean-desk requirements, and secure data deletion methods.
- **An insider-threat program becomes essential.** Because a single knowledgeable employee can constitute a complete vector for insight theft, behavioral monitoring through user and entity behavior analytics (UEBA) systems, employee spot-checking, new-hire screening, and rigorous offboarding procedures are critical. The prohibition on bring-your-own-device (BYOD) and external-removable-media policies, combined with data-loss-prevention (DLP) systems and clipboard and screen-capture controls, restricts insider-exfiltration pathways.
- **Network and endpoint hardening expands substantially.** Network segmentation, periodic device inspection and layering, device and port hardening, and locked-down mobile email clients all serve to reduce attack surfaces. Supply chain security measures—including multiparty threshold cryptography, dependency auditing, version pinning, and separate environments for cloning third-party repositories—are all aimed at addressing software supply chain vectors that scored highly across OC levels.
- **Organizations should expect security measures at this level to begin imposing noticeable constraints on operational flexibility.** The tension between security and productivity might become more pronounced and require careful management at this level.

¹ This restricted tagging can be implemented through advanced SELinux configurations. See Red Hat, “4.7. SELinux Contexts—Labeling Files,” webpage, undated; and Apriorit, “How to Secure and Manage File Access with SELinux,” *Software Development*, blog, November 9, 2023.

TABLE 5.3
Overview of the Insight Security Level 3 Benchmark

Category	Security Measure(s)
Access control and authentication	• Attribute-based access controls (ABAC) • Just-in-time privileged access • Centrally managed device encryption and compliance attestation • Privilege bracketing
Digital network and endpoint security	• Browser and client-side policies for AI research • Clipboard and screen-capture controls • Device and port hardening • Locked-down mobile email clients • Network segmentation (north-south, east-west) • No BYOD for AI research • No external removable media • Periodic deep inspections of high-sensitivity devices
Data protection and handling	• Formal sensitivity classification • Clean-desk policy for sensitive research areas • Document-handling policies • Filesystem-level tagging and I/O restrictions • Secure data deletion • Just-in-time coalescing of insight data into workloads • Volatile memory protections for insight-bearing systems
Insight compartmentalization	• Compartment authorization lists • Compartment-specific nondisclosure agreements (NDAs) • Information-flow monitoring between compartments • Compartment-awareness training • Documented identification of distinct compartments • Codeword and formal designation systems • Compartment access enforced by identity and access management (IAM)
Software integrity and supply chain assurance	• Multiparty threshold cryptography • Third-party dependency auditing • Version pinning and dependency freezing • Separate environments for cloning third-party repositories • Memory-corruption-vulnerability mitigation
Threat detection, monitoring, and incident response	• DLP systems • Runtime application self-protection
Insider threat mitigation and personnel security	• Employee spot checks for security compliance • New-hire screening • UEBA
Physical and environmental security	• Prevent surveillance via windows

Insight Security Level 4

Definition

A system that can likely thwart most standard operations by leading cyber-capable institutions (OC4). This level includes the operations of many of the leading state-sponsored groups, many intelligence agencies, and the top cyber-capable countries that are able to execute such operations more than 100 times per year. See Table 5.4 for an overview of ISL4.

TABLE 5.4
Overview of the Insight Security Level 4 Benchmark

Category	Security Measure(s)
Access control and authentication	• Biometric access control for high-risk zones • Dual-person or team-based access requirements for high-sensitivity insights • No sharing of insights via personal and nonapproved devices
Digital network and endpoint security	• Air-gapped production networks for insight workloads • Enhanced security on mobile devices • No wireless internet in secure facilities where insight-related work takes place • No external devices in secure research areas • Short hardware life cycle, with mandatory replacement intervals
Data protection and handling	• Data access fingerprinting • One-time programmable media for critical records • Self-destructing or expiring data copies • Enhanced volatile memory protection
Insight compartmentalization	• Cryptographic separation between compartments • Independent security assessment per compartment • Kernel-level DLP with file tainting • Minimization or elimination of shared resources across compartments
Software integrity and supply chain assurance	• Continuous software-bill-of-materials (SBOM) management • Deterministic and reproducible builds for key software • Disallowance of nonlocal AI code assistants • Post-quantum encryption standards • Formal verification of cryptographic implementations • Independent verification of hardware supply chain
Threat detection, monitoring, and incident response	• Deliberate misinformation (“canary traps”) • Radio frequency (RF) side-channel monitoring • Shadow Internet of Things (IoT) detection
Insider threat mitigation and personnel security	• Insider-risk surveillance • Strict international travel policies • Relationship-reporting requirements • Mandatory vacations and duty rotations (to detect anomalies that surface when regular operators are absent and to limit prolonged unsupervised access) • Media and publication reviews and social media policies • Remote work from only approved fixed locations • Exit screenings from secure workspaces
Physical and environmental security	• Noise for side-channel mitigation • Window noise and masking • Noise-proof or acoustically isolated rooms • Perimeter IDS (PIDS) • RF or Faraday shielding • Server rack tamper protection • Visual privacy screens or filters

Key Takeaways

- **Attack surfaces must be reduced to the extent that remaining security-critical surfaces can be comprehensively (and often manually) hardened, reviewed, monitored, and penetration-tested.** Achieving this reduction requires significantly more operational friction than lower ISLs.
- **Several ISL4 measures require significant lead time to implement them effectively.** Organizations that anticipate needing ISL4 protections should begin investing early in physical infrastructure (e.g., Faraday shielding, PIDS, and facility modifications for visual and acoustic privacy) and personnel security pipelines (e.g., insider-risk surveillance frameworks, travel-policy development, and exit-

screening procedures). Starting these efforts ahead of when the need arises preserves optionality even if precise timelines remain uncertain.

- **For security-critical junctions, software assurances and general-purpose hardware should no longer be trusted.** Critical security assumptions must be enforced in hardware, which could require fundamental changes to development environments, corporate offices, and data centers. Such changes include short hardware time-to-life cycles, biometric access controls, one-time programmable media for sensitive data, and independent verification of the integrity of the hardware supply chain.
- **Kernel-level enforcement of compartment boundaries represents a major technical escalation specific to insight security.** At this ISL, the operating system or hypervisor enforces isolation—such as through mandatory access control frameworks or virtual machine-based isolation—so that even privileged users in one compartment cannot read files, attach debuggers, or otherwise access resources in another compartment. This provides a substantially stronger guarantee than application-layer or purely policy-based controls. Independent security assessments and red-team exercises should also be conducted for each compartment’s configuration and enforcement mechanisms.
- **Physical and environmental protections address the broader attack surface more for insights than weights.** RF or Faraday shielding, visual privacy screens, acoustic dampening, noise injection in facility windows, and PIDS help defend against side-channel attacks, visual and audio surveillance, and unauthorized physical access.
- **Personnel security measures become significantly more restrictive at this level.** Such measures include limitations on employees’ personal activities, such as employing social media publication reviews, strict international travel policies, remote-work restrictions, and screenings after leaving workspaces.
- **Compartmentalization provides the primary structural defense against sophisticated insider threats, including planted operatives.** Even if a nation-state actor successfully places an employee inside an organization, cryptographic compartment boundaries at ISL4 limit that operative’s access to a single insight domain. No single insider should be able to gain access to a complete set of algorithmic insights. Detecting such operatives remains difficult; ISL5’s cleared-personnel requirements represent a more direct (though still imperfect) defense against this vector.

Insight Security Level 5

Definition

A system that could plausibly be claimed to thwart most top-priority operations by the top cyber-capable institutions (OC5). This level includes the handful of operations that the world’s most capable nation-states would prioritize. See Table 5.5 for an overview of ISL5.

Key Takeaways

- To achieve ISL5, the **most-protected insights would need to reside in completely network-isolated environments** that are disconnected from the external world, and all insight work and communication would be restricted to approved secure locations. Stringent policies on information transfer prevent even those with approved access from easily moving data between compartments.
- **ISL5 security measures require the longest lead times of any ISL. The isolated, physically hardened facilities required at this level demand specialized construction, stringent accreditation processes, and potential government coordination, all of which can take years to complete.** Cleared-personnel pipelines, supply chain compartmentalization across separate procurement channels, and the organizational restructuring needed to eliminate cross-compartment personnel each require sustained

TABLE 5.5
Overview of the Insight Security Level 5 Benchmark

Category	Security Measure(s)
Access control and authentication	• No sharing of insights beyond approved digital and physical areas
Insight compartmentalization	• No cross-compartment personnel for top compartments • Physical information transfer protocols • Supply chain compartmentalization
Insider threat mitigation and personnel security	• Cleared-personnel access (or an equivalent verification process) for specific algorithmic insights • No remote work on algorithmic insights • Onsite living quarters • Travel restrictions
Physical and environmental security	• Highest-tier physical protection standards
Software integrity and supply chain assurance	• Formally verified systems software for proprietary workloads

investment well before they become operationally necessary. Organizations that think that ISL5 might eventually be warranted should begin exploring partnerships with the national security community and initiating planning as early as possible.

- **Isolated, physically hardened compartmented facilities with emanation shielding and stringent access controls are fundamental architectural requirements at this level.** Multiple such facilities might be required, which would be a substantial investment.
- **The personnel exclusivity requirement (i.e., no cross-compartment personnel) is particularly challenging with AI research because researchers often need to integrate insights across multiple domains.** Organizations must carefully structure work to minimize the need for individuals to access multiple high-sensitivity compartments. Combined with the restriction of all work occurring at approved secure locations, researcher travel prohibitions, and, potentially, onsite living quarters, these measures represent severe limitations on operational flexibility.
- **Supply chain compartmentalization** (i.e., maintaining separate procurement channels for different compartments) provides defense against nation-state adversaries that might have compromised specific supply chains but not all of them.
- Organizations should recognize that security at this level is **strongly prioritized over operational availability and convenience**. Strict operational constraints are not open to exceptions, even if systems are down or critical operations issues arise.

Securing Insights Versus Securing Weights

The security measures in this report reflect fundamental differences between protecting algorithmic insights versus protecting model weights. SMW’s WSL2 benchmark states that “weights are stored exclusively on servers, not on local devices, such as laptops”—a constraint that eliminates entire categories of endpoint-related attack vectors.²

Although organizations should aggressively minimize distribution through compartmentalization and centralized repositories, a complete isolation of insights is extremely difficult, possibly even infeasible.

² Nevo et al., 2024, p. 74.

The authors of SMW analyzed five distinct environments in which model weights require protection: training, research, internal deployment, public API deployment, and on-premises deployment. This environment-specific analysis makes sense for weights because they exist as concrete files in well-defined locations with specific access patterns in each environment.

Rather than attempting to specify security requirements for each possible environment, we focus on the characteristics of insights themselves (their properties, format, and access requirements) and the attack vectors that might compromise them regardless of environment. Organizations can then apply these vector-centric security measures across whatever environments their specific operations require.

Compartmentalization represents the most significant departure from weight-security approaches. Insight security requires managing multiple information categories with different sensitivity levels and rigorously controlling information flows between them. In **Appendix D, we provide a detailed framework for progressive compartmentalization across ISLs, moving from informal need-to-know practices at ISL2 through formalized compartment structures and technical enforcement at ISL3, cryptographic separation at ISL4, and full architectural isolation at ISL5; we also provide guidance on how an organization might structure compartment boundaries that are based on the organization’s specific operational contexts.**

Notable Areas of Consensus and Disagreement

We encountered a significant diversity of expert opinions related to security measures and benchmarks. We describe which aspects manifested more or less variation as follows.

Areas of Consensus

- **Compartmentalization as foundational for insights:** There was strong agreement that protecting algorithmic insights requires compartmentalization approaches of substantial sophistication, reflecting the distributed nature of insights and the multiple sensitivity levels that must be managed simultaneously.
- **Personnel security importance:** Experts overwhelmingly agreed that insider threats and HUMINT operations represent primary risks for insight security. The consensus was that personnel security measures, behavioral monitoring, and employee-departure policies represent critical areas of investment given the central role that human judgment and access play in insight security.
- **Lower-level convergence:** There was significant convergence on ISL1 and ISL2 benchmarks: Experts generally agreed on what constitutes basic security hygiene and industry best practices.

Areas of Disagreement

- **Physical security measures:** Some experts with backgrounds in traditional cybersecurity questioned the necessity or cost-effectiveness of advanced physical security measures (e.g., side-channel prevention measures, acoustic dampening, compartmented facilities with emanation shielding), while experts with backgrounds in the intelligence community mostly considered these measures to be essential for protecting against nation-state adversaries.
- **Productivity versus security trade-offs:** Measures expected to result in significant costs to productivity, collaboration, and organizational culture were highly controversial. The disagreement centered less on whether high-level security measures are necessary or whether they impose significant costs and more on whether the security benefits justify those costs in specific organizational contexts. Experts who emphasized the necessity of strong security did not generally dispute the high costs involved; those who emphasized the costs did not generally dispute the security need. The practical consideration is whether the value of the algorithmic insights that an organization aims to protect warrants the operational disruption that higher ISLs entail.

Implications and a Path Forward

Organizations that are developing frontier AI systems face a fundamental challenge: The insights that provide a competitive advantage are inherently difficult to secure, yet their unauthorized proliferation could eliminate technological leads that have taken years and billions of dollars to establish.

The framework that we presented in this report—which comprises 44 attack vectors across nine categories, five ISLs, and corresponding benchmarks—provides organizations with a structured approach for assessing their security postures and identifying the areas in which investment is most needed. Our analysis also clarifies some of the practical trade-offs involved, particularly with higher ISLs, and can help organizations make deliberate choices about which protections to implement depending on the value of the insights they hold.

The ISLs represent a spectrum of increasing protection with corresponding increases in operational costs and organizational changes. ISL1 and ISL2 security measures align with established security best practices and impose minimal operational burdens; it seems likely that many organizations developing proprietary AI systems have either already implemented these measures, or the organizations should be interested in doing so. ISL3 introduces more-substantial constraints, including formal compartmentalization, enhanced personnel screening, and dedicated security infrastructure, but these measures are within the range of what security-conscious organizations in defense contracting and other sensitive and regulated industries already maintain. Beyond ISL3, the trade-offs become more pronounced. The measures associated with ISL4 and ISL5, such as isolated compartmented facilities with emanation shielding, government-standard personnel vetting, supply chain compartmentalization, and restrictions on researcher travel and communication, represent a fundamentally different mode of operation.

Whether these trade-offs are warranted depends on the value of the specific insights an organization aims to protect and the capabilities of adversaries the organization expects to face. Organizations considering ISL4 or ISL5 protections would likely need to explore partnerships with the national security community.

Several categories of security measures require significant lead time and are unlikely to be quickly spun up when circumstances change. Organizations that might need to operate at ISL3 or higher within the next several years should consider preparing in at least three areas: physical infrastructure (including secure facilities, environmental controls, and access systems), personnel security programs (including screening pipelines, behavioral monitoring, and structured offboarding), and supply chain assurance (including vendor auditing, SBOM management, and hardware verification). Starting these efforts early preserves optionality even if the timeline and ultimate ISL remain uncertain.

This report represents a first step toward a systematic understanding of algorithmic insight security. The threat landscape continues to evolve, and the specific assessments in this report will need to be revisited as capabilities advance and as organizations gain experience implementing these frameworks. We hope that this analysis facilitates more-informed decisions about which algorithmic insights warrant protection and at what level and cost—decisions that might prove consequential for competitive positioning, national security, and the trajectory of AI development itself.

Methods for Eliciting Expert Judgments on Securing AI Algorithmic Insights

In this appendix, we explain how we gathered and analyzed expert input to identify which attack vectors pose the greatest threats to AI algorithmic insights and which security measures most effectively protect them.

We engaged experts through three complementary modes: an in-person workshop, asynchronous worksheet submissions, and individual interviews. Each mode followed the same objectives:

- Develop a detailed understanding of attack vectors targeting AI algorithmic insights.
- Evaluate the perceived effectiveness of specific security measures across multiple SLs for protecting these insights.

Together, these activities formed the foundation for our analysis of expert judgments on securing AI algorithmic insights. This multimodal approach allowed us to capture a wide variety of perspectives and helped us produce robust, evidence-based findings while maintaining methodological consistency across data sources.

Participants

We invited subject-matter experts with a variety of technical and organizational backgrounds that are relevant to AI security. Table A.1 summarizes the participants' areas of expertise.

Modes of Expert Engagement

We used three modes to gather expert perspectives:

- **Preworkshop homework and worksheets.** Two weeks before the workshop, we asked participants to complete a short homework assignment that introduced key definitions, and we asked participants to rate the feasibility of attack vectors and the effectiveness of security measures. These worksheets provided initial quantitative data and helped shape the workshop agenda.
- **In-person workshop.** The workshop took place in San Francisco in May 2025 and spanned two days. Sessions focused on refining definitions, rating attack vectors' feasibility, and evaluating mitigations' effectiveness. Participants discussed OC levels (OC1 through OC5) and SLs (SL1 through SL5), identified gaps in existing frameworks, and proposed refinements. We followed Chatham House rules to encourage candid discussion.
- **Individual expert interviews.** We conducted semistructured interviews with eight experts to capture deeper reasoning and validate findings. Each 45-minute interview followed a standardized protocol

TABLE A.1
Study Participants, by Expertise

Expertise	Number of Participants
Security engineering	4
Security leadership	4
HUMINT attacks	3
Hardware security	3
Security product management	2
Supply chain attacks	1
RF and over-the-air (OTA) attacks	1
AI research	1
AI safety	1

NOTE: The workshop had 20 participants: Ten were in person and ten were asynchronous participants. Some participants had more than one area of expertise.

that explored attack feasibility, mitigation effectiveness, and broader reflections on securing AI algorithmic insights. We conducted interviews virtually.

Data Integration and Analysis

We integrated data from all three modes (i.e., homework worksheets, workshop discussions, and interviews) into a mixed-methods analysis. We used quantitative ratings from worksheets and workshop exercises to calculate gap scores comparing adversary capabilities with mitigations' effectiveness. We coded qualitative data from facilitator notes and interview transcripts using a structured thematic schema.

Integration across modes allowed us to triangulate findings, identify consistent patterns, and recognize outlier perspectives. This approach strengthened the reliability of our conclusions about which attack vectors pose the greatest threats and which security measures are most effective for protecting algorithmic insights.

Data Management and Confidentiality

All data-collection activities followed RAND's human-subjects protection procedures. Participation in the activities was voluntary and was conducted on a not-for-attribution basis. Notes and recordings were securely stored and accessible only to the study team. Audio recordings were deleted after transcription and verification.

Individual responses were anonymized before analysis, and we present aggregated results in this report without identifying information. These procedures ensured confidentiality while preserving the richness of the experts' perspectives.

Coding Schema

We used the coding schema in Table A.2 to analyze workshop and interview data. Codes captured participants' roles, definitions of algorithmic insights, attack vectors, OC levels, SLs, mitigation strategies, and rationales behind the experts' assessments.

TABLE A.2
Thematic Codebook Used for the AI Security Workshop

Code	Definition
Role	
Security leadership	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals in organizational leadership roles who are responsible for the overall security strategy and decisionmaking related to AI and algorithmic insights
Hardware security	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals whose primary expertise involves protecting and assessing the vulnerability of physical computing components, hardware-centric systems, or devices against attacks or breaches
Security engineering	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals who design, implement, and assess technical security controls and solutions to protect AI systems and algorithmic insights
Security product management	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals overseeing the life-cycle management, integration, and user needs of security products, tools, or platforms as they relate to AI and algorithmic insights
AI safety	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals focused on minimizing, identifying, or preventing harm arising from AI systems, such as misalignment or unsafe behaviors
AI research	Statements or perspectives that reflect the viewpoint, priorities, or judgments of individuals engaged in foundational or applied research in AI, particularly as it relates to new algorithmic developments, vulnerabilities, and system capabilities
Algorithmic insights	
Evaluation metrics	Discussion of methods or benchmarks used to evaluate training outcomes and performance improvements in AI models or algorithms
Level of improvement	Mention of the degree or significance of gains achieved (which must be validated), including optimizer development, dataset design, and training-efficiency improvements
Optimizer development	Discussion focused on new or improved mathematical formulas or algorithms for creating or enhancing optimizers
Dataset design	References to how better or different dataset composition contributes to improvements in AI training outcomes
Training efficiency	Emphasis on increasing the speed or reducing the compute requirements (e.g., graphics processing unit [GPU] reliance) for training AI models
Insights as ideas	Recognition that algorithmic insights are fundamentally actionable ideas; includes communicability (e.g., can be shared in a 30-minute call), goal dependence, public visibility, and the importance of knowing what does not work
Effort	Assessments of the time, cost, resources, or complexity needed to obtain, discover, or validate an insight or solution or the evaluation of the tractability of a security or AI challenge
Types of attacks	
Misconfiguration	Identification and discussion of security risks resulting from incorrect system, network, or software configurations
Remote code execution	Vulnerabilities or attacks enabling unauthorized parties to run code on targeted systems or infrastructure remotely
Running unauthorized code	Threats or scenarios in which unauthorized code (including exploits, malware, or unvalidated scripts) is executed within a protected environment
Supply chain	Risks and attack vectors associated with the compromise or manipulation of third-party hardware, software, or service providers in the supply chain
Breaking encryption algorithms	Concerns about or methods of defeating cryptographic protections to access protected data or models

Table A.2—Continued

Code	Definition
Military takeover	References to low-probability, high-impact scenarios involving state or military actors overtaking or seizing physical or digital assets
Misaligned AI exfiltration	Scenarios in which an AI system, because of misalignment or unintended behavior, leads to the unauthorized exfiltration of data or insights
Agentic-based attacks	Attacks in which autonomous or agent-based systems are used, intentionally or unintentionally, to further compromise, leak, or exploit algorithmic insights
Brute-forcing passwords	Attacks that rely on systematically guessing passwords or cryptographic secrets through automation
Physical security	Measures and risks relating to physical access to and protection of devices, facilities, or critical systems
TEMPEST	Concerns about side-channel attacks via electromagnetic (EM) or other physical emanations to extract information from hardware devices
HUMINT	Threats and risks arising from HUMINT operations, such as social engineering, insider threats, surveillance, or coercion of personnel
OC level	
OC1	Refers to attack scenarios or capacities associated with an OC level of 1 (e.g., amateur attempts)
OC2	Refers to attack scenarios or capacities associated with an OC level of 2 (e.g., professional, opportunistic attacks)
OC3	Refers to attack scenarios or capacities associated with an OC level of 3 (e.g., targeted attacks, persistent actors)
OC4	Refers to attack scenarios or capacities associated with an OC level of 4 (e.g., state-supported or advanced actors)
OC5	Refers to attack scenarios or capacities associated with an OC level of 5 (e.g., nation-state attacks, attacks with a large resource commitment)
SLs	
SL1	References to or an evaluation of SL1, the baseline or minimal set of recommended security controls and benchmarks
SL2	References to or evaluation of SL2, building on SL1 with increased controls and benchmarks
SL3	References to or evaluation of SL3, building on SL2 with enhanced controls and benchmarks
SL4	References to or evaluation of SL4, building on SL3 with even more stringent controls and benchmarks
SL5	References to or evaluation of SL5, involving the highest set of security benchmarks, including highly restrictive physical and environmental controls
Mitigation factors	Aspects of specific countermeasures, including difficulty, resource-intensiveness, or feasibility of whether or how well an attack can be prevented or limited
Effort (mitigation)	The high effort, cost, or complexity required to implement a particular security measure or mitigation, such as the use of Sensitive Compartmented Information Facilities or the elimination of remote work
High concern	Attack vectors, vulnerabilities, or scenarios that workshop participants considered to be a high concern
Low concern	Attack vectors, vulnerabilities, or scenarios that workshop participants considered to be a low concern
Concern factors	Specific elements (such as OC or reachability) driving the degree of concern about a given attack vector or scenario

Table A.2—Continued

Code	Definition
OC level	The OC level of an adversary, including considerations of an actor's capabilities, an attack's reach, and effective security measures in place
High importance	Mitigation or security measures seen as highly critical or prioritized in relation to protecting IP or AI insights
Low importance	Mitigation or security measures seen as less critical or prioritized in relation to protecting IP or AI insights
Importance factors	Elements that increase the perceived importance of a mitigation, such as tractability or relevance to company priorities
Tractability	The degree to which a problem or attack vector can be effectively mitigated or addressed
Personal interest	The influence of an individual participant's background, expertise, or motivation in driving the perceived importance or focus given to a particular issue

NOTE: The "Role" codes in this schema were applied only for those participants who took part in the workshop or interviews. The codes do not encompass all areas of expertise listed in Table A.1 because individuals who completed only the preworkshop worksheets were not included in the qualitative coding process. Their input was analyzed quantitatively, as described in the main report, rather than thematically.

Detailed List of Attack Vectors

In this appendix, we provide detailed descriptions of the attack vectors relevant to securing algorithmic insights. We organized the attack vectors by category, as listed in Table 4.1 in Chapter 4. In this appendix, we provide context and references to real-world examples, research, and documented vulnerabilities for each attack category.

Because algorithmic insights differ fundamentally from model weights in their nature and distribution, we modified the attack-vector taxonomy from SMW. We identified 44 attack vectors across nine categories, which were the same nine categories used in SMW. Of these 44 vectors, 38 are inherited from the SMW framework and apply directly to algorithmic insights, although some vectors received substantial insight-specific modifications. Six vectors are new contributions and are specific to algorithmic insight security (these are marked with a superscript *a* in Table 4.1). We also describe insight-specific manifestations of nine existing vectors that, while not warranting separate categorization, take on distinctive forms in the context of algorithmic insights and are useful for concrete threat modeling. The attack vectors are organized into the following categories:

- Running unauthorized code
- Compromising existing credentials
- Undermining the access control system itself
- Bypassing the access control system altogether
- AI-specific attack vectors
- HUMINT
- Nontrivial access to data or networks
- Unauthorized physical access to systems
- Supply chain attacks

For attack vectors that appear in both this report and SMW, we provide adapted descriptions that emphasize algorithmic insight-specific considerations while referencing SMW for its comprehensive technical details. Readers seeking implementation-level security guidance should consult both reports.

Running Unauthorized Code

A ubiquitous attack vector in today’s information security landscape is malicious actors exploiting software vulnerabilities or accessible interfaces to run unauthorized code. Essentially, this means making a system or device execute commands dictated by an attacker rather than by its legitimate owner. This category includes methods that might not introduce new code into the system, such as “living-off-the-land” techniques (e.g., return-oriented programming). Running malicious code overlaps considerably with other categories: It is a key tool in such attacks as stealing credentials, supply chain attacks, and undermining access control systems; many other types of attacks can be used to achieve remote code execution.

We expanded this category from SMW to include specific avenues of running unauthorized code that are particularly noteworthy given the more diffuse nature of algorithmic insights and their security-relevant characteristics. In the context of insights, successful code execution on researcher workstations, internal communication systems, or development environments could provide direct access to algorithmic knowledge that would be more compartmentalized in a weight-security context.

Exploitation of Vulnerabilities for Which a Patch Exists (Attacking Nonupdated Software)

These are known vulnerabilities that have been reported and have working patches, but some systems remain unpatched because of lax update policies or because of the use of products for which the vendor is no longer providing patches.

As detailed in Appendix A of SMW, this vector remains one of the most common entry points for attackers of all capability levels. For algorithmic insights specifically, the distributed nature of research environments (in which developers might use personal devices, work from home, or operate in less controlled environments than production data centers) creates expanded opportunities for the exploitation of unpatched systems.

Exploitation of Reported but Not Fully Patched Vulnerabilities

These are known vulnerabilities for which the vendor has either not provided a patch or provided a patch that only partially addressed the issue. During the window in which vulnerabilities remain unpatched, malicious actors can readily exploit them because their existence is already known.

SMW provides extensive examples, including the Spectre and Meltdown vulnerabilities and various virtual private network (VPN)–secure sockets layer flaws. For insights security, this vector is particularly concerning because research environments often prioritize functionality and collaboration over aggressive patching cycles, and the broad diversity of software in ML development stacks creates numerous potential gaps.

The Finding and Exploitation of Individual Zero-Days

Zero-days are vulnerabilities that a vendor or the broader cybersecurity community has not yet identified. Therefore, patches do not exist, and it is harder to detect their exploitation.

As documented in SMW, individual zero-days can be bought in markets for prices between \$10,000 and \$2.5 million depending on the platform. According to a 2017 RAND report, the mean time from initial detection of a zero-day by an exploit developer to public disclosure by an outside party is 6.9 years.¹

Compromising Existing Credentials

This category involves abusing credentials (such as encryption keys, passwords, and cookies) that have been legitimately assigned to a user. The compromise can be a full attack (e.g., gaining access to insight repositories) or a stepping stone toward accessing tools or resources enabling more-advanced attacks.

¹ Lillian Ablon and Andy Bogart, *Zero Days, Thousands of Nights: The Life and Times of Zero-Day Vulnerabilities and Their Exploits*, RAND Corporation, RR-1751-RC, 2017.

For algorithmic insights, credential compromise is particularly concerning because insights are distributed across numerous systems, and the compromise of a single set of credentials might provide access to multiple insight-containing resources.

Social Engineering

Social engineering is a relatively low-cost way to influence employees to perform actions that would allow an attack. MFA is often considered an appropriate response to social engineering attacks, yet slightly more advanced social engineering attacks can overcome the most common MFA schemes.

As detailed extensively in SMW, social engineering encompasses automated or general schemes (phishing at scale), more-targeted schemes (spear phishing, whaling), and sophisticated approaches that can bypass MFA. For algorithmic insights specifically, additional considerations apply.

Insight-Specific Considerations

- Researchers operate in cultures that value openness and collaboration, making them potentially more susceptible to requests that are framed as legitimate professional interest.
- Conference and academic settings create natural opportunities for targeted social engineering.
- The complexity of AI systems means that plausible pretexts for requesting technical information are readily available.
- Remote work environments reduce informal verification methods that might catch social engineering attempts (e.g., “Did you really send me that email?”).

Exploitation of Exposed Credentials

Authorized users might be careless with their credentials and leave them accessible to an attacker. Additionally, a system might have been designed carelessly to allow surreptitious access to credentials even without a user’s neglect.

SMW documents this vector comprehensively, noting that “57 percent of employees write passwords on sticky notes” and “5.5 out of every 1,000 GitHub commits contain unprotected software secrets.”² For insight security, the proliferation of API keys, access tokens, and credentials across ML development environments creates extensive exposure opportunities.

Expansion of Illegitimate Access (e.g., Escalation of Privileges)

Existing credentials are often obtained by first gaining some illegitimate access to a system and then obtaining credentials that provide further access. A more indirect version is purchasing credentials from disclosures.

As detailed in SMW, this vector was central to major breaches, including the Sands Hotel hack, the NotPetya attack, the LastPass breach, and the Triton/Trisys malware attacks on power plants. For insights, the concern is that initial access to any system in the research environment might provide pathways to more-sensitive insight-containing resources.

² Nevo et al., 2024, p. 45.

Undermining the Access Control System Itself

An attacker could use various tools to undermine the mechanisms responsible for reliably providing (or withholding) access. We use the term *access control system* loosely to include any security component that is responsible for preventing unauthorized access to data, such as encryption, authentication, and the permissions system.

The Authentication or Bypass of Vulnerabilities (in the Access Control System)

This vector entails breaking the existing encryption or authentication scheme underlying the security of the access control system. The most direct approach is finding a flaw that enables someone to decrypt a secret, forge credentials, or gain access to a resource despite not being an authorized user.

SMW provides extensive technical details on this vector, including examples from Wired Equivalent Privacy algorithm vulnerabilities, collision attacks against the message-direct algorithm MD5, the Logjam vulnerability, and the SolarWinds breach. These apply equally to insight security.

Access to Secret Material That Undermines a Protocol

An attacker can gain illegitimate access to a key or other secret that undermines the reliability of a protocol or platform, even if that secret does not belong to the victim. This might involve gaining access to the private key of a certificate authority or to parameters used to generate code-signing keys.

As documented in SMW, examples include the Comodo and DigiNotar certificate authority breaches and the Content Scramble System key exposure. This vector is equally relevant for insight security.

Bypassing the Access Control System Altogether

Attackers might not need to cope with the systems in place for security, authentication, or controlling access if they can find an alternative path to the information they seek.

Incorrect Configuration or Security-Policy Implementation

Configuration errors might unintentionally enable access. Similarly, a security policy might be established but not actually implemented. For instance, a database could be accidentally left accessible even though it contains sensitive information.

SMW documents this vector extensively, noting that more than 11 percent of reported U.S. data breaches involved unintentional disclosure by the breached organizations themselves.³ For insight security, the complexity of ML development environments (with their numerous cloud services, APIs, and data stores) creates abundant opportunities for configuration errors.

Additional (Less Secure) Copies of Sensitive Data

Additional copies of data might not be monitored or secured as thoroughly as the “main copy.” The additional copy might be intentionally created (e.g., backup copies or local copies used by research teams) but might be inadequately secured or accidentally retained.

³ Nevo et al., 2024, p. 51.

As documented in SMW, this vector was involved in breaches at the U.S. Department of Veterans Affairs, Uber, and London's Heathrow Airport.

Insight-Specific Considerations

- Researchers might maintain local copies of code, notebooks, and documentation on personal devices.
- Email attachments and chat logs could contain insight-relevant discussions.
- Collaboration tools (Google Docs, Notion, Confluence) accumulate insight documentation.
- Training checkpoints, experimental branches, and abandoned code repositories might contain sensitive implementations.
- Conference presentation drafts, paper submissions, and grant applications might describe insights.

AI-Specific Attack Vectors

Some attacks target AI infrastructure itself and are only relevant to AI systems. Because AI is a relatively new field, real-world examples are still scarce, but this should not lead to a false sense of security. The nascent state of the field likely implies that AI infrastructure is more vulnerable than other types of infrastructure rather than less.

Exploitation of Existing Vulnerabilities in the Machine Learning Stack

Adversaries might exploit preexisting vulnerabilities in the ML software and hardware stacks to execute malicious code or otherwise undermine security. This is an AI-specific subset of the running unauthorized code category; however, executing such an exploit might require less expertise on vulnerabilities (because of the existing state of ML infrastructure) and more ML expertise.

Prompt-Triggered Code Execution

This vector consists of bypassing restrictions of a model that can execute code by specially crafting prompts to manipulate the model's behavior (i.e., *prompt injection*). Some prompt-injection attacks might be used to execute code and overlap with code-execution attacks.

As documented in SMW, examples include the MathGPT vulnerability and prompt-injection vulnerabilities in LangChain. For insight security, AI coding assistants and research tools with code-execution capabilities represent potential attack pathways.

Model Extraction

The answer to each query of a model bears information on the weights that helped produce the answer. At least in theory (and to some extent in practice), someone could infer weights or additional information from examining enough query responses.

SMW documents this vector, noting that experts varied widely in how plausible they thought such attacks were and that researchers have successfully extracted embedding matrices of OpenAI models using typical API access.

Example

- In a 2025 survey, researchers demonstrated that adversaries can systematically replicate ML models' functionality through query-based attacks on ML-as-a-Service APIs, extracting architecture details, parameters, and decision boundaries without relying on insider access to steal algorithmic insights.⁴

The Staging of Data Poisoning for the Exfiltration of Insights

Expert discussions revealed that security practitioners at frontier AI companies are concerned about a very sophisticated attack: poisoning training data or fine-tuning inputs such that a deployed model will later stage or exfiltrate sensitive information under specific conditions. The model behaves normally until it encounters a trigger (a phrase, date, or context), at which point it executes hidden behavior, potentially copying insights to less secured locations or encoding them in external outputs.

This vector is specific to algorithmic insight security and was not in SMW.

Example

- Anthropic's "Sleeper Agents" research demonstrated that models can be backdoored to insert security vulnerabilities into generated code when triggered by a change of year (in this case, 2023 to 2024). Standard safety training (RLHF, supervised fine-tuning) failed to remove this behavior.⁵

Autocomplete and Code Assistant Leakage

AI coding assistants with broad codebase access might leak compartmentalized information through their suggestions. When an assistant is trained on or has retrieval access to an organization's full codebase, the assistant's completions might surface sensitive algorithmic implementations to users who lack direct access to those repositories. The assistant effectively bypasses access controls by serving as an intermediary with broader permissions than any individual user. This leakage could be inadvertent, allowing attackers with access to internal models to discover insights that would otherwise require higher levels of access—or it could be the result of deliberate poisoning attacks by adversaries.

Examples

- In 2025, researchers demonstrated "CamoLeak," a vulnerability in GitHub Copilot Chat that allowed attackers to exfiltrate source code and secrets from victims' private repositories through prompt injection, including an extraction of Amazon Web Services keys and zero-day vulnerabilities.⁶
- USENIX Security's 2021 research demonstrated data- and model-poisoning attacks against neural code auto-completers in which attackers inject specially crafted files into training corpora to cause models to suggest insecure code (e.g., weak encryption modes, outdated protocols) in specific contexts without degrading overall accuracy.⁷

⁴ Kaixiang Zhao, Lincan Li, Kaize Ding, Neil Zhenqiang Gong, Yue Zhao, and Yushun Dong, "A Systematic Survey of Model Extraction Attacks and Defenses: State-of-the-Art and Perspectives," arXiv, arXiv:2508.15031, August 20, 2025.

⁵ Evan Hubinger, Carson Denison, Jesse Mu, Mike Lambert, Meg Tong, Monte MacDiarmid, Tamera Lanham, Daniel M. Ziegler, Tim Maxwell, Newton Cheng, et al., "Sleeper Agents: Training Deceptive LLMs That Persist Through Safety Training," arXiv, arXiv:2401.05566v3, January 17, 2024.

⁶ Omer Mayraz, "CamoLeak: Critical GitHub Copilot Vulnerability Leaks Private Source Code," *Legit* blog, last updated February 12, 2026.

⁷ Roei Schuster, Congzheng Song, Eran Tromer, and Vitaly Shmatikov, "You Autocomplete Me: Poisoning Vulnerabilities in Neural Code Completion," *Proceedings of the 30th USENIX Security Symposium*, August 2021.

Human Intelligence

Some attacks involve influencing people rather than influencing technological systems (though, as always, the boundaries are fuzzy). As with other categories, HUMINT might be used as a component in a broader attack (e.g., to first gain access to a network using other tools). Expert discussions consistently emphasized HUMINT as a high-priority threat category for algorithmic insights.

Bribes and Cooperation

People can be paid or persuaded to take actions on behalf of an adversary. This includes getting an authorized user to do something “as a favor” or cooperating with users who already have an agenda (e.g., disgruntled employees seeking revenge, ideological employees serving a cause).

As detailed in SMW, examples include the cases of Ana Montes (who was recruited because of her ideological views), Robert Hanssen (who was financially motivated), and the 2023 arrests of Navy sailors for transmitting information to China in exchange for bribes.

Extortion

Instead of providing benefits, an adversary can threaten a person with physical, legal, financial, or other harms. Adversaries will often generate their own leverage; for example, convincing someone to take some small illegitimate action under the pretense that doing so is not significant, then clarifying that the action was, in fact, a major and possibly illegal infraction and threatening to turn the person in unless they continue to cooperate.

SMW documents this vector, noting that its severity ranges from simple tactics to extreme measures, including threats against family members.

Seduction

Seduction, which includes various techniques known as *honey potting* or *honey trapping*,⁸ has been a long-standing technique in espionage tradecraft and presents an attack vector well-suited for adversaries attempting to collect insight secrets from researchers and employees. Foreign adversaries, including assets associated with intelligence services, are known to have sought long-term romantic or sexual relationships as ways of obtaining information and continuous access to people with information.⁹

Adversary assets might track and approach specific employees or opportunistically engage employees at researcher meetups and events. The social nature of research conferences and the relatively small community of frontier AI researchers create opportunities for such targeting.

Candidate Placement

In a sophisticated variation of insider recruitment, a capable adversary might employ and train their own assets before those assets join an organization by helping them become strong candidates for sensitive roles.

As documented in SMW, this is a costly but highly effective methodology once deployed. Actors who use this vector at scale can draw on existing agents who have been trained long before the specific organization was targeted.

⁸ Phillip Knightley, “The History of the Honey Trap,” *Foreign Policy*, March 12, 2010.

⁹ Knightley, 2010.

Organizational Leverage Attacks

At the strategic or institutional level, an organization itself can be coerced or fooled into playing into an adversary's hand. An adversary can build financial or legal leverage over an organization through investments or grants that initially appear innocent but are then used to force access.

SMW documents the U.S. Department of Justice's accusation against Huawei for using legitimate business relationships to steal trade secrets.

Risks from Former Employees

Former employees present a risk because of the information they possess, whether in digital form, physical form, or knowledge that can be shared with other parties and adversaries. This vector might accompany extortion and bribes, or former employees might share information for ideological reasons, career advancement opportunities at competitors, or through inadvertent disclosures.

For algorithmic insights, this vector is particularly significant because insights exist substantially as knowledge in researchers' minds. In many cases, former employees might not even recognize that the knowledge they carry constitutes a proprietary insight.

NDA contracts, screening during offboarding, and communicating the issues and consequences of unauthorized sharing are specific techniques for mitigating this risk.

This vector is specific to algorithmic insight security and was not in SMW.

Example

- In 2025, the U.S. Department of Justice released an indictment against a Chinese national who worked for a major U.S. technology firm, uploaded proprietary technical information, and left to start an “early-stage technology company.”¹⁰

Elicitation of Insights

Adversaries might use conversational manipulation techniques to extract sensitive insights from employees who are unaware that they are being targeted. *Elicitation* refers to intelligence tradecraft in which an adversary engages a target in seemingly innocent conversation designed to draw out information. The adversary structures questions and discussion topics to encourage sharing without revealing their intelligence-gathering purpose. Employees might disclose insights without recognizing the sensitivity of what they are sharing, particularly when the conversation feels collaborative or when normal caution is reduced by the social context.¹¹

Elicitation might occur through in-person methods (conferences, social events, professional networking) or digital channels (technical forums, social media, chat groups).

This vector is particularly significant for algorithmic insights because of the following:

- The culture of AI research emphasizes open discussion and collaboration, making researchers more receptive to technical discussions.
- Researchers might not recognize which technical details constitute protected insights versus publishable knowledge.

¹⁰ Office of Public Affairs, “Superseding Indictment Charges Chinese National in Relation to Alleged Plan to Steal Proprietary AI Technology,” press release, U.S. Department of Justice, February 4, 2025.

¹¹ Center for Development of Security Excellence, *Accidental Conversations: Elicitation Techniques and the Science Behind Them*, job aid, Defense Counterintelligence and Security Agency, June 2025.

- Conference presentations, poster sessions, and informal discussions create natural elicitation opportunities when a person's defenses are lowered.
- Social settings (dinners, receptions, networking events) reduce normal OPSEC awareness.

This vector is specific to algorithmic insight security and was not in SMW.

Nontrivial Access to Data or Networks

Malicious actors might gain access to information or internal networks or services that they are not expected to access. The attack vectors in this category might comprise the full attack (e.g., an attacker gains access to insight-containing resources), or they might be one step in a multistep attack (e.g., providing access to a network in which the attacker can exploit a vulnerability and then continue to explore the network or providing a way of exfiltrating information after the attacker has already successfully injected code). Nontrivial access can be used both to penetrate a sensitive system and to exfiltrate collected information.

For algorithmic insights, this category takes on additional significance because insights can be captured through low-bandwidth channels that would be insufficient for exfiltrating model weights. Side-channel emanations, surveillance of screens or whiteboards, eavesdropping on technical conversations, and OTA attacks on network infrastructure can all yield actionable insight information. Whereas exfiltrating full model weights via these channels would be impractical because of the weights' sizes, a few lines of code, a diagram, or a brief technical exchange might be enough to convey a high-value insight. This category therefore includes both the digital access and side-channel vectors inherited from SMW, as well as several surveillance and RF-based vectors that reflect this expanded threat surface.

External Surveillance

External surveillance covers short- or long-distance audio or visual collection from outside controlled spaces. It includes classic peeping (e.g., line-of-sight photography through windows), as well as more-sophisticated methods, including the use of drones or other unmanned platforms to survey ongoing activity from a distance.

This vector is specific to algorithmic insight security and was not in SMW.

Examples

- Ampflab's X64ACS is a handheld, long-range, highly directional microphone surveillance system with an effective interception range of 150 meters that adversaries could use to collect information.¹²
- In 1980, U.S. Drug Enforcement Agency agents used a magnified, high-powered telescope to successfully read labels on containers inside a target apartment from their location across the street.¹³

Optical or Acoustic Reflection Capture

This vector captures cases in which the attacker does not observe the primary source directly but instead leverages secondary surfaces or signals (e.g., reflections and indirect measurements) to recover content. This can be especially relevant in locations in which direct line-of-sight is blocked but reflective surfaces remain present (e.g., glass walls, windows, glossy objects, whiteboards, even wearable items).

¹² Ampflab, "X64ACS Directional Microphone Technical Specifications and Operating Manual: Microphone Array Designed for Long Range Audio Surveillance," webpage, undated.

¹³ *United States v. Tabor*, 635 F.2d 131, 2d Cir., November 24, 1980.

Examples

- In 2014, Massachusetts Institute of Technology researchers demonstrated that they could recover intelligible speech from high-speed video of object vibrations caused by sound waves, enabling passive audio extraction from everyday objects (such as chip bags and plants) without specialized laser equipment.¹⁴
- Screen gleaning is a process in which attackers can read mobile device screens without a visual line of sight by intercepting the EM signal that the device sends to the screen.¹⁵

Internal Surveillance

Internal surveillance requires that an adversary has achieved some form of access to a building's interior (or to interior-adjacent infrastructure) long enough to place or activate a collection device and not necessarily to maintain an ongoing physical presence. Internal surveillance frequently serves as a *multiplier* for HUMINT, close-access operations, or supply chain compromise: Once a collection device is in place, it can operate continuously and capture “the thing that matters” whenever it occurs.

Internal surveillance might include hidden audio or video capture devices in conference rooms, secure work areas, or executive spaces and collections focused on where insights are discussed, not just where they are stored (e.g., research reviews, debugging sessions, incident rooms, architecture discussions).

This vector is specific to algorithmic insight security and was not in SMW.

Examples

- “The Thing” (also known as the “Great Seal Bug”) was a wooden Great Seal of the United States plaque that the Soviet Union gifted to the U.S. embassy in Moscow in 1945. The gift concealed a passive listening device that could be externally energized by RF, enabling years-long room audio collection before U.S. intelligence discovered the device in 1952.¹⁶
- In 2004, Australian Secret Intelligence Service agents posed as aid workers renovating government offices in Dili, East Timor, and planted listening devices in the government's cabinet room during oil treaty negotiations, gaining an unfair advantage in securing maritime boundary agreements worth billions of dollars in resource revenues.¹⁷

Surveillance via Access to Other Devices

This vector covers any surveillance that is enabled once an adversary gains access to a device that is colocated with (or logically adjacent to) insight work (the device could belong to a target organization, an employee, a vendor, or the building environment). The attacker does not need to steal files directly; they can instead use sensors and audio or visual pathways (e.g., cameras, microphones, screen capture devices, conferencing streams, “smart” building controls) to observe sensitive work as it happens.

In practice, *other devices* can commonly include the following:

¹⁴ Abe Davis, Michael Rubinstein, Neal Wadhwa, Gautham Mysore, Frédo Durand, and William T. Freeman, “The Visual Microphone: Passive Recovery of Sound from Video,” *ACM Transactions on Graphics*, Vol. 33, No. 4, July 2014.

¹⁵ Zhuoran Liu, Niels Samwel, Léo Weissbart, Zhengyu Zhao, Dirk Lauret, Lejla Batina, and Martha Larson, “Screen Gleaning: A Screen Reading TEMPEST Attack on Mobile Devices Exploiting an Electromagnetic Side Channel,” paper presented at the Network and Distributed Systems Security (NDSS) Symposium, virtual, February 21–25, 2021.

¹⁶ Paul Reuvers and Marc Simons, “The Great Seal Bug,” Crypto Museum, September 18, 2015.

¹⁷ Steve Cannane, Sashka Koloff, and Brigid Andersen, “‘Matter of Death and Life’: Espionage in East Timor and Australia’s Diplomatic Bungle,” ABC News, November 25, 2015.

- employee endpoints (e.g., laptops and phones with cameras or microphones, headsets, wearables)
- meeting room and audio-visual infrastructure (e.g., conferencing systems, smart displays, microphones, speakerphones)
- building systems or shared peripherals (security cameras, badge or access kiosks, room-control touch panels, printers, smart televisions)
- monitors and display chains in which compromise of the *display* (not the host computer) can enable screen snooping.

Examples

- In 2018, security researchers disclosed vulnerabilities in widely deployed Crestron control systems and touch panels (which, at the time, were common in hotels and conference rooms). A risk was that the devices could be repurposed for covert monitoring.¹⁸
- In March 2021, technology company Verkada reported that attackers accessed camera video and images for a subset of customers. Reporting and enforcement actions describe broader exposure claims (including references to very large numbers of camera feeds that adversarial actors accessed).¹⁹

Digital Access to Air-Gapped Networks

Penetrating and exfiltrating information from a system that is not ethernet-connected but has communications capabilities (e.g., universal serial bus [USB] sticks) is more challenging than for an internet-connected system, but there is significant precedent for such attacks.

SMW provides comprehensive coverage of this vector, including a report by technology company ESET that identified 17 malware frameworks that used USB devices to access air-gapped networks over the course of 15 years. Various covert channels (ultrasound, SATA [Serial Advanced Technology Attachment] cables, memory bus Wi-Fi signals) have been shown to exfiltrate data from air-gapped systems.

Attack of Network Components

This vector encompasses advanced attacks conducted at a relative distance using an EM signal or electronic warfare capabilities to exploit vulnerabilities in such network devices as gateways, routers, switches, mobile devices, and other key RF-enabled systems. Experts noted that the use of this vector combined with other attack vectors to conduct specialized attacks targeting sensitive information is particularly concerning.

Examples

- In 2024, researchers at Nozomi Networks discovered OTA vulnerabilities in Advantech hardware, specifically its EKI Access Points, which could have enabled attackers to exploit the wireless spectrum to execute code on the devices simply by being in physical proximity to it.²⁰
- In 2017, researchers discovered a zero-click remote-code execution vulnerability in Broadcom's BCM43xx Wi-Fi chipsets. The vulnerability affected billions of Android and iOS devices and was exploitable during the OTA wireless association process without authentication.²¹

¹⁸ Louise Matsakis, "Hackable Touchscreens Could Spy on Hotel Rooms and Meetings," *Wired*, August 10, 2018.

¹⁹ Kyle Randolph and Martin Hunt, *Summary: March 9, 2021 Security Incident Report*, Verkada, May 21, 2021.

²⁰ Nozomi Networks Labs, "Over-the-Air Vulnerabilities Discovered in Advantech EKI Access Points," *OT & IoT Security Blog*, November 27, 2024.

²¹ Nitay Artenstein, "Broadpwn: Remotely Compromising Android and iOS via a Bug in Broadcom's Wi-Fi Chipsets," *Exodus Blog*, July 26, 2017.

Attack of Other Devices

Attackers can use a compromised wireless-enabled device as a beachhead to compromise *other* nearby or same-network devices via OTA pathways. This differs from the “Attack of Network Components” vector in that the attacker is not primarily exploiting routers, switches, or gateways but instead leverages device-to-device and local-network discovery protocols to move laterally between endpoints.

Examples

- In late 2025, a vulnerability in a Google protocol on top of Bluetooth allowed the unauthorized pairing and access to audio devices and other Bluetooth-enabled devices, enabling eavesdropping and other types of attacks.²²
- In 2017, researchers disclosed eight zero-click Bluetooth vulnerabilities affecting 5.3 billion devices across Android, iOS, Linux, and Windows platforms, enabling airborne remote-code execution and device takeover without pairing, authentication, or a device being in discoverable mode, and the code could spread through proximity alone.²³

Side-Channel Attacks (Including TEMPEST Attacks)

Electronic information can often be detected or inferred using various leaking emanations, including EM emissions, optical emissions, acoustic sounds, radio signals, and caches.

As detailed extensively in SMW, such attacks have been known since World War II, and costs to conduct such attacks have fallen substantially. Although exfiltrating full model weights via a side-channel attack would be impractical because of weights’ sizes, insights are sufficiently compact that side-channel extraction becomes more feasible, particularly for keys or credentials that protect insight-containing systems.

Eavesdropping and Wiretaps

As detailed in SMW, an attacker can take actions to collect sensitive information in a continuous manner, including sending individuals to physically listen to conversations (with or without the assistance of specialized devices); planting microphones, cameras, or other automated devices; and tapping wires (e.g., phone lines, ethernet cables, the internet backbone) to covertly access communicated data.

Unauthorized Physical Access to Systems

This category includes attacks that require physical proximity to or physical interaction with target systems. In most cases, physical access to a system can lead to meaningful access to sensitive information on the system. Even if the underlying data are encrypted or protected against physical attacks, capable attackers can install devices or software—such as hardware keyloggers, malicious USB devices, or persistent software implants—that would provide the attackers with access later.

For algorithmic insights, physical access vectors are particularly concerning because insights are not confined to centralized servers or data centers. Researchers might discuss insights in conference rooms and at off-site meetings, display them on screens visible to passersby, and store them on portable devices. Insights’ distributed, human-accessible nature means that physical access to any location where research

²² Pieter Arntz, “WhisperPair Exposes Bluetooth Earbuds and Headphones to Tracking and Eavesdropping,” *Malwarebytes* blog, January 16, 2026.

²³ ARMIS, “BlueBorne Cyber Threat Impacts Amazon Echo and Google Home,” November 14, 2017.

work occurs can yield valuable information. This category includes both the traditional physical access vectors from SMW (direct access, device implants, access-control evasion, hardware penetration, and armed or military intrusion) and several vectors reflecting the insight-specific risks of close-access operations in research environments.

Physical Access to Devices in Other Locations

If premises are well secured, attackers could try to access an organization's devices in other locations by breaking into an employee's home, stealing or accessing a laptop in a public space, or using false pretenses to access devices left in hotel rooms.

As detailed in SMW, this vector includes both opportunistic theft and sophisticated operations. Countries often access people's devices at airports under the guise of a security inspection, and capable actors have infrastructure to access devices left in hotel rooms.

For algorithmic insights, this vector has heightened relevance:

- Researchers frequently travel to conferences, collaborator sites, and customer meetings.
- Home offices might lack physical security measures that are present in corporate facilities.
- Laptops containing research code and documentation travel with researchers.

Malicious Placement of Portable Device Implants

A common strategy is to leave devices (e.g., USB flash drives, hard drives, computer peripherals) around the target facility or in locations that employees frequent. These devices could be marked with a company's logo to give them credibility, or they could be left unmarked.

As documented in SMW, while awareness of these risks is slowly increasing, so are attackers' capabilities. USB cables with hidden chips that provide advanced access are available for as little as \$180.

Direct Physical Access

If no exceptional security practices are in place, an attacker can often directly access physical servers or devices. This might involve social engineering, breaking in, impersonating those with legitimate access, or achieving authorized access by acting as maintenance or service workers.

SMW documents examples of this vector: The Stuxnet operation allegedly involved a mechanic plugging a USB device into control systems, and attackers posed as janitors to install keyloggers at Sumitomo Mitsui Bank.

Removal of Devices and Storage

Employees might remove devices and storage from sensitive areas either inadvertently or to share information, or adversaries with access might remove devices from an organization's premises and control. This can be done in tandem with other vectors, such as the "Bribes and Extortion," "Risks from Former Employees," "Front Operations and Ruses," or "Direct Physical Access" vectors.

For algorithmic insights, this vector has heightened relevance because insights can be found on laptops, USB drives, and other portable devices.

Example

- In 2024, a U.S. Navy civilian contractor was indicted for removing and reselling computer equipment, including hard drives and computers associated with sensitive systems.²⁴

Evasion of Physical Access Control Systems

Many physical security systems rely critically on digital systems (e.g., cameras, alert systems, digital locks). These can be compromised or disabled through various means.

As documented in SMW, researchers have demonstrated vulnerabilities in hotel locks, keycards, and security-camera systems. As mentioned previously, a group gained access to hundreds of thousands of Verkada security cameras, giving them access to live feeds, video archives, and, in some cases, internal network access.

Armed Break-In

This vector is a variation on the “Direct Physical Access” vector but requires more-capable agents who are better trained in gaining access and have broader toolsets, including using violence if necessary.

SMW notes that this vector is significantly more costly and higher risk than simple direct physical access attacks.

Military Takeover

At the extreme end of physical attacks, an attacker might use military force to take over a facility.

As documented in SMW, during the 2021 coup in Myanmar, the military directed armed soldiers to break into data centers nationwide.

Penetration of Hardware Security

In high-security contexts, some devices will have physical hardware protections (e.g., hardware security modules, smartcards). An attacker would need to overcome physical hurdles to access information. Capable actors have a large toolset, including drilling, EM probing, acid dissolving, clock glitching, freezing, and timing or power attacks.

SMW provides detailed examples, including cold boot attacks, integrated circuit decapsulating, and laser fault injection.

Shoulder Surfing

Shoulder surfing is the direct, in-person observation of sensitive information visible on a screen or in a workspace. It is often opportunistic, low cost, and difficult to detect—especially in open offices, shared workspaces, and conferences.

This vector is specific to algorithmic insight security and was not in SMW.

²⁴ U.S. Attorney’s Office, Southern District of California, “Shipyard Contractor Sentenced to Prison for Stealing Almost \$600,000 Worth of Computer Equipment from the U.S. Navy,” press release, U.S. Department of Justice, July 10, 2024.

Example

In experiments across 46 companies in eight countries conducted in 2016, white-hat hackers successfully captured sensitive information through visual observation in 91 percent of attempts, with 49 percent of attempts completed in less than 15 minutes.²⁵

Supply Chain Attacks

Supply chain attacks involve intentionally undermining the security of supply chains, either surreptitiously or through other types of influence. Even an organization with perfect internal security might be vulnerable because of the infrastructure and equipment it relies on.

Services and Equipment the Organization Uses

This vector involves, among other equipment and services, computers, GPUs and ML-specific hardware, operating systems, code repositories, continuous integration and continuous deployment (CI/CD) infrastructure, monitoring systems, chat software, workspace software, and generally installed applications.

SMW provides extensive examples of this vector, including Operation Rubicon (the Central Intelligence Agency's and Germany's intelligence agency's covertly owned technology company Crypto AG), the Solar-Winds hack, and the Target breach through a heating, ventilation, and air conditioning vendor. The lessons from these examples apply equally to insight security.

As in some examples, an advanced adversary could insert surveillance mechanisms or backdoors into hardware and equipment while the equipment is shipped or stowed for shipment. Interdiction can occur with specific instances of a product destined for specific customers or across product lines.²⁶ Interdicted components can be modified in transit, on leaving the manufacturer or distributor, in the final assembly stages, or when being transferred between production lines.²⁷

This can be done for staging further access attacks or as a precision attack targeting a specific goal. Hardware component manufacturers, deliverers, and integrators might be unaware of the illicit access and any tampering.

Examples

- In 2015, participants of a scientific conference in Houston received CD-ROMs in the mail with the conference proceedings but also malware from a threat actor, the Equation Group.²⁸
- Also in 2015, reporting alleged that the Tailored Access Operations unit of the National Security Agency conducted a “supply chain interdiction” operation that involved intercepting network devices in transit, implanting them with malware, and then returning them to be shipped. The case involved devices destined for the Syrian Telecommunications Establishment internet backbone that were interdicted, yielding access that extended into the Syrian digital cellular network.²⁹

²⁵ Ponemon Institute, *Global Visual Hacking Experimental Study: Analysis*, August 2016.

²⁶ David Levene, “Causes of Vulnerabilities and Key Threats to Defense Supply Chains,” *Wild Blue Yonder*, June 6, 2025.

²⁷ Cristin Goodwin and Joram Borenstein, “Guarding Against Supply Chain Attacks—Part 2: Hardware Risks,” *Microsoft Security Blog*, February 3, 2020.

²⁸ Kim Zetter, “Suite of Sophisticated Nation-State Attack Tools Found with Connection to Stuxnet,” *Wired*, February 16, 2015.

²⁹ Bruce Schneier, “Cisco Shipping Equipment to Fake Addresses to Foil NSA Interception,” *Schneier on Security* blog, March 20, 2015.

Vendors with Access to Information

A separate attack vector, but one related to the equipment and services vector, is vendors who have access to sensitive data or systems. If vendors are compromised, an organization's data can be compromised.

As documented in SMW, the Stuxnet attack involved the attacker setting up multiple front companies and attacking five vendors as prerequisites. Similarly, a breach of the U.S. Office of Personnel Management resulted from access to credentials that were stolen from a subcontractor.

For algorithmic insights, relevant vendors include the following:

- cloud service providers with access to research code and data
- collaboration tool vendors (e.g., Slack, GitHub, Notion) that process insight-containing content
- security tools with codebase access
- contractors and consultants with access to technical systems.

Front Operations and Ruses

Intelligence adversaries, particularly well-resourced entities at the OC4 or OC5 level of operational capability, might run complex operations involving the creation of “front” supplier or contractor entities for the purposes of gaining access and information over time. This could also occur in more-limited, one-off cases, such as conference solicitations for events run as an information-gathering exercise.

For algorithmic insights, relevant scenarios include the following:

- fake research collaborations or joint ventures designed to extract technical knowledge
- fictitious academic institutions or researchers seeking collaboration
- front companies offering consulting services, supplies, investments, or acquisition discussions.

Code and Infrastructure Incorporated into the Codebase

Adversaries might compromise development and build infrastructure to gain access to source code, introduce backdoors, or extract insights from the AI-development process itself.

SMW covers this under the same category label. For algorithmic insights, CI/CD pipelines, artifact repositories, and development sandboxes are particularly sensitive targets because they contain research code and might have broad access to organizational systems.

Adversaries might also directly compromise upstream software package dependencies to gain access to sensitive systems. Such compromise might be targeted or nontargeted and opportunistic.

Examples

- In 2024, a coordinated effort compromised the open-source XZ Utils compression library package.³⁰
- Hackers replaced the PyTorch-nightly torchtriton dependency with a malicious package, leading to the extraction of sensitive data from infected systems.³¹

³⁰ Akamai Security Intelligence Group, “XZ Utils Backdoor—Everything You Need to Know, and What You Can Do,” *Akamai Blog*, April 1, 2024.

³¹ PyTorch Foundation, “Compromised PyTorch-Nightly Dependency Chain Between December 25th and December 30th, 2022,” *PyTorch* blog, December 31, 2022.

Detailed Benchmark Systems for Insight Security Levels

In this appendix, we propose benchmark security systems for protecting algorithmic insights against increasingly capable adversaries. This appendix is structurally parallel to Appendix B (“Detailed Benchmark Systems for Security Levels”) in SMW.

Consistent with SMW, these benchmarks

- **do not constitute a standard** and should not be used as a compliance checklist; instead, they serve as a **rough tool for calibrating** a security posture against different classes of adversaries
- represent a **conceptual “center of mass” of expert judgment** and literature rather than a precise optimization over all possible trade-offs
- emphasize **defense-in-depth**; many measures overlap or partially substitute for each other, but the overall posture becomes substantially stronger when multiple independent controls are in place.

We note the relevant reference when existing government standards or authoritative guidance directly addresses a measure. These references serve two purposes: helping implementers locate detailed technical specifications and grounding our recommendations in established security frameworks. We include external references only when the cited document directly addresses the measure in question. We do not include references that are merely conceptually aligned or that address adjacent topics.

Finally, as previously discussed, this appendix focuses on measures that are *distinctive to algorithmic insights* or measures that need to be interpreted differently when insights (rather than only weights) are the primary security object. SMW already covers a wide variety of general information technology, personnel, and physical security controls with each WSL; those are assumed and not repeated here except when a modification is important for insight security specifically.

Frequently Referenced Standards

We reference the following documents repeatedly throughout this appendix:

- **National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53—*Security and Privacy Controls for Information Systems and Organizations*.**¹ This document is a comprehensive federal catalog of security controls organized into families (e.g., “AC” for Access Control, “SC” for System and Communications Protection, “PE” for Physical and Environmental Protection). When we cite specific control families, we refer to the families listed in this document.

¹ Joint Task Force, 2020.

- **NIST SP 800-88**—*Guidelines for Media Sanitization*.² This document provides authoritative guidance on secure data deletion, including cryptographic erasure, overwriting, and physical destruction methods.
- **NIST SP 800-161**—*Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*.³ This document provides a framework for identifying, assessing, and mitigating supply chain risks.
- **NIST SP 800-218**—*Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*.⁴ This document provides practices for secure software development, including dependency management and build integrity.
- **NIST SP 800-162**—*Guide to Attribute Based Access Control (ABAC) Definition and Considerations*.⁵ This document provides a definition of and implementation guidance for attribute-based access decisions.
- **NIST SP 800-124**—*Guidelines for Managing the Security of Mobile Devices in the Enterprise*.⁶ This document lists controls for MDM, including MDM deployment.
- **NIST SP 800-46**—*Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security*.⁷ This document provides guidance on securing remote work and personal device usage.
- **NIST SP 800-50**—*Building a Cybersecurity and Privacy Learning Program*.⁸ This document provides guidance for developing and managing organizationwide security awareness and learning programs.

Insight Security Level 1

ISL1 corresponds to defending against **OCI amateur attackers**: individuals with limited resources and skill who nonetheless might opportunistically target exposed systems. For algorithmic insights, ISL1 adds a thin layer of basic hygiene on top of WSL1.

² Ramaswamy Chandramouli and Eric A. Hibbard, *Guidelines for Media Sanitization*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-88r2, September 2025.

³ Jon Boyens, Angela Smith, Nadya Bartol, Kris Winkler, Alex Holbrook, and Matthew Fallon, *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-161r1-upd1, May 2022.

⁴ Murugiah Souppaya, Karen Scarfone, and Donna Dodson, *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-218, February 2022.

⁵ Vincent C. Hu, David Ferraiolo, Richard Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone, *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-162, January 2014.

⁶ Gema Howell, Joshua M. Franklin, Vincent Sritapan, Murugiah Souppaya, and Karen Scarfone, *Guidelines for Managing the Security of Mobile Devices in the Enterprise*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-124r2, May 2023.

⁷ Murugiah Souppaya and Karen Scarfone, *Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-46, Revision 2, July 2016.

⁸ Marian Merritt, Susan Hansche, Brenda Ellis, Kevin Sanchez-Cherry, Julie Nethery Snyder, and Donald Walden, *Building a Cybersecurity and Privacy Learning Program*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-50r1, September 2024.

Access Control and Authentication

- **Private internal test AI instances:** Internal experimental models, debug sandboxes, and test interfaces are not exposed directly to the public internet. When they must be hosted on public-IP infrastructure, they are placed behind strong authentication controls and are not discoverable via search or unauthenticated scanning.

Digital Network and Endpoint Security

- **Disable macros by default:** Office and productivity suites used by staff with access to insights have macros disabled by default, and ideally this disabling is centrally enforced via enterprise policy. Exceptions (if any) require justification and a security review, reducing the risk of simple macro-borne malware.

Insider Threat Mitigation and Personnel Security

- **Insight-focused NDAs:** Staff with access to algorithmic insights sign NDAs that explicitly cover insights and closely related design and evaluation artifacts, emphasizing that these are treated as sensitive, protected information. NDAs are framed as a complement to, not a replacement for, technical controls.

Threat Detection, Monitoring, and Incident Response

- **EDR on key endpoints:** All laptops, desktops, servers, and other endpoints that either *store* insights or *administer* systems storing insights run centrally managed EDR with behavioral detection and centralized blocking and response controls.⁹
- **IDS:** Network and host-based IDS monitor the networks and hosts that store, process, or carry algorithmic insights or related administrative traffic. IDS sensors provide both signature-based and anomaly-based detections (e.g., command and control, lateral movement, unusual data transfer from insight repositories) and feed alerts into centralized monitoring for triage and incident response.¹⁰

Insight Security Level 2

Implementation of Previous Security Levels

- All ISL1 controls have been implemented.

Access Control and Authentication

- **Full-disk and volume encryption on insight-storing devices:** Any laptop, workstation, server, or removable drive that stores or caches nonpublic algorithmic insights (including local clones of insight

⁹ See Murugiah Souppaya and Karen Scarfone, *Guide to Malware Incident Prevention and Handling for Desktops and Laptops*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-83, Revision 1, July 2013.

¹⁰ See Karen Scarfone and Peter Mell, *Guide to Intrusion Detection and Prevention Systems (IDPS): Recommendations of the National Institute of Standards and Technology*, National Institute of Standards and Technology, U.S. Department of Commerce, Special Publication 800-94, February 2007.

repositories, exports, or logs) must use full-disk or filesystem-level encryption with modern, industry-standard algorithms.¹¹

- **Prohibit sending sensitive insights over insecure channels:** Policies should prohibit the sharing of sensitive insight content over insecure or uncontrolled channels (e.g., text, personal email, unmanaged messaging apps) and be accompanied by training and technical controls when possible.
- **RBAC:** Insight repositories and systems use RBAC so that data owners and administrators can down-scope access to the minimum necessary roles or groups.
- **Secure authorization for cloud endpoints and APIs:** API endpoints and systems that run web-server platforms should be secured, with authorization required to access data via API endpoints, and proper algorithm matching and key handling should be enforced for functions, such as JWT (JSON web token).

Digital Network and Endpoint Security

- **Hardware and document disposal protocols:** Devices and paper documents that might contain algorithmic insights are sanitized or destroyed using approved processes to prevent data recovery (e.g., shredding, secure wipe).¹²
- **Browser extension allow-listing:** Engineers with insight access are limited to allow-listed browser extensions, and there is a review and approval process for new additions.
- **MDM:** Phones, laptops, and tablets that access insight systems are onboarded into a centrally managed MDM solution, enforcing encryption, lock screens, patch levels, and remote wipes.¹³
- **Secure communication protocols:** All communication channels that transmit algorithmic insights or credentials for systems containing insights (e.g., source control, artifact repositories, administration consoles, code review tools, chat systems) use modern, encrypted, and authenticated protocols (such as up-to-date transport layer security) with secure configurations and do not allow any fallback to legacy or unauthenticated protocols.¹⁴

AI Model Resilience

- **No API keys in client-side code:** API keys granting access to insight systems or high-privilege AI APIs are never embedded in client-side code or public artifacts; instead, they are stored server-side or in secure vaults.
- **Controlled use of algorithmic insights as training data:** High-sensitivity algorithmic insights should not be used indiscriminately as training or fine-tuning data for models whose outputs are externally exposed. Any use of insight-containing documentation, design notes, or evaluation data for model training must be explicitly reviewed for risk, restricted to models deployed within the same security boundary, and scoped so that outputs do not meaningfully increase the risk of insight exfiltration beyond that boundary.

¹¹ See Karen Scarfone, Murugiah Souppaya, and Matt Sexton, *Guide to Storage Encryption Technologies for End User Devices: Recommendations of the National Institute of Standards and Technology*, National Institute of Standards and Technology, U.S. Department of Commerce, Special Publication 800-111, November 2007.

¹² See Chandramouli and Hibbard, 2025.

¹³ See Howell et al., 2023.

¹⁴ See Kerry A. McKay and David A. Cooper, *Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-52, Revision 2, August 2019; and Elaine Barker, Quynh Dang, Sheila Frankel, Karen Scarfone, and Paul Wouters, *Guide to IPsec VPNs*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-77, Revision 1, June 2020.

- **Restrict information in AI deployment interfaces and APIs:** Public-facing inference endpoints and dashboards for deployed models are designed so that they do not expose the detailed provenance or internal structure of sensitive insights via outputs, metadata, or error messages.

Insight Compartmentalization

- **Need-to-know sharing of sensitive research within relevant teams:** Sensitive algorithmic insights are shared only with the teams and individuals who need them for their work rather than being broadly accessible across an organization. This informal compartmentalization does not require formal designation systems or documented compartment structures, but it does require that managers and team leads actively limit the distribution of sensitive research results, design documents, and technical discussions to those with a clear operational need. Establish a culture in which the default is restricted sharing, and explicit justification is required for broader access.

Threat Detection, Monitoring, and Incident Response

- **Protective DNS:** Configure a protective, filtering DNS service for use with all devices that connect to the internet and have access to or store algorithmic insights. These DNS services block certain known attack sites and command-and-control domains at the DNS level.¹⁵

Insider Threat Mitigation and Personnel Security

- **Structured offboarding and exit procedures for departing employees:** Departing staff and contractors follow a formal offboarding process that includes the timely revocation of all logical and physical access to insight systems, the recovery of corporate devices and storage media, a confirmation of data return or deletion from personal accounts, and explicit reminders of continuing obligations under NDAs and other agreements.¹⁶
- **Security awareness and OPSEC training:** Researchers who have access to insights should be engaged in required training on security (both digital security and OPSEC) to be generally aware that adversaries might be trying to steal insights and trade secrets.¹⁷
- **Whistleblower reporting and protection:** Policies and mechanisms exist for staff to report security concerns (including insider abuses) without fear of reprisal.

Insight Security Level 3

Implementation of Previous Security Levels

- All ISL1 and ISL2 controls have been implemented.

¹⁵ Cybersecurity and Infrastructure Security Agency, “Joint NSA and CISA Guidance on Strengthening Cyber Defense Through Protective DNS,” U.S. Department of Homeland Security, March 4, 2021.

¹⁶ See section PS-4, “Personnel Termination,” and section PS-5, “Personnel Transfer,” in Joint Task Force (2020).

¹⁷ See Merritt et al., 2024.

Access Control and Authentication

- **ABAC:** Access to systems that store or process algorithmic insights is enforced using ABAC, in which decisions are based on user, resource, and context attributes (e.g., role, project, compartment, location, device posture). Policies ensure that only users with the required combination of attributes can access a given insight or compartment.¹⁸
- **Just-in-time privileged access:** Administrative access to insight-bearing infrastructure uses mechanisms ensuring short-lived, scoped credentials or role assignments tied to specific justifications (e.g., tickets or change requests). After a defined period, privileges are automatically removed across all relevant systems, and all use is recorded for review. This can be implemented through dedicated just-in-time privileged access-management systems or through equivalent technical controls achieving the same outcomes.¹⁹
- **Centrally managed device encryption and compliance attestation:** All laptops, workstations, and servers that can access or store nonpublic algorithmic insights must have encryption centrally enforced and managed (e.g., via MDM or endpoint management), and there must be the ability to attest compliance, escrow and rotate keys, and remotely revoke or destroy keys if a device is lost, stolen, or suspected to be compromised.²⁰
- **Privilege bracketing:** Privilege bracketing is implemented to ensure that elevated privileges for insight-related systems are used only within tightly defined *brackets* (i.e., specific tasks, time windows, and systems). Routine work is done with low-privilege accounts, and switching into and out of privileged modes is explicit, auditable, and minimized.

Digital Network and Endpoint Security

- **Browser and client-side policies for AI research:** Browsers and client environments that are used to access or handle insights are isolated from general web browsing through separate browser profiles, virtualized environments, or dedicated devices. Access to external sites is controlled through centrally managed allow-lists limiting exposure to trusted, necessary domains. Browser hardening that is appropriate to an organization's threat models has been implemented; browser hardening could include the following: disabling unnecessary extensions and plugins, enforcing content security policies, using isolated browser containers, deploying browser-specific security monitoring, or restricting JavaScript execution on untrusted external sites while allowing it for approved development tools and platforms.²¹
- **Clipboard and screen-capture controls:** Endpoints and remote-access environments that are used to work with algorithmic insights are enforced by policies that limit or block screen capturing, printing, and clipboard exporting to unmanaged applications or devices; any approved exceptions are explicitly authorized and monitored.
- **Device and port hardening:** Endpoints that access insight systems are hardened by disabling unnecessary services and physical ports (e.g., unused USB, FireWire, external storage), removing default

¹⁸ Hu et al., 2014.

¹⁹ For principles related to reduced-standing privilege and context-aware access decisions, see Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly, *Zero Trust Architecture*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-207, August 2020.

²⁰ See Rose et al., 2020.

²¹ Cybersecurity and Infrastructure Security Agency, *Capacity Enhancement Guide: Securing Web Browsers and Defending Against Malvertising for Federal Agencies*, U.S. Department of Homeland Security, undated-a.

accounts, and enforcing secure configurations, thereby reducing the number of exploitable entry points for attackers.²²

- **Lock down mobile email clients:** Ensure the security of mobile devices' access to email clients, particularly on iOS devices or platforms. This can include disallowing mobile email access entirely or using an approved third-party vendor email client with an enterprise policy in place of using the native email app, particularly on iOS. Ensure that corporate email accounts that contain or reference algorithmic insights information are not logged in to a system's email application (or applications) when not in use.
- **Network segmentation (north-south, east-west):** Networks that host resources related to insights are virtually segmented into controlled zones, and there are limits on lateral movement and clear choke points for monitoring.²³
- **No BYOD for AI research:** There is a strict no-BYOD policy for any activity involving algorithmic insights. Only corporate-managed endpoints may connect to insight compartments, development environments, or administrative interfaces, and personally owned devices are barred from these networks and services even when VPN or remote desktop access is technically possible.²⁴
- **No external removable media:** The use of USB drives or similar removable media for systems that touch insights is prohibited except under tightly controlled and monitored exceptions.
- **Periodic deep inspection of high-sensitivity devices:** Devices involved in insight development or administration are periodically selected for in-depth inspections, including firmware or configuration auditing and, when appropriate, physical disassembly or delayering to check for unauthorized hardware (e.g., covert radios, storage, or keyloggers). Inspections are documented, and nonconforming devices are removed from service until they are remediated.

Data Protection and Handling

- **Formal sensitivity classification:** Insights and related documentation are assigned sensitivity labels under a formal classification policy (e.g., "internal," "restricted," "highly restricted") with criteria that reflect any competitive impacts and security risks if the documentation or insights are disclosed. These labels guide decisions about compartment placement, access approvals, and which additional protections (e.g., special storage locations, logging requirements) must apply.
- **Clean-desk policy for sensitive research areas:** Workspaces where algorithmic insights are handled follow a clean desk policy: printed materials, notebooks, whiteboard photos, and removable media containing insight-related information are secured (e.g., locked storage) when not in use and may not be left unattended on desks, in shared spaces, or on conference room whiteboards.
- **Document-handling policies:** Document policies for insight artifacts (e.g., watermarking, secure repositories, minimal hard copies) are adopted, and append-only change logs for critical data may be used.²⁵
- **Filesystem-level tagging and I/O restrictions:** Insight-bearing data are stored only in filesystems that support security tagging, and sensitive files are marked with labels that encode compartment, sensitivity, and handling rules. OS and security controls use these labels to enforce I/O restrictions—for

²² See, for example, section CM-6, "Configuration Settings," and section CM-7, "Least Functionality," in Joint Task Force, 2020.

²³ See, for example, section SC-7, "Boundary Protection," and section SC-32, "System Partitioning," in Joint Task Force, 2020.

²⁴ See Souppaya and Scarfone (2016) and Howell et al. (2023) for managed-device alternatives.

²⁵ National Security Agency, Cybersecurity and Infrastructure Agency, Federal Bureau of Investigation, Australian Signals Directorate's Australian Cyber Security Centre, New Zealand's National Cyber Security Centre, and United Kingdom's National Cyber Security Centre, "AI Data Security: Best Practices for Securing Data Used to Train & Operate AI Systems," fact sheet, U/OO/157249-25, PP-25-2301, May 2025.

example, blocking writes to unauthorized directories, disallowing sync to unmanaged cloud storage, or limiting which processes can read or modify tagged files.

- **Secure data deletion:** Decommissioned storage and devices that previously held insights are sanitized (according to processes laid out in *Guidelines for Media Sanitization*) or secured in an equivalent manner (cryptographic erasure, multipass overwriting, or destruction).²⁶
- **Just-in-time coalescing of insight data into workloads:** Build and deployment systems assemble sensitive insight components only at runtime for specific jobs, then the systems remove or restrict access to the assembled artifacts after use. This approach reduces the number of persistent, widely accessible copies of insights and limits the window during which complete insight sets exist in accessible form.
- **Volatile memory protections for insight-bearing systems:** Systems that process algorithmic insights implement protections against volatile memory exposure, such as by
 - disabling hibernation on systems that access insights (i.e., preventing disk persistence of random-access memory)
 - encrypting swap and page files
 - clearing sensitive data from memory after use when technically feasible
 - implementing memory locking for critical insight-processing applications to prevent swapping
 - configuring secure memory clearing on a system shutdown and restart

Insight Compartmentalization

- **Compartment authorization lists:** Each insight compartment has a formally maintained authorization list that maps named individuals (and, as applicable, roles or groups) to their permitted access. Changes to compartment access (grants, revocations, temporary exceptions) follow a documented approval process, and authorization lists are regularly reviewed to ensure that they match actual IAM and physical-access settings.
- **Compartment awareness training:** Personnel who have access to algorithmic insights or systems within insight compartments receive training on the compartment structure, codewords or designations, handling rules (including what information may cross compartment boundaries), and how to report suspected violations. This training is provided at onboarding and refreshed periodically.²⁷
- **Documented identification of distinct compartments:** Documentation is maintained that clearly identifies each insight compartment, its purpose, the types of algorithmic insights it may contain, and the systems, repositories, and environments that belong to it. This documentation is kept up to date and used as the reference point for access control, monitoring, and change management.
- **Codeword and a formal designation system:** A formal codeword or designation system for insight compartments is maintained: Each compartment has a unique, nondescriptive identifier used in access controls, NDAs, tickets, and internal communication. Mapping between codewords and their underlying content is itself treated as sensitive and is disclosed only to authorized personnel.
- **Compartment-specific NDAs:** Personnel with access to a given insight compartment sign NDAs that reference that compartment's codeword or designation and explicitly cover rules regarding content and handling. These agreements should reinforce that information may not be shared across compartments and that unauthorized cross-compartment disclosure carries specific consequences.
- **Information-flow monitoring between compartments:** Monitoring focuses on information flows between insight compartments: Cross-compartment reads, writes, and exports are tagged in logs, aggregated centrally, and analyzed for unusual patterns or violations of handling rules. High-risk flows,

²⁶ See Chandramouli and Hibbard, 2025.

²⁷ See Merritt et al., 2024.

such as repeated copying from multiple compartments into a single destination, must trigger alerts and automated or manual reviews.

- **IAM-enforced compartment access:** Access to each insight compartment is enforced through IAM using roles or attributes that directly reflect compartment authorization lists. Systems that host compartmented data or services accept only authenticated identities with the appropriate IAM attributes, and changes to compartment membership take effect automatically across all connected systems.

Software Integrity and Supply Chain Assurance

- **Multiparty threshold cryptography:** Threshold cryptography is implemented for the most sensitive cryptographic operations and secrets. In a threshold scheme, secret keys (or other critical secret material) are split among multiple parties or components such that no single party holds the entire key. A minimum number of shares (the threshold) must be used together to perform a cryptographic operation.
- **Separate environments for cloning third-party repositories:** Developers and researchers should be aware of the risks of cloning unknown third-party source repositories, including that vulnerabilities in version-control systems might allow remote code execution at the point of cloning or unpacking. Unknown third-party code should therefore be cloned in an environment that is separate from the file-system or device that has algorithmic insight files or data.
- **Third-party dependency auditing:** Dependencies used in model training, deployment, or data handling are individually reviewed and allow-listed, and special attention is paid to potential supply chain risks.²⁸
- **Memory corruption vulnerability mitigation:** Security-critical systems (e.g., key services, authentication infrastructure) implement comprehensive approaches to mitigate memory-corruption vulnerabilities. Complementary strategies are deployed, which could include the following:
 - using memory-safe languages (e.g., Rust, Go, Swift) for new critical components when feasible
 - deploying compiler-based exploit mitigations (e.g., stack canaries, address space layout randomization, control-flow integrity)
 - implementing runtime memory protections and sandboxing
 - conducting fuzzing and memory-safety testing of critical code paths
 - collecting telemetry and crash analytics to identify potential memory-corruption issues.
- **Version pinning and dependency freezing:** Key workloads involving insights are built against pinned dependency versions (i.e., locked to specific, vetted versions of third-party software components), and updates require a review and change management to minimize the risk of unexpected behavior or supply chain attacks via silent upstream changes.²⁹

Threat Detection, Monitoring, and Incident Response

- **DLP systems:** DLP tools monitor data-transfer channels for any attempted exfiltration of insight-related data, and blocking or quarantine procedures are enacted as required.
- **Runtime application self-protection:** Runtime application self-protection techniques are employed for critical applications to detect and block exploitation attempts at runtime.³⁰

²⁸ See Boyens et al., 2022; Souppaya, Scarfone, and Dodson, 2022.

²⁹ See Souppaya, Scarfone, and Dodson (2022) for practices on managing third-party components and updates.

³⁰ Paul E. Black, Barbara Guttman, and Vadim Okun, *Guidelines on Minimum Standards for Developer Verification of Software*, National Institute of Standards and Technology, U.S. Department of Commerce, NISTIR 8397, October 2021.

Insider Threat Mitigation and Personnel Security

- **Employee spot checks for security compliance:** Periodic, randomized spot checks are conducted on personnel with access to algorithmic insights. Spot checks involve examining the personnel's workspaces and device usage and checking their handling of sensitive materials for compliance with security procedures. These physical checks complement automated monitoring by verifying compliance with security procedures that have physical components that digital systems do not fully capture. Spot-check results are tracked over time to identify recurring issues, inform targeted training, and refine security policies.
- **New-hire screening:** Relevant roles (e.g., those working on insight-heavy research, security personnel) undergo background screenings using commercial or government services to surface potential insider threats or other risks.³¹
- **UEBA:** UEBA techniques are used to build behavioral baselines for users, service accounts, and critical systems that interact with algorithmic insights. Significant deviations, such as new access paths into insight compartments, spikes in data access, or anomalous administrative actions will generate prioritized alerts for an investigation and will complement traditional rule- and signature-based monitoring.

Physical and Environmental Security

- **Prevent surveillance via windows:** Exterior sight lines into spaces where sensitive work with algorithmic insights occurs are assessed, and measures (such as removing windows or adding privacy films, blackout blinds, or internal partitions) are implemented so that screens, whiteboards, and printed materials cannot be viewed from outside or from uncontrolled adjacent spaces.

Insight Security Level 4

Implementation of Previous Security Levels

- All ISL1 through ISL3 controls have been implemented.

Access Control and Authentication

- **Biometric access control for high-risk zones:** For selected high-risk zones that handle critical algorithmic insights, biometric authentication is used as part of a multifactor physical access control system. Biometric events are logged for each individual, enabling precise attribution of who entered a space and when and supporting any investigation of potential insider or physical intrusions.³²
- **Dual-person or team-based access requirements for high-sensitivity insights:** For the most sensitive insight sets, **no single individual can access them alone**; multiperson controls apply (e.g., dual control for key operations).
- **No sharing of insights via personal and nonapproved devices:** Staff are prohibited from storing or sharing insights via any mobile communication services or apps, including end-to-end encrypted services; this is enforced via mobile policies and monitoring.

³¹ See section PS-3, "Personnel Screening," in Joint Task Force, 2020.

³² Hildegard Ferraiolo, Ketan Mehta, Nabil Ghadiali, Jason Mohler, Vincent Johnson, and Steven Brady, *Guidelines for the Use of PIV Credentials in Facility Access*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-116, Revision 1, June 2018.

Digital Network and Endpoint Security

- **Air-gapped production networks for insight workloads:** Production systems that run workloads with highly sensitive insights are physically isolated from the public internet and have strictly controlled transfer mechanisms.
- **Enhanced security on mobile devices:** Mobile devices that are used for any insight-related work operate in hardened modes (e.g., “lockdown mode” on iOS) with restricted capabilities.
- **No wireless internet in secure facilities where insight-related work takes place:** Disallow Wi-Fi in any facilities in which algorithmic insights are stored, deployed, or accessed; only approved wired networking is permitted.
- **No external devices in secure research areas:** Certain offices or zones are designated as no-external-device areas for insight work; that is, only corporate-managed devices are allowed inside, and personal or unapproved electronics (phones, laptops, wearables, USB drives) must be left outside in secure storage areas. Compliance is enforced through access-control procedures and physical screening.
- **Short hardware life cycle, with mandatory replacement intervals:** Hardware in critical insight environments has short, planned lifetimes and is cycled out before accumulated vulnerabilities and exposure to attacks create unmanageable risk.

Data Protection and Handling

- **Data access fingerprinting:** Copies of critical insight data carry unique markers per user or team, enabling attribution if leaks occur.³³
- **One-time programmable media for critical records:** For recordkeeping in which integrity and non-repudiation are paramount (such as for security logs, access records, or key configuration snapshots related to insight systems), data are written to one-time programmable media that does not support overwriting or deletion. This ensures that attempts to cover up unauthorized access or changes are substantially harder to execute without leaving evidence.
- **Self-destructing or expiring data copies:** Copies of data containing algorithmic insights (e.g., exports, working subsets, temporary analysis snapshots) are created with built-in expiration measures so they become inaccessible after predefined conditions (time limits, a project’s end, a loss of network reachability) and are securely deleted or cryptographically revoked without relying on a manual cleanup. Persistent, indefinite copies of such data are not permitted outside designated storage systems.
- **Enhanced volatile memory protection:** Building on recommendations for the “volatile memory protections for insight-bearing systems” vector,
 - disable all swap- or page-file use on systems with direct insight access
 - implement random-access memory encryption when hardware supports it
 - use full-memory-encryption systems for the highest-sensitivity environments.

Insight Compartmentalization

- **Cryptographic separation between compartments:** Each insight compartment uses its own cryptographic domain (separate keys, key policies, and, when feasible, separate key management services instances or accounts) for encrypting stored data and backups. Cryptographic configurations are designed so that gaining access to one compartment’s keys does not provide decryption access to any other compartment.

³³ For more information, see National Security Agency et al., 2025.

- **Independent security assessment per compartment:** Independent assessments are commissioned for each insight compartment, and assessors should be charged to probe whether compartment boundaries can be bypassed or eroded (e.g., via misconfigurations, shadow access paths, or cross-compartment workflows). Findings are documented, prioritized, and tracked through the remediation process, and reassessments verify that fixes are effective.
- **Kernel-level DLP with file tainting:** The operating system enforces kernel-level DLP for algorithmic insights using file and data *taint tracking*; that is, when sensitive files are created or accessed, the kernel tags derived artifacts (e.g., copies, exports, intermediate files) and monitors their use. Tainted data cannot be written to unauthorized destinations (e.g., removable media, unmanaged network shares, or unapproved processes) without an explicit, logged exemption.
- **Minimization or elimination of shared resources across compartments:** Shared databases, file-systems, and services between or among high-sensitivity compartments are aggressively reduced or eliminated entirely to avoid correlated compromises.

Software Integrity and Supply Chain Assurance

- **Continuous SBOM management:** Insight-related systems maintain up-to-date SBOMs and track known vulnerabilities in components.³⁴
- **Deterministic and reproducible builds for key software:** Critical software (e.g., an insight database) is built so that independent parties can reproduce identical binaries from the source, enhancing supply chain confidence.
- **Disallowance of nonlocal AI code assistants:** Developers working with sensitive insights do not use external cloud AI-coding assistants that require communication with third-party vendors.
- **Post-quantum encryption standards:** Cryptographic protection of insights use post-quantum resistant algorithms as appropriate.³⁵
- **Formal verification of cryptographic implementations:** Cryptographic components that are central to protecting insights are formally verified whenever it is feasible to do so, reducing implementation bugs.
- **Independent verification of hardware supply chain:** Independent verification by hardware vendors or a reputable third-party verifier is required to ensure that the hardware supply chain for any custom or general hardware is free from supply chain interdiction compromises.³⁶

Threat Detection, Monitoring, and Incident Response

- **Deliberate misinformation (“canary traps”):** Unique, traceable “canary” variants of sensitive algorithmic insights (e.g., slightly altered training recipes, parameter settings, or internal documentation) are embedded and monitored for their appearance outside authorized channels. Discovery of a canary version helps identify which user, group, or compartment leaked or mishandled information.

³⁴ See Cybersecurity and Infrastructure Security Agency, “Software Bill of Materials (SBOM),” webpage, U.S. Department of Homeland Security, undated-b.

³⁵ Information Technology Laboratory, *Module-Lattice-Based Key-Encapsulation Mechanism Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 203, August 13, 2024b; Information Technology Laboratory, *Module-Lattice-Based Digital Signature Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 204, August 13, 2024a; Information Technology Laboratory, *Stateless Hash-Based Digital Signature Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 205, August 13, 2024c.

³⁶ Boyens et al., 2022.

- **RF side-channel monitoring:** Facilities housing sensitive insights deploy RF monitoring sensors to detect unusual emissions or covert radios.
- **Shadow IoT detection:** Networks that host or transmit algorithmic insights are continuously scanned for unauthorized or unmanaged IoT devices (e.g., rogue cameras, Wi-Fi access points, smart speakers). Detected devices are flagged for investigation, and policies require that the devices are either formally registered under central management or removed from the network.

Insider Threat Mitigation and Personnel Security

- **Insider-risk surveillance:** An insider-risk surveillance program for staff who handle critical algorithmic insights is maintained, correlating such data as building-entry logs, instances of travel to high-risk locations, unusual meeting activity, and communication content and metadata. Significant deviations from normal patterns are flagged for further review by a designated security team.
- **Strict international travel policies:** Staff with insight access are subject to travel restrictions and pre-approval, especially for travel to high-risk destinations.
- **Relationship-reporting requirements:** Staff with access to top sensitivity insights are required to disclose all relationships that could present conflicts or coercion risks to insider-risk teams.
- **Mandatory vacations and duty rotations:** High-privilege roles rotate periodically and have mandatory time off so that others temporarily assume their responsibilities, increasing the chance that misuse or policy violations are detected.
- **Media and publication review and social media policies:** External communications (e.g., papers, blog posts, online social media profiles) undergo reviews when they might touch on sensitive insight areas, and staff receive guidance on safe sharing practices.
- **Remote work from only approved fixed locations:** Remote access to systems containing algorithmic insights is permitted only from a small set of approved, static office locations that satisfy defined physical, connectivity, and monitoring controls. Employees are prohibited from accessing insight compartments from transient locations (e.g., travel, coworking hot desks) even if VPN access is technically possible.
- **Exit screening from secure workspaces:** When leaving secure workspaces that have been designated for algorithmic insights, employees and visitors are subject to exit screenings that are designed to detect any unauthorized removal of information (e.g., hardware, drives, printouts, photographs). Screening can include the physical inspection of bags and clothing, the use of walk-through detectors, or the use of other approved screening methods that are calibrated to the area's sensitivity level.

Physical and Environmental Security

- **Noise for side-channel mitigation:** Facilities housing sensitive insights use noise-generation systems or apply other techniques to reduce the effectiveness of acoustic or EM side-channel attacks.
- **Window noise and masking:** External windows at facilities housing sensitive insights incorporate acoustic or EM masking to hinder acoustic and other surveillance techniques.
- **Noise-proof or acoustically isolated rooms:** Discussions of extremely sensitive insights occur only in dedicated noise-proofed, isolated rooms, mitigating acoustic surveillance.
- **PIDS:** Facilities housing sensitive insights deploy PIDS to detect attempts at any physical intrusions.
- **RF or Faraday shielding:** Faraday-shielded spaces or racks around certain high-sensitivity systems—such as key servers, training clusters, or secure meeting rooms—are used to limit RF emissions and block unauthorized wireless communication. Shielding complements other physical and network controls to reduce opportunities for RF-based surveillance or exfiltration.

- **Server rack tamper protection:** Racks include tamper-detection sensors (e.g., accelerometers, door-opening detection devices) tied into centralized security monitoring systems.
- **Visual privacy screens and filters:** Visual privacy filters are used on displays in areas where unauthorized individuals might see screens (such as near walkways, in mixed-occupancy offices, or in rooms that visitors occasionally use) so that only users who are directly in front of a screen can clearly view content related to algorithmic insights. The use of such filters is treated as a standard requirement when placing workstations in higher-traffic zones.

Insight Security Level 5

Implementation of Previous Security Levels

- All ISL1 through ISL4 controls have been implemented.

Access Control and Authentication

- **No sharing of insights beyond approved digital and physical areas:** Insight content may be discussed or handled only within approved secure environments; staff are explicitly prohibited from sharing insights over any communication medium (including personal conversations in uncontrolled spaces) that would take those insights outside the secure areas.

Insight Compartmentalization

- **No cross-compartment personnel for top compartments:** For the most sensitive compartments, staff work exclusively within a single compartment (or tightly related set) and do not maintain concurrent access to other compartments. Transfers between compartments are treated as rare events requiring formal review and, where appropriate, cooling-off periods.
- **Physical information transfer protocols:** Transfers of data or artifacts between physically separated insight compartments are only performed using approved physical channels (such as controlled removable media) under a formal “two-person rule.” Each transfer is documented, the media and content are checked before and after, and receiving systems are verified to ensure that only the intended information has been imported.
- **Supply chain compartmentalization:** To reduce correlated supply chain risk, procurement and provisioning is compartmentalized for the supply chain’s most sensitive insight environments: key compartments use differing vendors, manufacturing sources, cloud tenants/accounts, or deployment pipelines. A compromise in one supply chain is therefore less likely to grant an attacker access across multiple compartments.

Insider Threat Mitigation and Personnel Security

- **Cleared-personnel access (or equivalent verification process) for specific algorithmic insights:** Access to insights is limited to personnel within a single national clearance regime (e.g., cleared U.S. persons), with no routine sharing with foreign governments or foreign-national staff. Implementing such controls might require coordination with government clearance or vetting mechanisms where applicable.
- **No remote work on algorithmic insights:** Remote work is disallowed for any tasks that involve access to algorithmic insights or systems that can administer those insights. Such work must be conducted exclusively from secured corporate premises that meet defined physical, network, and monitoring requirements; VPN or remote-access solutions cannot be used to bypass this restriction.

- **Onsite living quarters:** Personnel might be required to live onsite or adjacent to facilities housing sensitive insights. This reduces external exposure, limits unsupervised contact opportunities, and enables more continuous oversight and protection for individuals who hold critical algorithmic insights.
- **Travel restrictions:** Travel by staff who have access to the most-sensitive algorithmic insights is restricted, especially travel to jurisdictions or events assessed as high-risk for targeting or recruitment. Travel to such locations requires a prior security review and senior approval and might be disallowed entirely for certain roles or destinations.

Physical and Environmental Security

- **Sensitive compartmented information–level physical protection standards:** Facilities housing the highest-value insights are protected **to the physical and technical security standards** described in *Intelligence Community Standard Number 705: Physical and Technical Security Standards for Sensitive Compartmented Information Facilities*.³⁷

Software Integrity and Supply Chain Assurance

- **Formally verified systems software for proprietary workloads:** Workloads implementing high-sensitivity algorithms run only on formally verified, security-hardened systems software (e.g., formally verified microkernels, such as seL4), making systems significantly harder to exploit.

³⁷ Office of Director of National Intelligence, *Intelligence Community Standard Number 705: Physical and Technical Security Standards for Sensitive Compartmented Information Facilities*, ICS 705-1, September 17, 2010.

Progressive Compartmentalization Across Insight Security Levels

Compartmentalization represents the most significant departure from weight-security approaches, and we present it as both an aspiration and a pragmatic compromise.

The aspiration is to centralize and strictly control sensitive insights, thereby minimizing their distribution and the amount of surface area exposed to theft. The compromise is recognizing that, unlike weights, insights will be extremely difficult to fully centralize.

Securing algorithmic insights requires managing multiple distinct categories of information with different sensitivity and access requirements. In practice, compartment boundaries can be drawn around differences in access needs and medium (e.g., code versus documents versus tacit knowledge) and tightened for techniques with unusually high transferability or shelf life. The progressive compartmentalization measures across ISLs—from organizational policies to technical enforcement to stricter cryptographic separations to, finally, full architectural isolation—reflect the unique challenge of protecting diverse insights while enabling authorized work.

The Compartmentalization Challenge

SMW isolates a single crown-jewel asset (model weights) from unauthorized access. Insight security must instead separate multiple categories of insights and rigorously control information flows between them. **Organizations should determine their own compartmentalization structure that is based on their specific operational contexts, capability portfolios, and risk assessments.** The number of compartments, their boundaries, and which insights belong in each compartment will vary significantly across organizations.

As an illustrative example, an organization might choose to maintain strict boundaries between the following:

- novel architecture designs and training-data processing techniques
- inference-optimization methods and deployment-infrastructure details
- research prototypes and production-system implementations
- existing capabilities and future research directions
- algorithmic innovations that are applicable to general AI development versus innovations that are specific to potentially dangerous capabilities.

However, other organizations might reasonably adopt different compartmentalization schemes depending on their threat models, operational structures, and the nature of their research portfolios.

These boundaries serve two purposes: limiting the “blast radius” from any single compromise and reducing the number of personnel who possess complete knowledge of an organization’s most sensitive techniques. If an adversary gains access to one compartment, strong compartmentalization ensures that the adversary

acquires only a subset of an organization's proprietary insights rather than comprehensive knowledge that could enable the full replication of capabilities.

Progressive Enforcement Across Levels

Compartmentalization grows more rigorous at each ISL, reflecting increasing adversary sophistication:¹

- **ISL2—informal need-to-know practices.** The foundation for compartmentalization is established through need-to-know sharing practices: Sensitive research is shared only with the teams and individuals who need it rather than being broadly accessible across an organization. At this level, compartmentalization relies on managerial discipline and cultural norms rather than formal structures or technical enforcement. Although compartmentalization is lightweight at this step, ISL2 represents a meaningful departure from the open knowledge-sharing culture prevalent at many organizations and could reduce the blast radius of opportunistic compromises.
- **ISL3—formalized compartments with technical enforcement.** The informal need-to-know practices from ISL2 are formalized into documented compartment structures, and compartment boundaries require technical enforcement. This includes documented identification of distinct compartments, maintained authorization lists, and compartment-awareness training alongside technical measures, including a formal codeword or designation system that uniquely identifies each compartment, IAM systems that automatically enforce compartment access restrictions, information-flow monitoring that logs and audits cross-compartment access attempts, and compartment-specific NDAs that explicitly reference each compartment's codeword and handling rules.
- **ISL4—cryptographic separation enforcement.** Compartmentalization achieves cryptographic separation, and each compartment is protected by distinct encryption keys (and, when feasible, separate key-management infrastructure) to ensure that compromise of one compartment's cryptographic material does not expose other compartments'. Kernel-level DLP with file tainting tracks sensitive information at the operating system level: When insight-bearing files are created or accessed, the kernel tags derived artifacts (e.g., copies, exports, intermediate files) and prevents tainted data from being written to unauthorized destinations without explicit, logged exemptions. Cross-compartment shared resources are minimized or eliminated, particularly for high-sensitivity compartments for which shared databases or file systems could create attack vectors. Independent security assessments probe each compartment boundary to verify that technical enforcement mechanisms function as intended and that no shadow access paths exist.
- **ISL5—architectural and physical separation.** The highest-sensitivity compartments operate with complete architectural isolation. Personnel assigned to the most-sensitive compartments work exclusively within a single compartment and do not maintain concurrent access to other compartments; transfers between compartments require formal reviews and, as appropriate, cooling-off periods. Physical information transfer protocols require multiperson reviews for any data movement between air-gapped compartments, and documented verification of both media and content is required before and after the transfer. Supply chain compartmentalization maintains separate procurement channels, vendors, and provisioning pipelines for different compartments, reducing the likelihood that a single supply chain compromise grants access across multiple compartments.

¹ ISL1 does not include dedicated compartmentalization measures. At this level, organizations are focused on establishing baseline security hygiene practices that serve as the necessary foundation on which compartmentalization can later be built. Compartmentalization as a distinct organizational practice begins at ISL2.

It is worth noting that compartmentalization functions as part of a broader security architecture. Although the measures that we describe here focus specifically on separating and protecting distinct insight categories, they work in concert with access controls, network security, physical security, and other protective measures across all SLs. The effectiveness of compartmentalization depends not only on the specific compartment boundaries and enforcement mechanisms but also on an organization's comprehensive implementation of security measures that are appropriate to each level.

Illustrative Scenarios of Compartmentalization in Practice

The following scenarios illustrate how compartmentalization operates at each ISL. Each scenario traces the same moment at a hypothetical frontier AI company ("FrontierOrg"): the training-process team has developed a proprietary *training recipe* (a specific combination of techniques and configurations) that allows the lab to train models to a given capability level using substantially less compute than what competitors use. This recipe resides in the Training Process compartment. A researcher on the Data Curation team, Dr. Chen, needs to understand how the recipe's efficiency depends on the training data's composition because her team is making decisions about what data to prioritize next.

Baseline: No Compartmentalization

FrontierOrg has no formal compartmentalization. Dr. Chen sends a Slack message to a colleague on the Training Process team who pastes the full training recipe—including the specific techniques, hyperparameter configurations, and the internal analysis that produced them—into a shared Slack channel that is visible to dozens of employees. Dr. Chen downloads the document to her laptop.

The complete training recipe is now on a personal device, was transmitted over a commercial messaging platform, and sits in a channel visible to people with no operational need for it. An attacker who compromises any one of those accounts—or Dr. Chen's laptop—obtains an insight worth hundreds of millions of dollars in compute savings. A state-sponsored actor running a spear phishing campaign needs to compromise only a single employee with access to the Slack channel. There is no logging of who accessed what, no detection mechanism, and no way to determine after the fact how many copies of this recipe exist.

Insight Security Level 1: Current Best Practice

FrontierOrg has standard cybersecurity hygiene, including single sign-on processes, MFA, endpoint protection, and encrypted enterprise communications, but it does not have compartmentalization. Dr. Chen messages her colleague on the managed enterprise platform, which logs the exchange. She accesses the Training Process team's internal repository and reads the full recipe.

The infrastructure is secured: Communications are encrypted and logged, documents are centralized, and only authenticated employees can reach internal systems. But any authenticated employee can access any insight. An attacker who compromises a single employee's credential via phishing or credential stuffing gains access to the same repositories that Dr. Chen browsed. The attack surface is the entire employee population, and a single compromised account exposes insights across all domains.

Insight Security Level 2: Need-to-Know Sharing

FrontierOrg has established a need-to-know culture in which sensitive research is shared only with relevant teams. The Training Process team's repository is not broadly accessible. It is limited to team members and those with an explicit need. Dr. Chen, on the Data Curation team, does not have default access to the Train-

ing Process team’s repository. She asks her manager, who then reaches out to the Training Process team lead. The team lead shares a summary of how the recipe’s efficiency varies by data composition rather than sharing the full recipe because the full recipe is not needed for Dr. Chen’s work. This exchange relies on managerial judgment and cultural norms rather than formal authorization systems.

Compared to the baseline, there is now a meaningful boundary between insight domains, even though it is enforced by organizational discipline rather than technical controls. An attacker who compromises Dr. Chen’s account gains access to the Data Curation team’s materials and whatever has been shared with her but not the Training Process team’s repository. The attack surface is significantly narrower than in the ISL1 case in which any authenticated employee could access any repository.

Insight Security Level 3: Formalized Compartmentalization with Technical Enforcement

Compartments are now designated by nondescriptive codewords (e.g., the codeword for the Training Process team is “ALPINE,” and the codeword for the Data Curation team is “SUMMIT”). Employees sign compartment-specific NDAs, information-flow monitoring tracks cross-compartment transfers, and filesystem-level tagging enforces I/O restrictions on insight-bearing data.

Dr. Chen never sees an ALPINE artifact directly. The ALPINE compartment owner authorizes a mediated transfer: An ALPINE-cleared researcher prepares a sanitized summary describing how the recipe’s efficiency varies by data composition without revealing the recipe’s actual techniques or configurations. This summary is transferred through a logged cross-compartment channel, tagged with its origin and classification, and flagged by the information-flow monitoring system, which notes that this is a first-time ALPINE-to-SUMMIT transfer and generates an alert.

An attacker who fully compromises SUMMIT’s environment obtains a sanitized description of data-composition sensitivity, not the recipe itself. More importantly, the monitoring system creates a new obstacle: An attacker attempting to systematically exfiltrate insights by requesting material from multiple compartments would trigger an anomaly-detection alert. In other words, the pattern of cross-compartment requests is itself a signal. A sophisticated insider threat (perhaps an employee recruited by a foreign intelligence service) would face a paper trail of compartment-specific NDAs, logged transfers, and monitored information flows that would constrain the insider threat’s ability to collect information broadly without detection.

Insight Security Level 4: Cryptographically Enforced Compartmentalization

Each compartment operates in its own cryptographic domain with separate encryption keys and separate key-management systems. Kernel-level DLP with file tainting tracks insight-derived data across the filesystem, multiperson controls govern the most-sensitive insights, and each copy of critical data is fingerprinted per recipient.

Dr. Chen’s request now requires dual approval from two authorized ALPINE personnel. The sanitized summary is fingerprinted with a unique marker and cryptographically re-encrypted from ALPINE’s key domain into SUMMIT’s. This process occurs on a hardened transfer system under multiperson control. On SUMMIT systems, kernel-level taint tracking tags any document that Dr. Chen creates that draws on the ALPINE-derived summary, propagating export restrictions to derivative work.

The attacker’s calculus changes fundamentally at this level. Compromising SUMMIT’s infrastructure—even root access to every SUMMIT server—yields nothing about ALPINE because ALPINE’s data are encrypted under entirely separate keys. There is no single point of compromise that unlocks multiple compartments. An insider who exfiltrates material can be traced using fingerprinted documents that enable post hoc attribution, and if the material surfaces in a competitor’s systems or on the open internet, it will trace back to a specific transfer, recipient, and date.

Insight Security Level 5: Physical and Personnel Compartmentalization

ALPINE and SUMMIT researchers work in physically separated, isolated facilities with emanation shielding and stringent access controls. Staff cannot hold concurrent clearances for multiple top-level compartments, and personnel transferring between compartments are required to undergo cooling-off periods. No remote work on algorithmic insights is allowed, and supply chains are compartmentalized across vendors and infrastructure.

Dr. Chen cannot contact an ALPINE researcher because she does not know who works in ALPINE, and ALPINE personnel cannot discuss ALPINE material outside their secure facility. Her request routes through an administrative channel staffed by personnel cleared for metadata but not technical content. Within ALPINE's secure area, two researchers prepare the sanitized summary under multiperson controls, which a security officer then reviews. The transfer occurs under a two-person rule via controlled removable media at a designated physical handoff point. The media is sanitized after transfer.

For a sophisticated state-level adversary—the kind of threat actor that ISL5 is designed to resist—the attack surface has collapsed almost entirely. There is no digital pathway between compartments: no shared network, no shared infrastructure, no shared supply chain. A cyberoperation that compromises SUMMIT's entire digital environment, no matter how sophisticated the operation is, learns nothing about ALPINE. The adversary must mount a separate physical or HUMINT operation against each compartment independently via recruiting or coercing personnel who work exclusively in that compartment, or the adversary must penetrate an isolated, physically hardened facility. Even a successfully recruited insider can access only their own compartment. The cost to the adversary scales with the number of compartments rather than collapsing to a single point of compromise.

Detailed Examples of Algorithmic Insights

In this appendix, we provide concrete examples of algorithmic insights across the three major categories that we identified in this report. These examples illustrate both the diversity of insights that might warrant protection and the varying complexity, transferability, and potential impact of different innovations.

Pretraining and Training-Time Insights

Pretraining and training-time insights cover innovations that change *what is trained* (e.g., architecture, objectives, data) or *how it is trained* (e.g., optimization, numerical formats, distributed systems).

Architectural Innovations

Examples include

- **transformer-style attention architectures** that replace recurrence with self-attention and enable strong scaling with parallel hardware¹
- **sparse or conditional computation architectures** (e.g., mixture-of-experts) that trade dense compute for routing and can improve quality-per-floating-point-operations in some regimes.²

Training Algorithms and Stability Techniques

Examples include

- **optimizer choices** that substantially affect convergence and stability (e.g., Adam³) and commonly used refinements, such as decoupled weight decay (e.g., AdamW)⁴
- **normalization and regularization approaches** that influence training stability and generalization (e.g., LayerNorm, dropout)⁵

¹ Vaswani et al., 2023.

² Noam Shazeer, Azalia Mirhoseini, Krzysztof Maziarczyk, Andy Davis, Quoc Le, Geoffrey Hinton, and Jeff Dean, “Outrageously Large Neural Networks: The Sparsely-Gated Mixture-of-Experts Layer,” arXiv, arXiv:1701.06538, January 23, 2017.

³ Diederik P. Kingma and Jimmy Ba, “Adam: A Method for Stochastic Optimization,” arXiv, arXiv:1412.6980v9, January 30, 2017.

⁴ Ilya Loshchilov and Frank Hutter, “Decoupled Weight Decay Regularization,” arXiv, arXiv:1711.05101v3, January 4, 2019.

⁵ Jimmy Lei Ba, Jamie Ryan Kiros, and Geoffrey E. Hinton, “Layer Normalization,” arXiv, arXiv:1607.06450, July 21, 2016; Nitish Srivastava, Geoffrey Hinton, Alex Krizhevsky, Ilya Sutskever, and Ruslan Salakhutdinov, “Dropout: A Simple Way to Prevent Neural Networks from Overfitting,” *Journal of Machine Learning Research*, Vol. 15, No. 56, 2014.

- **stabilization heuristics**, such as gradient clipping, which is often used to mitigate exploding gradients and other training pathologies.⁶

Distributed Training and Memory-Efficiency Techniques

Examples include

- **activation recomputation or gradient checkpointing**, which reduces a memory footprint by trading compute for memory⁷
- **optimizer-state sharding strategies** (e.g., ZeRO) that reduce memory bottlenecks and enable larger models on fixed hardware budgets.⁸

Numerical Precision and Compute-Efficiency Methods

Examples include

- **mixed-precision training** (e.g., FP16 with loss scaling, BF16, or emerging FP8 formats) that reduces memory bandwidth and accelerates training while maintaining stability⁹
- **quantized optimizer states or 8-bit optimizers**, which reduce memory pressure and can increase throughput in some regimes.¹⁰

Scaling-Law and Compute-Allocation Discoveries

Examples include

- **empirical scaling laws** linking loss and performance to compute, model size, and data, which support more-systematic planning and “budgeting” of training runs¹¹
- **compute-optimal training allocation** results (e.g., “Chinchilla-style” findings) that shift best practices toward more data at fixed compute and away from over-parameterization in some regimes.¹²

⁶ Razvan Pascanu, Tomas Mikolov, and Yoshua Bengio, “On the Difficulty of Training Recurrent Neural Networks,” arXiv, arXiv:1211.5063v2, February 16, 2013.

⁷ Tianqi Chen, Bing Xu, Chiyuan Zhang, and Carlos Guestrin, “Training Deep Nets with Sublinear Memory Cost,” arXiv, arXiv:1604.06174v2, April 22, 2016.

⁸ Samyam Rajbhandari, Jeff Rasley, Olatunji Ruwase, and Yuxiong He, “ZeRO: Memory Optimizations Toward Training Trillion Parameter Models,” arXiv, arXiv:1910.02054v3, May 13, 2020.

⁹ Paulius Micikevicius, Sharan Narang, Jonah Alben, Gregory Diamos, Erich Elsen, David Garcia, Boris Ginsburg, Michael Houston, Oleksii Kuchaiev, Ganesh Venkatesh, et al., “Mixed Precision Training,” arXiv, arXiv:1710.03740v3, February 15, 2018; Paulius Micikevicius, Dusan Stolic, Neil Burgess, Marius Cornea, Pradeep Dubey, Richard Grisenthwaite, Sangwon Ha, Alexander Heinecke, Patrick Judd, John Kamalu, et al., “FP8 Formats for Deep Learning,” arXiv, arXiv:2209.05433v2, September 29, 2022.

¹⁰ Tim Dettmers, Mike Lewis, Sam Shleifer, and Luke Zettlemoyer, “8-Bit Optimizers via Block-Wise Quantization,” arXiv, arXiv:2110.02861v2, June 20, 2022.

¹¹ Jared Kaplan, Sam McCandlish, Tom Henighan, Tom B. Brown, Benjamin Chess, Rewon Child, Scott Gray, Alec Radford, Jeffrey Wu, and Dario Amodei, “Scaling Laws for Neural Language Models,” arXiv, arXiv:2001.08361, January 23, 2020.

¹² Jordan Hoffman, Sebastian Borgeaud, Arthur Mensch, Elena Buchatskaya, Trevor Cai, Eliza Rutherford, Diego de Las Casas, Lisa Anne Hendricks, Johannes Welbl, Aidan Clark, et al., “Training Compute-Optimal Large Language Models,” arXiv, arXiv:2203.15556, March 29, 2022.

Data Strategies and Dataset Engineering

Examples include

- **large-scale curated corpora** used to improve breadth and reduce brittleness via diversity and deduplication (e.g., The Pile)¹³
- **large-scale cleaning and filtering pipelines** (e.g., the “C4” corpus lineage used in Text-To-Text Transfer Transformer-style work) that show how filtering decisions and preprocessing can materially affect downstream performance¹⁴
- **synthetic data regimes and instruction-generation pipelines** (e.g., the Self-Instruct framework), which can shift capability profiles by changing the training distribution, sometimes without changing the model size¹⁵
- **distillation** as a training-time strategy to transfer capability from a larger teacher model into a smaller (or otherwise constrained) student model, changing deployment cost curves.¹⁶

Post-Training Insights

Post-training insights modify a base model *after* pretraining, often with comparatively low incremental compute. These insights frequently combine (1) a **training recipe** (data collection, loss, and an optimizer), (2) **human or model-generated supervision**, and (3) **workflow and tooling** that makes the method operationally repeatable.

Preference Optimization and Reinforcement Learning from Human Feedback–Style Methods

Examples include

- **RLHF-style pipelines** that combine supervised fine-tuning with preference modeling and reinforcement learning to shape helpfulness and instruction-following (e.g., InstructGPT)¹⁷
- **policy optimization algorithms** commonly used in RLHF stacks (e.g., proximal policy optimization), which can matter materially for stability and outcome quality¹⁸

¹³ Leo Gao, Stella Biderman, Sid Black, Laurence Golding, Travis Hoppe, Charles Foster, Jason Phang, Horace He, Anish Thite, Noa Nabeshima, et al., “The Pile: An 800GB Dataset of Diverse Text for Language Modeling,” arXiv, arXiv:2101.00027, December 31, 2020.

¹⁴ Colin Raffel, Noam Shazeer, Adam Roberts, Katherine Lee, Sharan Narang, Michael Matena, Yanqi Zhou, Wei Li, and Peter J. Liu, “Exploring the Limits of Transfer Learning with a Unified Text-to-Text Transformer,” *Journal of Machine Learning Research*, Vol. 21, No. 140, 2020.

¹⁵ Yizhong Wang, Yeganeh Kordi, Swaroop Mishra, Alisa Liu, Noah A. Smith, Daniel Khashabi, and Hannaneh Hajishirzi, “Self-Instruct: Aligning Language Models with Self-Generated Instructions,” arXiv, arXiv:2212.10560v2, May 25, 2023.

¹⁶ Geoffrey Hinton, Oriol Vinyals, and Jeff Dean, “Distilling the Knowledge in a Neural Network,” arXiv, arXiv:1503.02531, March 9, 2015.

¹⁷ Ouyang et al., 2022.

¹⁸ John Schulman, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov, “Proximal Policy Optimization Algorithms,” arXiv, arXiv:1707.06347v2, August 28, 2017.

- **direct preference optimization approaches** that optimize preferences without an explicit reward-model and reinforcement learning loop, which often change operational complexity and sensitivity.¹⁹

Instruction Tuning and Supervised Post-Training

Examples include

- **instruction tuning** results showing that fine-tuning on mixtures of tasks and instructions can induce broad generalization gains relative to pretraining-only baselines²⁰
- **domain- or capability-specific supervised fine-tuning**, in which relatively small, curated datasets can produce large shifts in reliability within targeted domains (and are often paired with a strong evaluation discipline)²¹

Parameter-Efficient Fine-Tuning

Examples include

- **adapters** that introduce small trainable modules while freezing most backbone weights²²
- **low-rank adaptation**, which learns low-rank updates to weight matrices and is widely used for efficient adaptation²³
- **quantization-aware parameter-efficient fine-tuning** (e.g., quantized low-rank adaptation), which combines low-bit quantization with adaptation to reduce memory while maintaining a strong fine-tuning performance in many settings.²⁴

Tool Use and Scaffolding Frameworks

Examples include

- **retrieval-augmented generation**, which improves factuality and coverage by conditioning generation on retrieved context²⁵

¹⁹ Rafael Rafailov, Archit Sharma, Eric Mitchell, Stefano Ermon, Christopher D. Manning, and Chelsea Finn, “Direct Preference Optimization: Your Language Model Is Secretly a Reward Model,” arXiv, arXiv:2305.18290v3, July 29, 2024.

²⁰ Jason Wei, Maarten Bosma, Vincent Y. Zhao, Kelvin Guu, Adams Wei Yu, Brian Lester, Nan Du, Andrew M. Dai, and Quoc V. Le, “Finetuned Language Models Are Zero-Shot Learners,” arXiv, arXiv:2109.01652v5, February 8, 2022.

²¹ Wei et al., 2022.

²² Neil Houlsby, Andrei Giurgiu, Stanislaw Jastrzebski, Bruna Morrone, Quentin de Laroussilhe, Andrea Gesmundo, Mona Attariyan, and Sylvain Gelly, “Parameter-Efficient Transfer Learning for NLP,” arXiv, arXiv:1902.00751v2, June 13, 2019.

²³ Edward J. Hu, Yelong Shen, Phillip Wallis, Zeyuan Allen-Zhu, Yanzhi Li, Shean Wang, Lu Wang, and Weizhu Chen, “LoRA: Low-Rank Adaptation of Large Language Models,” arXiv, arXiv:2106.09685v2, October 16, 2021.

²⁴ Tim Dettmers, Artidoro Pagnoni, Ari Holtzman, and Luke Zettlemoyer, “QLoRA: Efficient Finetuning of Quantized LLMs,” arXiv, arXiv:2305.14314, May 23, 2023.

²⁵ Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” arXiv, arXiv:2005.11401v4, April 12, 2021.

- **tool- and action-augmented prompting frameworks** (e.g., ReAct) that interleave reasoning and actions (e.g., search, calculation, calling tools) to improve multistep task performance²⁶
- **self-supervised tool-use induction** methods (e.g., Toolformer) that teach models to decide *when* to call tools and how to incorporate results²⁷
- **reasoning scaffolds**, such as chain-of-thought prompting, which can substantially change observed problem-solving behavior without changing weights.²⁸

Verification and Judge or Critic Training

An example is **verifier training** for structured tasks (e.g., step-by-step math), in which a separate model or head is trained to evaluate candidate solutions and can be used to select or refine outputs.²⁹

Inference and Deployment Optimization Insights

Inference and deployment insights reduce cost and latency, improve throughput, or change the operational feasibility. In practice, these insights often appear as **kernel-level techniques**, **systems-design patterns**, and **serving-time algorithms**.

GPU-Kernel and Attention-Mechanism Optimizations

Examples are **FlashAttention-style I/O-aware attention kernels**, which reorganize attention computation to reduce memory reads and writes and improve throughput for long contexts.³⁰

Serving Infrastructure and Memory Management

Examples include

- **paged or virtual-memory-like key-value-cache management** for LLM serving (e.g., vLLM’s “Paged-Attention” framing), enabling higher-use and better-batching behavior under variable-length generation³¹
- **continuous batching and request-scheduling strategies**, which are often tightly coupled with key-value-cache design and can meaningfully affect production economics.³²

²⁶ Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao, “ReAct: Synergizing Reasoning and Acting in Language Models,” arXiv, arXiv:2210.03629v3, March 10, 2023.

²⁷ Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom, “Toolformer: Language Models Can Teach Themselves to Use Tools,” arXiv, arXiv:2302.04761, February 9, 2023.

²⁸ Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Brian Ichter, Fei Xia, Ed Chi, Quoc Le, Denny Zhou, “Chain-of-Thought Prompting Elicits Reasoning in Large Language Models,” arXiv, arXiv:2201.11903v6, January 10, 2023.

²⁹ Karl Cobbe, Vineet Kosaraju, Mohammad Bavarian, Mark Chen, Heewoo Jun, Lukasz Kaiser, Matthias Plappert, Jerry Tworek, Jacob Hilton, Reiichiro Nakano, et al., “Training Verifiers to Solve Math Word Problems,” arXiv, arXiv:2110.14168v2, November 18, 2021.

³⁰ Tri Dao, Daniel Y. Fu, Stefano Ermon, Atri Rudra, and Christopher Ré, “FlashAttention: Fast and Memory-Efficient Exact Attention with IO-Awareness,” arXiv, arXiv:2205.14135v2, June 23, 2022.

³¹ Kwon et al., 2023.

³² Kwon et al., 2023.

Compression: Quantization and Pruning

Examples include

- **8-bit inference and quantized matmul strategies** that preserve quality while reducing memory bandwidth requirements (e.g., LLM.int8)³³
- **post-training quantization for generative transformers** (e.g., generalized post-training quantization-style approaches), shifting the trade space between accuracy, speed, and engineering complexity³⁴
- **Model compression “bundles”** (i.e., pruning, quantization, coding) that historically demonstrated large compression factors with tolerable quality loss in some regimes.³⁵

Decoding-Time Algorithms

An example is **speculative decoding**, which accelerates generation by using a smaller draft model and verifying with a larger model, improving latency and throughput in some serving regimes.³⁶

Prompt Engineering and Interaction Methods

Examples include

- **few-shot prompting** as a capability elicitation method for LLMs (popularized in GPT-3-style work)³⁷
- **chain-of-thought prompting** as a prompting strategy that can change performance on reasoning-style tasks³⁸
- **zero-shot “let’s think step by step”-style prompting**, showing that even minimal prompting changes can elicit different behaviors in some LLMs.³⁹

³³ Tim Dettmers, Mike Lewis, Younes Belkada, and Luke Zettlemoyer, “LLM.int8(): 8-Bit Matrix Multiplication for Transformers at Scale,” arXiv, arXiv:2208.07339v2, November 10, 2022.

³⁴ Elias Frantar, Saleh Ashkboos, Torsten Hoefler, and Dan Alistarh, “GPTQ: Accurate Post-Training Quantization for Generative Pre-Trained Transformers,” arXiv, arXiv:2210.17323v2, March 22, 2023.

³⁵ Song Han, Huizi Mao, and William J. Dally, “Deep Compression: Compressing Deep Neural Networks with Pruning, Trained Quantization and Huffman Coding,” arXiv, arXiv:1510.00149v5, February 15, 2016.

³⁶ Yaniv Leviathan, Matan Kalman, and Yossi Matias, “Fast Inference from Transformers via Speculative Decoding,” arXiv, arXiv:2211.17192v2, May 18, 2023.

³⁷ Tom B. Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al., “Language Models Are Few-Shot Learners,” arXiv, arXiv:2005.14165v4, July 22, 2020.

³⁸ Wei et al., 2022.

³⁹ Takeshi Kojima, Shixiang Shane Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa, “Large Language Models Are Zero-Shot Reasoners,” arXiv, arXiv:2205.11916v4, January 29, 2023.

Abbreviations

ABAC	attribute-based access controls
AI	artificial intelligence
API	application programming interface
BYOD	bring your own device
CAST	Center on AI, Security, and Technology
CI/CD	continuous integration and continuous deployment
DLP	data-loss prevention
DNS	domain name system
EDR	endpoint detection and response
EM	electromagnetic
GPU	graphics processing unit
HUMINT	human intelligence
IAM	identity and access management
IDS	intrusion detection systems
I/O	input/output
IoT	Internet of Things
IP	intellectual property
ISL	insight security level
LLM	large language model
MDM	mobile device management
MFA	multifactor authentication
ML	machine learning
NDA	nondisclosure agreement
NIST	National Institute of Standards and Technology
OC	operational capacity
OPSEC	operational security
OTA	over the air
PIDS	perimeter intrusion detection systems
RBAC	role-based access controls
RF	radio frequency
RLHF	reinforcement learning from human feedback
SBOM	software bill of materials
SL	security level
SMW	<i>Securing AI Model Weights</i>
SP	Special Publication
UEBA	user and entity behavior analytics
USB	universal serial bus
VPN	virtual private network
WSL	weight security level

References

- Ablon, Lillian, and Andy Bogart, *Zero Days, Thousands of Nights: The Life and Times of Zero-Day Vulnerabilities and Their Exploits*, RAND Corporation, RR-1751-RC, 2017. As of June 22, 2026:
https://www.rand.org/pubs/research_reports/RR1751.html
- Akamai Security Intelligence Group, “XZ Utils Backdoor—Everything You Need to Know, and What You Can Do,” *Akamai Blog*, April 1, 2024. As of December 23, 2025:
<https://www.akamai.com/blog/security-research/critical-linux-backdoor-xz-utils-discovered-what-to-know>
- Ampflab, “X644ACS Directional Microphone Technical Specifications and Operating Manual: Microphone Array Designed for Long Range Audio Surveillance,” webpage, undated. As of December 22, 2025:
<https://ampflab.com/long-range-directional-microphone-X64ACS.html>
- Anthropic, “Claude’s Extended Thinking,” press release, February 24, 2025.
- Apriorit, “How to Secure and Manage File Access with SELinux,” *Software Development* blog, November 9, 2023. As of December 19, 2025:
<https://www.apriorit.com/dev-blog/cybersecurity-managing-file-access-with-selinux>
- ARMIS, “BlueBorne Cyber Threat Impacts Amazon Echo and Google Home,” November 14, 2017. As of December 23, 2025:
<https://www.armis.com/blog/blueborne-cyber-threat-impacts-amazon-echo-and-google-home/>
- Arntz, Pieter, “WhisperPair Exposes Bluetooth Earbuds and Headphones to Tracking and Eavesdropping,” *Malwarebytes* blog, January 16, 2026. As of May 28, 2026:
<https://www.malwarebytes.com/blog/news/2026/01/whisperpair-exposes-bluetooth-earbuds-and-headphones-to-tracking-and-eavesdropping>
- Artenstein, Nitay, “Broadpwn: Remotely Compromising Android and iOS via a Bug in Broadcom’s Wi-Fi Chipsets,” *Exodus Blog*, July 26, 2017. As of December 23, 2025:
<https://blog.exodusintel.com/2017/07/26/broadpwn/>
- Ba, Jimmy Lei, Jamie Ryan Kiros, and Geoffrey E. Hinton, “Layer Normalization,” arXiv, arXiv:1607.06450, July 21, 2016.
- Barker, Elaine, Quynh Dang, Sheila Frankel, Karen Scarfone, and Paul Wouters, *Guide to IPsec VPNs*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-77, Revision 1, June 2020.
- Black, Paul E., Barbara Guttman, and Vadim Okun, *Guidelines on Minimum Standards for Developer Verification of Software*, National Institute of Standards and Technology, U.S. Department of Commerce, NISTIR 8397, October 2021.
- Boyens, Jon, Angela Smith, Nadya Bartol, Kris Winkler, Alex Holbrook, and Matthew Fallon, *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-161r1-upd1, May 2022.
- Brown, Tom B., Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al., “Language Models Are Few-Shot Learners,” arXiv, arXiv:2005.14165v4, July 22, 2020.
- Buchanan, Ben, *The AI Triad and What It Means for National Security Strategy*, Center for Security and Emerging Technology, August 2020.
- Cannane, Steve, Sashka Koloff, and Brigid Andersen, “‘Matter of Death and Life’: Espionage in East Timor and Australia’s Diplomatic Bungle,” ABC News, November 25, 2015.
- Center for Development of Security Excellence, *Accidental Conversations: Elicitation Techniques and the Science Behind Them*, job aid, Defense Counterintelligence and Security Agency, June 2025.
- Chandramouli, Ramaswamy, and Eric A. Hibbard, *Guidelines for Media Sanitization*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-88r2, September 2025.

- Chen, Tianqi, Bing Xu, Chiyuan Zhang, and Carlos Guestrin, “Training Deep Nets with Sublinear Memory Cost,” arXiv, arXiv:1604.06174v2, April 22, 2016.
- Christiano, Paul, Jan Leike, Tom B. Brown, Miljan Martic, Shane Legg, and Dario Amodei, “Deep Reinforcement Learning from Human Preferences,” arXiv, arXiv:1706.03741v4, February 17, 2023.
- Cobbe, Karl, Vineet Kosaraju, Mohammad Bavarian, Mark Chen, Heewoo Jun, Lukasz Kaiser, Matthias Plappert, Jerry Tworek, Jacob Hilton, Reiichiro Nakano, et al., “Training Verifiers to Solve Math Word Problems,” arXiv, arXiv:2110.14168v2, November 18, 2021.
- Cybersecurity and Infrastructure Security Agency, *Capacity Enhancement Guide: Securing Web Browsers and Defending Against Malvertising for Federal Agencies*, U.S. Department of Homeland Security, undated-a.
- Cybersecurity and Infrastructure Security Agency, “Software Bill of Materials (SBOM),” webpage, U.S. Department of Homeland Security, undated-b. As of December 23, 2025: <https://www.cisa.gov/sbom>
- Cybersecurity and Infrastructure Security Agency, “Joint NSA and CISA Guidance on Strengthening Cyber Defense Through Protective DNS,” U.S. Department of Homeland Security, March 4, 2021.
- Dao, Tri, Daniel Y. Fu, Stefano Ermon, Atri Rudra, and Christopher Ré, “FlashAttention: Fast and Memory-Efficient Exact Attention with IO-Awareness,” arXiv, arXiv:2205.14135v2, June 23, 2022.
- Davis, Abe, Michael Rubinstein, Neal Wadhwa, Gautham Mysore, Frédo Durand, and William T. Freeman, “The Visual Microphone: Passive Recovery of Sound from Video,” *ACM Transactions on Graphics*, Vol. 33, No. 4, July 2014.
- Daya Guo, Dejian Yang, Haowei Zhang, Junxiao Song, Peiyi Wang, Qihao Zhu, Runxin Xu, Ruoyu Zhang, Shirong Ma, Xiao Bi, et al., “DeepSeek-R1: Incentivizing Reasoning Capability in LLMs via Reinforcement Learning,” arXiv, arXiv:2501.12948, January 22, 2025.
- Dean, Romeo, *Security Forecast*, AI 2027, April 2025. As of December 19, 2025: <https://ai-2027.com/research/security-forecast>
- Dettmers, Tim, Mike Lewis, Younes Belkada, and Luke Zettlemoyer, “LLM.int8(): 8-Bit Matrix Multiplication for Transformers at Scale,” arXiv, arXiv:2208.07339v2, November 10, 2022.
- Dettmers, Tim, Mike Lewis, Sam Shleifer, and Luke Zettlemoyer, “8-Bit Optimizers via Block-Wise Quantization,” arXiv, arXiv:2110.02861v2, June 20, 2022.
- Dettmers, Tim, Artidoro Pagnoni, Ari Holtzman, and Luke Zettlemoyer, “QLoRA: Efficient Finetuning of Quantized LLMs,” arXiv, arXiv:2305.14314, May 23, 2023.
- Ferraiolo, Hildegard, Ketan Mehta, Nabil Ghadiali, Jason Mohler, Vincent Johnson, and Steven Brady, *Guidelines for the Use of PIV Credentials in Facility Access*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-116, Revision 1, June 2018.
- Frantar, Elias, Saleh Ashkboos, Torsten Hoefler, and Dan Alistarh, “GPTQ: Accurate Post-Training Quantization for Generative Pre-Trained Transformers,” arXiv, arXiv:2210.17323v2, March 22, 2023.
- Frontier Model Forum, homepage, undated. As of June 18, 2026: <https://www.frontiermodelforum.org/>
- Gao, Leo, Stella Biderman, Sid Black, Laurence Golding, Travis Hoppe, Charles Foster, Jason Phang, Horace He, Anish Thite, Noa Nabeshima, et al., “The Pile: An 800GB Dataset of Diverse Text for Language Modeling,” arXiv, arXiv:2101.00027, December 31, 2020.
- Goodwin, Cristin, and Joram Borenstein, “Guarding Against Supply Chain Attacks—Part 2: Hardware Risks,” *Microsoft Security Blog*, February 3, 2020. As of December 23, 2025: <https://www.microsoft.com/en-us/security/blog/2020/02/03/guarding-against-supply-chain-attacks-part-2-hardware-risks/>
- Gundlach, Hans, Jayson Lynch, Matthias Mertens, and Neil Thompson, “The Price of Progress: Algorithmic Efficiency and the Falling Cost of AI Inference,” arXiv, arXiv:2511.23455, November 28, 2025.
- Han, Song, Huizi Mao, and William J. Dally, “Deep Compression: Compressing Deep Neural Networks with Pruning, Trained Quantization and Huffman Coding,” arXiv, arXiv:1510.00149v5, February 15, 2016.

- Hinton, Geoffrey, Oriol Vinyals, and Jeff Dean, “Distilling the Knowledge in a Neural Network,” arXiv, arXiv:1503.02531, March 9, 2015.
- Ho, Anson, Tamay Besiroglu, Ege Erdil, David Owen, Robi Rahman, Zifan Carl Guo, David Atkinson, Neil Thompson, and Jaime Sevilla, “Algorithmic Progress in Language Models,” arXiv, arXiv:2403.05812, March 9, 2024.
- Hoffman, Jordan, Sebastian Borgeaud, Arthur Mensch, Elena Buchatskaya, Trevor Cai, Eliza Rutherford, Diego de Las Casas, Lisa Anne Hendricks, Johannes Welbl, Aidan Clark, et al., “Training Compute-Optimal Large Language Models,” arXiv, arXiv:2203.15556, March 29, 2022.
- Houlsby, Neil, Andrei Giurgiu, Stanislaw Jastrzebski, Bruna Morrone, Quentin de Laroussilhe, Andrea Gesmundo, Mona Attariyan, and Sylvain Gelly, “Parameter-Efficient Transfer Learning for NLP,” arXiv, arXiv:1902.00751v2, June 13, 2019.
- Howell, Gema, Joshua M. Franklin, Vincent Sritapan, Murugiah Souppaya, and Karen Scarfone, *Guidelines for Managing the Security of Mobile Devices in the Enterprise*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-124r2, May 2023.
- Hu, Edward J., Yelong Shen, Phillip Wallis, Zeyuan Allen-Zhu, Yuanzhi Li, Shean Wang, Lu Wang, and Weizhu Chen, “LoRA: Low-Rank Adaptation of Large Language Models,” arXiv, arXiv:2106.09685v2, October 16, 2021.
- Hu, Vincent C., David Ferraiolo, Richard Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone, *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-162, January 2014.
- Hubinger, Evan, Carson Denison, Jesse Mu, Mike Lambert, Meg Tong, Monte MacDiarmid, Tamera Lanham, Daniel M. Ziegler, Tim Maxwell, Newton Cheng, et al., “Sleepers Agents: Training Deceptive LLMs That Persist Through Safety Training,” arXiv, arXiv:2401.05566v3, January 17, 2024.
- Information Technology Laboratory, *Module-Lattice-Based Digital Signature Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 204, August 13, 2024a.
- Information Technology Laboratory, *Module-Lattice-Based Key-Encapsulation Mechanism Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 203, August 13, 2024b.
- Information Technology Laboratory, *Stateless Hash-Based Digital Signature Standard*, National Institute of Standards and Technology, U.S. Department of Commerce, FIPS 205, August 13, 2024c.
- Joint Task Force, *Security and Privacy Controls for Information Systems and Organizations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-53, Revision 5, September 2020.
- Kaplan, Jared, Sam McCandlish, Tom Henighan, Tom B. Brown, Benjamin Chess, Rewon Child, Scott Gray, Alec Radford, Jeffrey Wu, and Dario Amodei, “Scaling Laws for Neural Language Models,” arXiv, arXiv:2001.08361, January 23, 2020.
- Kingma, Diederik P., and Jimmy Ba, “Adam: A Method for Stochastic Optimization,” arXiv, arXiv:1412.6980v9, January 30, 2017.
- Knightley, Phillip, “The History of the Honey Trap,” *Foreign Policy*, March 12, 2010.
- Kojima, Takeshi, Shixiang Shane Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa, “Large Language Models Are Zero-Shot Reasoners,” arXiv, arXiv:2205.11916v4, January 29, 2023.
- Kwon, Woosuk, Zhuohan Li, Siyuan Zhuang, Ying Sheng, Lianmin Zheng, Cody Hao Yu, Joseph E. Gonzalez, Hao Zhang, and Ion Stoica, “Efficient Memory Management for Larger Language Model Serving with PagedAttention,” *SOSP’23: Proceedings of the 29th Symposium on Operating Systems Principles*, October 2023.
- Levene, David, “Causes of Vulnerabilities and Key Threats to Defense Supply Chains,” *Wild Blue Yonder*, June 6, 2025.
- Leviathan, Yaniv, Matan Kalman, and Yossi Matias, “Fast Inference from Transformers via Speculative Decoding,” arXiv, arXiv:2211.17192v2, May 18, 2023.
- Lewis, Patrick, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” arXiv, arXiv:2005.11401v4, April 12, 2021.

- Liu, Aixin, Bei Feng, Bing Xue, Bingxuan Wang, Bochao Wu, Chengda Lu, Chenggang Zhao, Chengqi Deng, Chenyu Zhang, Chong Ruan, et al., “DeepSeek-V3 Technical Report,” arXiv, arXiv:2412.19437v2, February 18, 2025.
- Liu, Zhuoran, Niels Samwel, Léo Weissbart, Zhengyu Zhao, Dirk Lauret, Lejla Batina, and Martha Larson, “Screen Gleaning: A Screen Reading TEMPEST Attack on Mobile Devices Exploiting an Electromagnetic Side Channel,” paper presented at the Network and Distributed Systems Security (NDSS) Symposium, virtual, February 21–25, 2021.
- Loshchilov, Ilya, and Frank Hutter, “Decoupled Weight Decay Regularization,” arXiv, arXiv:1711.05101v3, January 4, 2019.
- Marvin, Ggaliwango, Nakayiza Hellen, Daudi Jjingo, and Joyce Nakatumba-Nabende, “Prompt Engineering in Large Language Models,” in I. Jeena Jacob, Selwyn Piramuthu, and Przemyslaw Falkowski-Gilski, eds., *Data Intelligence and Cognitive Informatics: Proceedings of ICDICI 2023*, Springer, 2024.
- Matsakis, Louise, “Hackable Touchscreens Could Spy on Hotel Rooms and Meetings,” *Wired*, August 10, 2018.
- Mayraz, Omer, “CamoLeak: Critical GitHub Copilot Vulnerability Leaks Private Source Code,” *Legit* blog, last updated February 12, 2026. As of December 22, 2025:
<https://www.legitsecurity.com/blog/camoleak-critical-github-copilot-vulnerability-leaks-private-source-code>
- McKay, Kerry A., and David A. Cooper, *Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-52, Revision 2, August 2019.
- Merritt, Marian, Susan Hansche, Brenda Ellis, Kevin Sanchez-Cherry, Julie Nethery Snyder, and Donald Walden, *Building a Cybersecurity and Privacy Learning Program*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST SP 800-50r1, September 2024.
- Miciekevicius, Paulius, Sharan Narang, Jonah Alben, Gregory Diamos, Erich Elsen, David Garcia, Boris Ginsburg, Michael Houston, Oleksii Kuchaiev, Ganesh Venkatesh, et al., “Mixed Precision Training,” arXiv, arXiv:1710.03740v3, February 15, 2018.
- Miciekevicius, Paulius, Dusan Stosic, Neil Burgess, Marius Cornea, Pradeep Dubey, Richard Grisenthwaite, Sangwon Ha, Alexander Heinecke, Patrick Judd, John Kamalu, et al., “FP8 Formats for Deep Learning,” arXiv, arXiv:2209.05433v2, September 29, 2022.
- Mitre, Jim, and Joel B. Predd, *Artificial General Intelligence’s Five Hard National Security Problems*, RAND Corporation, PE-A3691-4, February 2025. As of June 3, 2026:
<https://www.rand.org/pubs/perspectives/PEA3691-4.html>
- National Security Agency, Cybersecurity and Infrastructure Agency, Federal Bureau of Investigation, Australian Signals Directorate’s Australian Cyber Security Centre, New Zealand’s National Cyber Security Centre, and United Kingdom’s National Cyber Security Centre, “AI Data Security: Best Practices for Securing Data Used to Train & Operate AI Systems,” fact sheet, U/OO/157249-25, PP-25-2301, May 2025.
- National Security Commission on Artificial Intelligence, “Emerging Threats in the AI Era,” in *Final Report*, 2021.
- Nevo, Sella, Dan Lahav, Ajay Karpur, Yogev Bar-On, Henry Alexander Bradley, and Jeff Alstott, *Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models*, RAND Corporation, RR-A2849-1, 2024. As of December 19, 2025:
https://www.rand.org/pubs/research_reports/RRA2849-1.html
- Nozomi Networks Labs, “Over-the-Air Vulnerabilities Discovered in Advantech EKI Access Points,” *OT & IoT Security Blog*, November 27, 2024.
- Office of Director of National Intelligence, *Intelligence Community Standard Number 705: Physical and Technical Security Standards for Sensitive Compartmented Information Facilities*, ICS 705-1, September 17, 2010.
- Office of Public Affairs, “Superseding Indictment Charges Chinese National in Relation to Alleged Plan to Steal Proprietary AI Technology,” press release, U.S. Department of Justice, February 4, 2025.
- Ouyang, Long, Jeff Wu, Xu Jiang, Diogo Almeida, Carroll L. Wainwright, Pamela Mishkin, Chong Zhang, Sandhini Agarwal, Katarina Slama, Alex Ray, et al., “Training Language Models to Follow Instructions with Human Feedback,” arXiv, arXiv:2203.02155, March 4, 2022.

- Pascanu, Razvan, Tomas Mikolov, and Yoshua Bengio, “On the Difficulty of Training Recurrent Neural Networks,” arXiv, arXiv:1211.5063v2, February 16, 2013.
- Patel, Dylan, A. J. Kourabi, Doug, and Reyk Knuhtsen, “DeepSeek Debates: Chinese Leadership on Cost, True Training Cost, Closed Model Margin Impacts,” SemiAnalysis, January 30, 2025.
- Ponemon Institute, *Global Visual Hacking Experimental Study: Analysis*, August 2016.
- PyTorch Foundation, “Compromised PyTorch-Nightly Dependency Chain Between December 25th and December 30th, 2022,” *PyTorch* blog, December 31, 2022. As of December 23, 2025: <https://pytorch.org/blog/compromised-nightly-dependency/>
- Rafailov, Rafael, Archit Sharma, Eric Mitchell, Stefano Ermon, Christopher D. Manning, and Chelsea Finn, “Direct Preference Optimization: Your Language Model Is Secretly a Reward Model,” arXiv, arXiv:2305.18290v3, July 29, 2024.
- Raffel, Colin, Noam Shazeer, Adam Roberts, Katherine Lee, Sharan Narang, Michael Matena, Yanqi Zhou, Wei Li, and Peter J. Liu, “Exploring the Limits of Transfer Learning with a Unified Text-to-Text Transformer,” *Journal of Machine Learning Research*, Vol. 21, No. 140, 2020.
- Rajbhandari, Samyam, Jeff Rasley, Olatunji Ruwase, and Yuxiong He, “ZeRO: Memory Optimizations Toward Training Trillion Parameter Models,” arXiv, arXiv:1910.02054v3, May 13, 2020.
- Randolph, Kyle, and Martin Hunt, *Summary: March 9, 2021 Security Incident Report*, Verkada, May 21, 2021.
- Red Hat, “4.7. SELinux Contexts—Labeling Files,” webpage, undated. As of December 19, 2025: https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/sect-security-enhanced_linux-working_with_selinux-selinux_contexts_labeling_files
- Reuvers, Paul, and Marc Simons, “The Great Seal Bug,” Crypto Museum, September 18, 2015.
- Rose, Scott, Oliver Borchert, Stu Mitchell, and Sean Connelly, *Zero Trust Architecture*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-207, August 2020.
- Scarfone, Karen, and Peter Mell, *Guide to Intrusion Detection and Prevention Systems (IDPS): Recommendations of the National Institute of Standards and Technology*, National Institute of Standards and Technology, U.S. Department of Commerce, Special Publication 800-94, February 2007.
- Scarfone, Karen, Murugiah Souppaya, and Matt Sexton, *Guide to Storage Encryption Technologies for End User Devices: Recommendations of the National Institute of Standards and Technology*, National Institute of Standards and Technology, U.S. Department of Commerce, Special Publication 800-111, November 2007.
- Schick, Timo, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom, “Toolformer: Language Models Can Teach Themselves to Use Tools,” arXiv, arXiv:2302.04761, February 9, 2023.
- Schneier, Bruce, “Cisco Shipping Equipment to Fake Addresses to Foil NSA Interception,” *Schneier on Security* blog, March 20, 2015. As of June 1, 2026: https://www.schneier.com/blog/archives/2015/03/cisco_shipping_.html
- Schulman, John, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov, “Proximal Policy Optimization Algorithms,” arXiv, arXiv:1707.06347v2, August 28, 2017.
- Schuster, Roei, Congzheng Song, Eran Tromer, and Vitaly Shmatikov, “You Autocomplete Me: Poisoning Vulnerabilities in Neural Code Completion,” *Proceedings of the 30th USENIX Security Symposium*, August 2021.
- Shazeer, Noam, Azalia Mirhoseini, Krzysztof Maziarsz, Andy Davis, Quoc Le, Geoffrey Hinton, and Jeff Dean, “Outrageously Large Neural Networks: The Sparsely-Gated Mixture-of-Experts Layer,” arXiv, arXiv:1701.06538, January 23, 2017.
- Souppaya, Murugiah, and Karen Scarfone, *Guide to Malware Incident Prevention and Handling for Desktops and Laptops*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-83, Revision 1, July 2013.
- Souppaya, Murugiah, and Karen Scarfone, *Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-46, Revision 2, July 2016.

Souppaya, Murugiah, Karen Scarfone, and Donna Dodson, *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*, National Institute of Standards and Technology, U.S. Department of Commerce, NIST Special Publication 800-218, February 2022.

Srivastava, Nitish, Geoffrey Hinton, Alex Krizhevsky, Ilya Sutskever, and Ruslan Salakhutdinov, “Dropout: A Simple Way to Prevent Neural Networks from Overfitting,” *Journal of Machine Learning Research*, Vol. 15, No. 56, 2014.

United States v. Tabora, Appellee, 635 F.2d 131, 2d Cir., November 24, 1980.

U.S. Attorney’s Office, Southern District of California, “Shipyard Contractor Sentenced to Prison for Stealing Almost \$600,000 Worth of Computer Equipment from the U.S. Navy,” press release, U.S. Department of Justice, July 10, 2024.

Vaswani, Ashish, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N. Gomez, Lukasz Kaiser, and Illia Polosukhin, “Attention Is All You Need,” arXiv, arXiv:1706.03762v7, August 2, 2023.

Wang, Yizhong, Yeganeh Kordi, Swaroop Mishra, Alisa Liu, Noah A. Smith, Daniel Khashabi, and Hannaneh Hajishirzi, “Self-Instruct: Aligning Language Models with Self-Generated Instructions,” arXiv, arXiv:2212.10560v2, May 25, 2023.

Wei, Jason, Maarten Bosma, Vincent Y. Zhao, Kelvin Guu, Adams Wei Yu, Brian Lester, Nan Du, Andrew M. Dai, and Quoc V. Le, “Finetuned Language Models Are Zero-Shot Learners,” arXiv, arXiv:2109.01652v5, February 8, 2022.

Wei, Jason, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Brian Ichter, Fei Xia, Ed Chi, Quoc Le, and Denny Zhou, “Chain-of-Thought Prompting Elicits Reasoning in Large Language Models,” arXiv, arXiv:2201.11903v6, January 10, 2023.

White House, *National Security Strategy of the United States of America*, November 2025.

Yao, Shunyu, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao, “ReAct: Synergizing Reasoning and Acting in Language Models,” arXiv, arXiv:2210.03629v3, March 10, 2023.

Zetter, Kim, “Suite of Sophisticated Nation-State Attack Tools Found with Connection to Stuxnet,” *Wired*, February 16, 2015.

Zhao, Kaixiang, Lincan Li, Kaize Ding, Neil Zhenqiang Gong, Yue Zhao, and Yushun Dong, “A Systematic Survey of Model Extraction Attacks and Defenses: State-of-the-Art and Perspectives,” arXiv, arXiv:2508.15031, August 20, 2025.

About the Authors

Asher Brass-Gershovich is a technical researcher at RAND. Work on this report was conducted while he was a senior researcher at the Institute for AI Policy and Strategy. His work focuses on AI security and compute policy, including AI data center security and AI chip location verification. He is also a co-founder of the Heron AI Security Initiative, and a Standards Fellow at ALTER. He holds a B.A. in political science and international relations from the Open University of Israel. Asher and Rachel Steratore contributed equally to the writing of this report.

Rachel Steratore is a sociotechnical researcher at RAND. She conducts technical and policy research on how people interpret, evaluate, and trust AI and other emerging technologies, with the goal of supporting transparent, safe, and equitable innovation. Her work integrates cognitive research, systems thinking, and governance strategies to inform national programs and institutional decisionmaking on AI evaluation, risk assessment, and technology policy. She holds a Ph.D. in engineering and public policy. Rachel and Asher Brass-Gershovich contributed equally to the writing of this report.

Wesley Hurd is a technical analyst at RAND engaged in AI and information security governance, standards development, and analysis. He has extensive information security and systems experience in private industry. He holds a B.S. in computer science and is completing an M.A. in religious studies.

Henry Alexander Bradley is a research assistant at RAND working on projects related to AI, information security, and biosecurity. He has experience in programming, ML, LLMs, and modeling and simulation, as well as a background in qualitative research methods. He holds a B.S. in computer science.

Anjay Friedman is a researcher at RAND focused on AI verification, governance, and security. He holds a B.S. in computer science.

Sella Nevo is a principal researcher at RAND and the director of the RAND Center on AI, Security, and Technology. He conducts technical and policy research at the intersection of national security and emerging technology. Nevo holds a dual B.S. degree in computer science and mathematics.